MediLens — Kế hoạch dự án Healthcare từ A đến Z

Oct 16, 2026 · @N

1. Tổng quan & tầm nhìn

MediLens là web app giúp bệnh nhân **hiểu bệnh án của chính mình**: scan bệnh án (OCR) → AI trích xuất chẩn đoán, vị trí tổn thương, chỉ số → hiển thị trên mô hình cơ thể 3D/2D và sơ đồ nội tạng theo từng Khoa, kèm dòng thời gian trước/sau điều trị. Dự án được làm như một dự án doanh nghiệp: đủ quy trình, tài liệu, kiểm thử, bảo mật, vận hành — nhưng do một người đảm nhận mọi role.

Tên làm việc: MediLens (đổi tùy ý). **Thời gian đề xuất:** 9–12 tháng part-time (~20 giờ/tuần) hoặc 5–6 tháng full-time.

Mục tiêu (đo được)

#	Mục tiêu	Thước đo thành công
G1	Bệnh nhân tải lên bệnh án và thấy tổn thương trên mô hình cơ thể	≥ 85% tài liệu test được trích xuất và gắn đúng vùng cơ thể
G2	Giải thích bệnh dễ hiểu, có nguồn, không thay thế bác sĩ	100% câu trả lời AI có trích dẫn nguồn + disclaimer
G3	Theo dõi diễn tiến theo thời gian (pre/post)	Timeline hiển thị ≥ 2 mốc cho cùng một tổn thương
G4	Hệ thống đạt chuẩn "enterprise"	CI/CD, test coverage ≥ 70%, SLO 99.5%, audit log đầy đủ
G5	Bạn học được quy trình dự án lớn	Có đủ bộ tài liệu ở mục 12 (BRD, SRS, ADR, runbook…)

Phạm vi

- **Trong phạm vi:** auth & hồ sơ cá nhân, upload & OCR bệnh án, trích xuất thực thể y khoa, mapping vào vùng giải phẫu, viewer 3D/2D theo Khoa, timeline, giải thích bằng LLM có RAG, chia sẻ với bác sĩ/người thân, admin & audit.

- **Ngoài phạm vi (giai đoạn đầu):** chẩn đoán bệnh, kê đơn, kết nối trực tiếp HIS/EMR bệnh viện, xử lý ảnh DICOM (CT/MRI) chuyên sâu, thanh toán bảo hiểm.

Nguyên tắc dự án

1. **An toàn trước tiên:** app *minh họa và giải thích*, không chẩn đoán. Mọi nội dung AI có nhãn "do AI tạo", độ tin cậy và nguồn.
2. **Dữ liệu giả trước, dữ liệu thật sau:** dùng dữ liệu synthetic/public suốt quá trình phát triển; chỉ dùng dữ liệu thật khi đã có đủ bảo mật và đồng ý.
3. **Human-in-the-loop:** người dùng luôn xem lại và sửa kết quả trích xuất trước khi lưu.
4. **Mọi thứ đều có tài liệu và có thể đo:** mỗi quyết định có ADR, mỗi tính năng có tiêu chí chấp nhận và metric.
5. **Mỗi role một "chiếc mũ":** mỗi tuần dành thời gian riêng cho từng vai trò, viết output đúng như người ở vai trò đó phải nộp.

Cách đọc tài liệu này

Mục 2–4 là phần BA (ý tưởng, đơn vị nghiệp vụ, quy tắc). Mục 5 là roadmap. Mục 6 là kế hoạch cho từng role — đây là phần chính để thực hiện. Mục 7–9 là kỹ thuật. Mục 10–12 là đo lường, rủi ro và nguồn lực. Phần II (mục 13–21) là đặc tả chuyên sâu cấp doanh nghiệp: bảo mật, dữ liệu, Data Engineering, Solution Architecture, Backend, Frontend, dịch vụ AWS, vận hành – bảo trì và bộ AI Skill theo role. Phần III (mục 22–29) rà soát theo chuẩn dự án lớn: pháp lý thiết bị y tế, an toàn lâm sàng, 9 role bổ sung, thiết kế service bảo mật, chiến lược dữ liệu, input đa phương thức, xử lý lệch giải phẫu, chọn model tiết kiệm và kế hoạch 52 tuần. Tab **English** chứa bản tiếng Anh đầy đủ.

2. Giai đoạn 0 – Ý tưởng & khám phá (Discovery)

Discovery kéo dài 3–4 tuần và kết thúc bằng một **Product Brief + BRD được duyệt** (bạn tự duyệt với vai trò Product Owner, dùng checklist ở cuối mục). Không viết code production trong giai đoạn này, chỉ prototype.

2.1 Problem statement

Bệnh nhân nhận bệnh án đầy thuật ngữ, viết tắt, chữ tay, nhiều trang. Họ không hình dung được *tổn thương ở đâu, nặng thế nào, ảnh hưởng gì tới cơ quan khác, thay đổi ra sao sau điều trị*. Bác sĩ có ít thời gian giải thích. MediLens biến bệnh án thành hình ảnh trực quan + giải thích có nguồn.

2.2 Persona

Persona	Mô tả	Nhu cầu chính	Nỗi đau
Bệnh nhân (Patient)	25–65 tuổi, dùng smartphone, không có kiến thức y khoa	Hiểu bệnh, theo dõi tiến triển	Thuật ngữ khó, lo lắng, bệnh án giấy thất lạc
Người chăm sóc (Caregiver)	Con/cha mẹ chăm người bệnh	Xem hồ sơ người thân khi được cho phép	Không có quyền truy cập, thông tin rời rạc
Bác sĩ (Clinician)	Bác sĩ được bệnh nhân chia sẻ	Xem nhanh tóm tắt, sửa trích xuất sai	Thời gian ít, dữ liệu không chuẩn
Quản trị viên (Admin)	Vận hành hệ thống	Quản lý user, nội dung giải phẫu, audit	Sự cố, yêu cầu tuân thủ
Biên tập y khoa (Medical Reviewer)	Người duyệt nội dung (bạn đóng vai)	Duyệt template bệnh, mapping vùng cơ thể	Nội dung sai gây hại

2.3 User journey chính (Patient)

1. Đăng ký → xác thực email/OTP → đồng ý điều khoản & xử lý dữ liệu sức khỏe (consent).
2. Tạo hồ sơ sức khỏe (giới tính sinh học, năm sinh, chiều cao/cân nặng — tùy chọn).
3. Upload ảnh/PDF bệnh án → hệ thống kiểm tra chất lượng ảnh → OCR → trích xuất.
4. Màn hình **Review**: bản gốc bên trái, kết quả trích xuất bên phải; người dùng xác nhận/sửa.
5. Hệ thống phân loại vào Khoa/Unit, đánh dấu vùng tổn thương trên mô hình 3D/2D.
6. Người dùng xoay/zoom mô hình, bấm vào vùng → xem giải thích: là gì, nguyên nhân thường gặp, hệ lụy, khả năng lan/di căn (nếu có), câu hỏi nên hỏi bác sĩ.
7. Upload bệnh án lần sau → timeline so sánh trước/sau.
8. Chia sẻ hồ sơ có thời hạn cho bác sĩ/người thân; nhận nhắc lịch tái khám.

2.4 MVP và các bản sau (MoSCoW)

Tính năng	MVP (v1.0)	v1.5	v2.0
Auth (email, OAuth Google), MFA	Must		
Upload ảnh/PDF, OCR tiếng Việt + Anh	Must		
Trích xuất chẩn đoán, vị trí, mức độ, ngày	Must		
Màn hình review/sửa	Must		
Viewer 2D toàn thân + 3D toàn thân	Must		
3 Khoa đầu tiên: Răng hàm mặt, Nội (Tim mạch), Ung bướu	Must		
Giải thích bằng LLM + RAG có trích dẫn	Must		
Timeline pre/post	Should		
Chia sẻ cho bác sĩ/người thân	Should		
Thêm Khoa: Ngoại, Thận–Tiết niệu, Tiêu hóa, Hô hấp		Could	
Computer Vision trên ảnh chụp tổn thương (da, răng)		Could	
Nhắc lịch, thông báo		Could	
FHIR export/import, tích hợp bệnh viện			Won't (v1)
Mobile app native			Won't (v1)

2.5 Nghiên cứu cần làm

- **Đối thủ / tham khảo:** BioDigital Human, Visible Body, Complete Anatomy (giải phẫu 3D); Ada, K Health (symptom checker); các app hồ sơ sức khỏe tại Việt Nam. Ghi lại: tính năng, cách hiển thị, mô hình kinh doanh, điểm yếu.
- **Phỏng vấn 5–8 người** (bạn bè, người thân từng nằm viện): họ khó hiểu gì trong bệnh án? Muốn xem gì? Sợ gì khi đưa dữ liệu sức khỏe lên mạng?
- **Thu thập mẫu bệnh án** (đã che thông tin) để hiểu bố cục: phiếu khám, giấy ra viện, kết quả xét nghiệm, kết quả giải phẫu bệnh, phiếu chụp X-quang răng.

- **Pháp lý:** Luật 91/2025/QH15 (hiệu lực 01/01/2026) và Nghị định 356/2025/NĐ-CP hướng dẫn Luật (thay Nghị định 13/2023 từ 01/01/2026) về bảo vệ dữ liệu cá nhân (dữ liệu sức khỏe là dữ liệu nhạy cảm); tham khảo HIPAA/GDPR như chuẩn quốc tế.

2.6 Output của giai đoạn 0

- [ ] Product Brief (1–2 trang): vấn đề, người dùng, giá trị, metric North Star
- [ ] Persona + User Journey Map
- [ ] Competitive analysis
- [ ] BRD (Business Requirements Document) v1
- [ ] Lean Canvas / Business Model Canvas
- [ ] Prototype click-through (Figma) cho luồng upload → review → viewer
- [ ] Danh sách giả định và cách kiểm chứng
- [ ] Quyết định Go/No-Go cho MVP

3. Business Units (Khoa & đơn vị con) và domain model

Hệ thống tổ chức theo 3 cấp: **Department (Khoa lớn) → Unit (chuyên khoa/đơn vị con) → Anatomical Region (vùng giải phẫu)**. Mỗi Unit có viewer riêng, bộ từ điển bệnh riêng và quy tắc mapping riêng. MVP làm 3 Unit đầu tiên; kiến trúc phải cho phép thêm Unit mới chỉ bằng cấu hình + asset, không sửa code lõi.

3.1 Danh mục Khoa và Unit

Khoa (Department)	Unit con	Viewer đặc thù	Dữ liệu trích xuất chính	Phase
Răng hàm mặt	Nha khoa tổng quát, Chỉnh nha, Phẫu thuật hàm mặt, Nha chu	Sơ đồ răng 32 răng (FDI 11–48) dạng 2D + mô hình hàm 3D	Số răng, mặt răng (M/D/O/B/L), sâu, mất, trám, implant, viêm nha chu	MVP
Nội khoa	Tim mạch, Hô hấp, Tiêu hóa, Nội tiết, Thần kinh	Tim 3D (4 buồng, van, mạch vành), phổi 2 lá, ống tiêu hóa	Chẩn đoán ICD-10, EF%, huyết áp, chỉ số xét nghiệm	MVP (Tim mạch), v1.5 phần còn lại

Khoa (Department)	Unit con	Viewer đặc thù	Dữ liệu trích xuất chính	Phase
Ngoại khoa	Chấn thương chỉnh hình, Ngoại tổng quát, Ngoại thần kinh	Bộ xương 3D, khớp, vết mổ trên da	Vị trí gãy/tổn thương, bên trái/phải, phương pháp phẫu thuật	v1.5
Thận – Tiết niệu (Bài tiết)	Thận học, Tiết niệu	Thận 2 bên, niệu quản, bàng quang	eGFR, creatinine, sỏi (vị trí, kích thước)	v1.5
Ung bướu	Ung thư theo cơ quan (phổi, gan, vú, đại trực tràng…)	Cơ quan nguyên phát + hạch + vị trí di căn trên toàn thân	Vị trí u, kích thước, TNM, giai đoạn, giải phẫu bệnh, di căn	MVP
Da liễu	Da liễu tổng quát	Bản đồ da toàn thân 2D (trước/sau)	Vị trí, kích thước, loại tổn thương	v2.0 (kết hợp CV)
Mắt, Tai Mũi Họng	Nhãn khoa, TMH	Mắt 3D, sơ đồ tai/mũi/họng	Thị lực, áp lực mắt, vị trí tổn thương	v2.0

3.2 Cấu hình một Unit (Unit Config)

Mỗi Unit được mô tả bằng một file cấu hình (JSON/YAML, lưu trong DB + version):

- `unit_code`, `department_code`, tên VI/EN, icon
- `regions[]`: danh sách vùng giải phẫu, mỗi vùng có `region_code`, mã chuẩn tham chiếu (ví dụ FMA hoặc SNOMED CT body structure), mesh ID trong file 3D, path ID trong SVG 2D, bên (trái/phải/giữa)
- `conditions[]`: bệnh thuộc Unit, mã ICD-10, mức độ (severity scale), vùng mặc định, vùng có thể lan tới
- `extraction_schema`: JSON Schema các trường LLM phải trích xuất cho Unit này
- `visual_rules`: màu theo mức độ, kiểu marker (vùng tô, điểm, đường), animation
- `content_refs`: các bài giải thích trong knowledge base

3.3 Domain model (các thực thể nghiệp vụ)

Thực thể	Ý nghĩa	Quan hệ chính
User	Tài khoản đăng nhập	1 User – n Role; 1 User – 1..n Patient Profile (bản thân + người thân được quản lý)
PatientProfile	Hồ sơ sức khỏe	n MedicalDocument, n Condition, n Observation
MedicalDocument	Một lần upload (ảnh/PDF nhiều trang)	n DocumentPage, 1 ExtractionRun mới nhất
ExtractionRun	Một lần chạy pipeline AI	Phiên bản model, prompt, kết quả thô, điểm tin cậy
Encounter	Lần khám/nhập viện (ngày, nơi khám)	Gom các Condition/Observation cùng lần khám
Condition	Bệnh/chẩn đoán	Thuộc Unit, gắn 1..n BodyFinding, có trạng thái theo thời gian
BodyFinding	Tổn thương trên vùng cơ thể	Region, mức độ, kích thước, bên, ngày ghi nhận
Observation	Chỉ số đo (xét nghiệm, sinh hiệu)	Mã LOINC (nếu map được), giá trị, đơn vị, khoảng tham chiếu
Department / Unit / Region	Danh mục giải phẫu & chuyên khoa	Cây phân cấp
KnowledgeArticle	Bài giải thích y khoa có nguồn	Gắn với Condition/Region, có reviewer và ngày duyệt
ShareGrant	Quyền chia sẻ	Người nhận, phạm vi, thời hạn, trạng thái
Consent	Đồng ý xử lý dữ liệu	Loại, phiên bản điều khoản, thời điểm, thu hồi
AuditEvent	Nhật ký truy cập	Ai, làm gì, với dữ liệu nào, khi nào, từ đâu

Gợi ý học tập: đặt tên thực thể gần với chuẩn **HL7 FHIR** (Patient, Encounter, Condition, Observation, DocumentReference, Consent, AuditEvent). Như vậy sau này export FHIR dễ dàng và bạn học được chuẩn dữ liệu y tế quốc tế.

4. Business Rules (quy tắc nghiệp vụ)

Mỗi rule có mã `BR-xxx` để truy vết tới user story, test case và code (traceability matrix). Rule được viết dạng "Khi… thì… ngoại trừ…" và có test tự động tương ứng.

4.1 Tài khoản & truy cập

Mã	Quy tắc
BR-001	Người dùng phải ≥ 18 tuổi để tự tạo tài khoản; hồ sơ trẻ em chỉ được tạo bởi người giám hộ (Caregiver) và gắn cờ `minor`.
BR-002	Phải đồng ý Điều khoản + Chính sách xử lý dữ liệu sức khỏe trước khi upload tài liệu đầu tiên. Đổi phiên bản điều khoản → yêu cầu đồng ý lại.
BR-003	MFA bắt buộc với role Clinician và Admin; khuyến khích với Patient.
BR-004	Khóa tài khoản 15 phút sau 5 lần đăng nhập sai liên tiếp; gửi email cảnh báo.
BR-005	Phiên đăng nhập hết hạn sau 30 phút không hoạt động; refresh token tối đa 7 ngày, xoay vòng mỗi lần dùng.
BR-006	Phân quyền RBAC + kiểm tra quyền sở hữu (ABAC): Patient chỉ xem hồ sơ của mình hoặc hồ sơ được chia sẻ; Admin **không** xem nội dung y tế nếu không có lý do được ghi log (break-glass).

4.2 Tài liệu & trích xuất AI

Mã	Quy tắc
BR-010	Định dạng chấp nhận: JPG, PNG, HEIC, PDF; ≤ 20 MB/file, ≤ 30 trang/tài liệu.
BR-011	Ảnh bị từ chối nếu độ mờ (Laplacian variance) < ngưỡng hoặc độ phân giải < 1000 px cạnh ngắn; hiển thị hướng dẫn chụp lại.
BR-012	Mỗi trường trích xuất có điểm tin cậy 0–1. Trường < 0.7 được tô vàng và **bắt buộc** người dùng xác nhận.
BR-013	Kết quả AI ở trạng thái `draft` cho tới khi người dùng xác nhận → `confirmed`. Chỉ dữ liệu `confirmed` xuất hiện trên viewer và timeline.
BR-014	Mọi chỉnh sửa của người dùng được lưu lịch sử (ai sửa, giá trị cũ/mới) và dùng làm dữ liệu đánh giá model (nếu người dùng đồng ý).
BR-015	Không thể map vào vùng cơ thể → gán `region = unmapped`, hiển thị trong danh sách thay vì đoán vị trí.
BR-016	Trùng lặp: cùng hash file hoặc cùng ngày khám + cùng nơi khám + cùng chẩn đoán → cảnh báo trùng, không tạo bản ghi mới.
BR-017	Phân loại Unit: dựa trên mã ICD-10 → bảng mapping; nếu một bệnh thuộc nhiều Unit (ví dụ ung thư phổi → Ung bướu + Hô hấp) thì hiển thị ở cả hai, Unit chính là Ung bướu.

4.3 Hiển thị & nội dung y khoa

Mã	Quy tắc
BR-020	Màu mức độ thống nhất toàn hệ thống: xanh (theo dõi), vàng (nhẹ), cam (trung bình), đỏ (nặng), tím (di căn/lan rộng). Luôn kèm ký hiệu/nhãn chữ, không chỉ dùng màu (accessibility).

Mã	Quy tắc
BR-021	Di căn/lan rộng chỉ hiển thị khi bệnh án ghi rõ (ví dụ M1, "di căn gan"). Phần "khả năng lan tới" là nội dung giáo dục chung, hiển thị tách biệt với nhãn "thông tin tham khảo, không phải tình trạng của bạn".
BR-022	Giải thích LLM chỉ được trả lời dựa trên knowledge base đã duyệt (RAG) + dữ liệu của chính người dùng; không có nguồn → trả lời "chưa có thông tin, hãy hỏi bác sĩ".
BR-023	LLM không đưa ra liều thuốc, không đề nghị ngừng/đổi thuốc, không tiên lượng thời gian sống. Phát hiện câu hỏi khẩn cấp (đau ngực, khó thở, ý định tự hại) → hiển thị số cấp cứu 115 và hướng dẫn đi khám ngay.
BR-024	Mỗi KnowledgeArticle phải có nguồn (WHO, Bộ Y tế, NIH/MedlinePlus, hướng dẫn chuyên ngành), người duyệt và ngày duyệt; quá 12 tháng → tự động đánh dấu cần duyệt lại.
BR-025	Timeline so sánh pre/post chỉ giữa các BodyFinding cùng Region và cùng Condition; khác đơn vị đo → quy đổi hoặc không so sánh.

4.4 Chia sẻ, lưu trữ & quyền dữ liệu

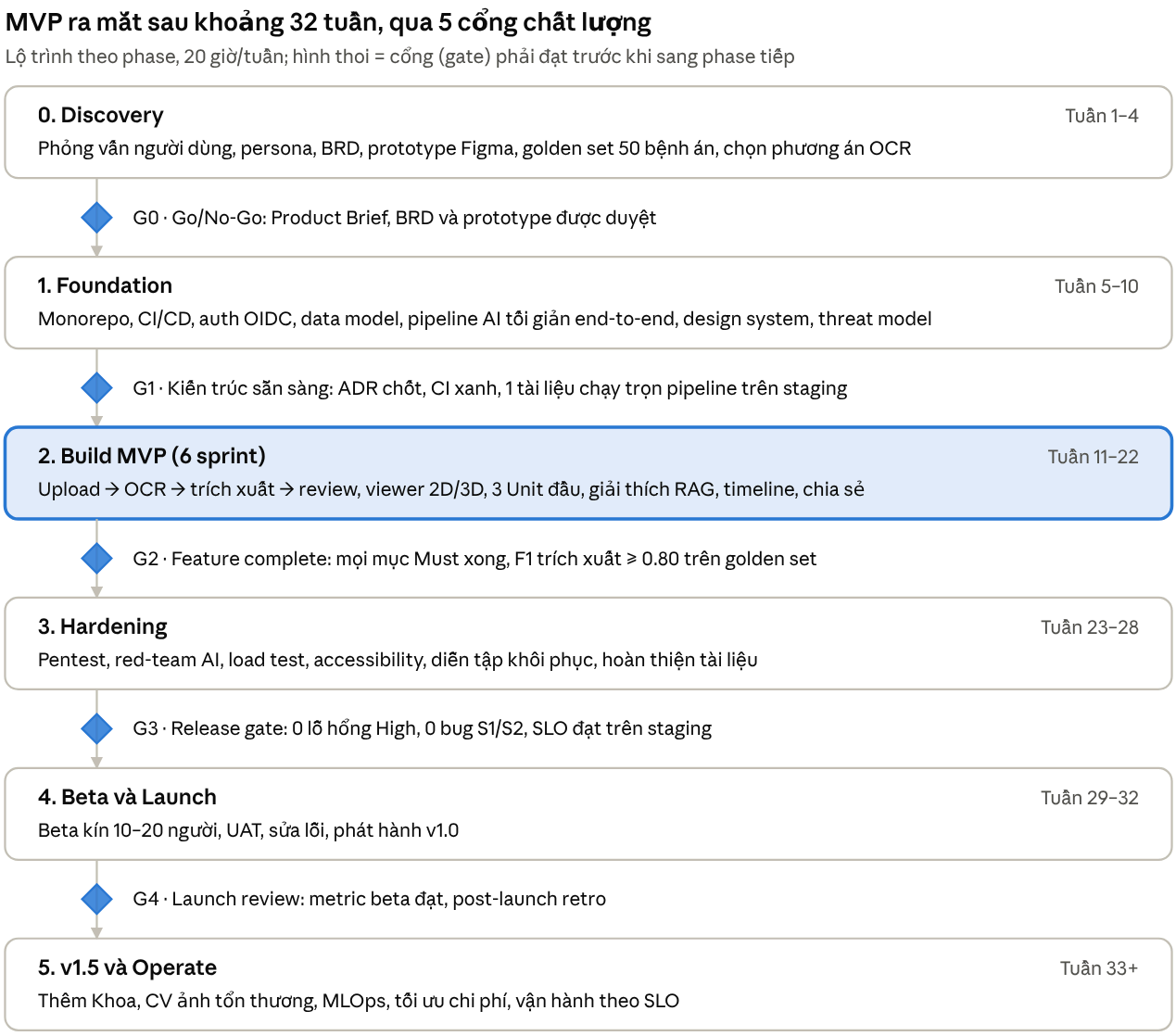
Mã	Quy tắc
BR-030	Chia sẻ có phạm vi (toàn bộ / theo Unit / theo tài liệu), thời hạn (mặc định 7 ngày, tối đa 90 ngày) và có thể thu hồi ngay.
BR-031	Link chia sẻ chỉ dùng được khi người nhận đăng nhập; không có link công khai ẩn danh.
BR-032	Người dùng có quyền tải toàn bộ dữ liệu (export JSON/PDF) và yêu cầu xóa tài khoản. Xóa mềm ngay, xóa cứng sau 30 ngày (trừ audit log giữ theo quy định).

Mã	Quy tắc
BR-033	File gốc lưu mã hóa; ảnh xem trước được tạo với watermark tên người dùng khi chia sẻ.
BR-034	Dữ liệu người dùng **không** dùng để huấn luyện/fine-tune model nếu không có consent riêng (opt-in).
BR-035	Mọi truy cập đọc/ghi dữ liệu y tế ghi AuditEvent; audit log chỉ append, giữ tối thiểu 3 năm (tham số cấu hình).

5. Roadmap tổng thể

MVP (v1.0) ra mắt sau khoảng **32 tuần** làm part-time; mỗi phase kết thúc bằng một cổng (gate) có tiêu chí rõ ràng — chưa đạt thì chưa sang phase sau.

Cập nhật: lộ trình đầy đủ 52 tuần / 26 sprint (thêm Hypercare, v1.5, v2.0 và các cổng bổ sung) nằm ở mục 29. Mốc ra mắt v1.0 ở tuần 32 không đổi.



roadmap · 6 phase, 5 cổng chất lượng

Phase Build là phần nặng nhất (12 tuần, 6 sprint); nếu trễ, cắt bớt Unit hoặc timeline (Should) thay vì bỏ qua Hardening.

5.1 Kế hoạch 6 sprint của phase Build MVP

Sprint	Mục tiêu sprint	Kết quả demo được
S1 (tuần 11–12)	Upload an toàn + state machine + OCR	Upload ảnh, thấy text OCR và trạng thái realtime
S2 (tuần 13–14)	Trích xuất LLM + màn Review	Sửa và xác nhận kết quả, highlight bounding box

Sprint	Mục tiêu sprint	Kết quả demo được
S3 (tuần 15–16)	Viewer 2D toàn thân + Unit Răng hàm mặt	Sơ đồ răng FDI tô màu theo bệnh án
S4 (tuần 17–18)	Viewer 3D + Unit Tim mạch	Xoay/zoom mô hình, bấm vùng xem chi tiết
S5 (tuần 19–20)	Unit Ung bướu + RAG giải thích	Khối u, hạch, di căn; hỏi đáp có trích dẫn
S6 (tuần 21–22)	Timeline pre/post + chia sẻ + admin	So sánh hai lần khám, chia sẻ có hạn cho bác sĩ

5.2 Nghi thức mỗi sprint (làm một mình vẫn giữ)

- **Ngày 1:** Sprint Planning 1 giờ — chọn story từ backlog, viết Sprint Goal.
- **Hằng ngày:** daily note 5 phút (hôm qua / hôm nay / vướng mắc) trong Notion.
- **Giữa sprint:** backlog refinement 1 giờ cho sprint sau (mũ BA).
- **Ngày cuối:** Sprint Review (quay video demo 5 phút) + Retro (giữ / bỏ / thử) + cập nhật risk register và Evaluation Report.

6. Kế hoạch theo từng role

Bạn đóng 12 vai trò. Mỗi vai có: mục tiêu, việc cần làm theo phase, deliverable bắt buộc, công cụ, rủi ro riêng và kỹ năng cần học. Quy tắc làm việc một người: **mỗi sprint 2 tuần**, mở đầu bằng Sprint Planning (mũ PO/PM), kết thúc bằng Review + Retro; mỗi thay đổi đi qua Pull Request và bạn tự review với checklist của role khác (ví dụ code BE được review bằng checklist Security).

Lịch phân bổ thời gian gợi ý (20 giờ/tuần)

Phase	BA/PO	UX/UI	AI/ML	DE	BE	FE	DevOps/SRE	Security	QA/QC
Discovery	50%	30%	15%					5%	
Foundation	10%	10%	15%	10%	20%	10%	15%	5%	5%
Build MVP	5%	10%	25%	10%	20%	20%	5%	5%	10%
Hardening	5%		10%	5%	10%	10%	15%	20%	25%
Launch & Operate	10%	5%	15%	10%	10%	10%	20%	10%	10%

6.1 Business Analyst (BA)

Mục tiêu: biến ý tưởng thành yêu cầu rõ ràng, kiểm chứng được, truy vết được.

- **Discovery:** phỏng vấn người dùng, vẽ As-Is/To-Be process (BPMN), xác định stakeholder (RACI), viết BRD.
- **Foundation:** viết SRS/PRD: functional requirements (FR-xxx), non-functional requirements (NFR-xxx: hiệu năng, bảo mật, khả dụng, khả năng truy cập), business rules (mục 4), glossary thuật ngữ y khoa VI–EN.
- **Build:** viết user story theo INVEST, acceptance criteria dạng Gherkin (Given/When/Then), use case cho luồng phức tạp (upload → review → confirm), làm rõ yêu cầu khi Dev hỏi (bạn tự ghi câu hỏi vào backlog).
- **Hardening/Launch:** UAT script, kiểm tra traceability (BR → Story → Test → Release), change request log.
- **Deliverables:** BRD, SRS/PRD, Use Case Spec, User Story Map, Data Dictionary, Glossary, Traceability Matrix, UAT Plan.
- **Công cụ:** Notion/Confluence, Jira hoặc Linear, draw.io/Miro, Figma (đọc), Google Sheets.
- **Rủi ro:** scope creep (muốn làm mọi Khoa cùng lúc); yêu cầu y khoa mơ hồ; viết story quá to. **Giảm thiểu:** khóa scope MVP bằng MoSCoW, story ≤ 3 ngày làm.
- **Học:** BABOK cơ bản, BPMN 2.0, viết Gherkin, khái niệm ICD-10/SNOMED/LOINC/FHIR.

Ví dụ user story:

```
US-021 – Xác nhận kết quả trích xuất
Là bệnh nhân, tôi muốn xem bản gốc và kết quả AI cạnh nhau để sửa chỗ sai
trước khi lưu.
Given tôi có tài liệu ở trạng thái "extracted"
When tôi mở màn hình Review
Then tôi thấy ảnh gốc có highlight vùng chữ tương ứng với từng trường
And các trường có độ tin cậy < 0.7 được tô vàng và phải bấm xác nhận
And nút "Lưu" chỉ bật khi mọi trường vàng đã xác nhận (BR-012)
```

6.2 Product Owner / Project Manager (PO/PM)

Mục tiêu: quyết định làm gì trước, giữ tiến độ, quản lý rủi ro và chất lượng tổng thể.

- **Discovery:** Product Vision, North Star Metric (ví dụ: *số hồ sơ được xác nhận và xem trên viewer mỗi tuần*), OKR theo quý, roadmap.
- **Liên tục:** quản lý product backlog (ưu tiên bằng RICE hoặc WSJF), Sprint Planning/Review/Retro, burndown chart, risk register (mục 11), quyết định release Go/No-Go.
- **Quản lý dự án:** WBS, Gantt cho các phase, milestone, Definition of Ready / Definition of Done, báo cáo tiến độ hăng tuần cho chính mình (weekly status: Done / Next / Blockers / Risks).
- **Deliverables:** Product Vision, Roadmap, OKR, Release Plan, Sprint Reports, Risk Register, Decision Log, Release Notes, Post-mortem.
- **Rủi ro:** làm một mình dễ bỏ quy trình; ước lượng sai. **Giảm thiểu:** timebox cố định, buffer 20% mỗi phase, retro thật sự viết ra.
- **Học:** Scrum Guide, Kanban, kỹ thuật ước lượng (story point, T-shirt), quản lý rủi ro PMBOK.

6.3 UX/UI Designer

Mục tiêu: người không có kiến thức y khoa vẫn hiểu được bệnh của mình trong < 2 phút mà không hoảng sợ.

- **Discovery:** user research, persona, journey map, information architecture (IA), sitemap.
- **Foundation:** wireframe low-fi các màn: Onboarding/Consent, Dashboard, Upload, Review, Body Viewer (3D/2D), Unit Viewer (răng, tim, khối u), Timeline, Explain panel, Share, Settings, Admin.

- **Build: Design System** (màu, typography, spacing, component, token), hi-fi mockup, prototype, quy ước màu mức độ (BR-020), trạng thái loading/empty/error, dark mode.
- **Đặc thù healthcare:** ngôn ngữ trấn an, tránh hình ảnh gây sốc (mô hình cách điệu, không giải phẫu chân thực đẫm máu), luôn có disclaimer, accessibility WCAG 2.2 AA (tương phản, bàn phím, screen reader cho viewer 3D bằng danh sách vùng thay thế).
- **Kiểm thử:** usability test 5 người/vòng, đo task success rate và SUS score.
- **Deliverables:** IA/Sitemap, Wireframes, Design System, Hi-fi UI, Prototype, Usability Test Report, Accessibility checklist.
- **Công cụ:** Figma, FigJam, Maze/Useberry (test), Stark (kiểm tra tương phản).
- **Rủi ro:** viewer 3D đẹp nhưng khó dùng; quá nhiều thông tin y khoa. **Giảm thiểu:** progressive disclosure (tóm tắt → chi tiết), luôn có chế độ 2D đơn giản.

6.4 AI Solution Architect / ML Engineer (OCR, CV, LLM)

Mục tiêu: pipeline biến ảnh bệnh án thành dữ liệu có cấu trúc, đúng, có độ tin cậy, có thể đo và cải thiện.

Pipeline AI (theo thứ tự):

1. **Tiền xử lý ảnh (CV cổ điển):** kiểm tra mờ/tối, xoay thẳng (deskew), cắt viền tài liệu (document detection + perspective transform), khử nhiễu, tăng tương phản — OpenCV.
2. **Phân loại trang (Document classification):** đơn thuốc / giấy ra viện / xét nghiệm / giải phẫu bệnh / phim X-quang… — bắt đầu bằng LLM vision zero-shot, sau đó train classifier nhỏ (EfficientNet/LayoutLMv3) khi có dữ liệu.
3. **Layout + OCR:** phát hiện vùng chữ, bảng, chữ ký, con dấu. Phương án so sánh: PaddleOCR (hỗ trợ tiếng Việt tốt, chạy local), VietOCR (chữ in tiếng Việt), Tesseract (baseline), dịch vụ cloud (Google Document AI, Azure Document Intelligence, AWS Textract) và LLM đa phương thức. Chữ viết tay: dùng LLM vision hoặc cloud OCR; luôn đánh dấu độ tin cậy thấp.
4. **Trích xuất thông tin (IE):** LLM với **structured output (JSON Schema)** theo `extraction_schema` của Unit: chẩn đoán, mã ICD-10, vị trí giải phẫu, bên, kích thước, giai đoạn TNM, chỉ số xét nghiệm, ngày, nơi khám. Mỗi trường trả về giá trị + trích dẫn đoạn văn gốc (bounding box) + độ tin cậy.
5. **Chuẩn hóa thuật ngữ (Normalization):** viết tắt → đầy đủ (THA → tăng huyết áp, ĐTĐ → đái tháo đường), map sang ICD-10 / SNOMED CT / LOINC bằng kết hợp từ điển + embedding search + LLM rerank.

6. **Mapping giải phẫu:** từ vị trí văn bản ("thùy trên phổi phải", "răng 36") → `region_code` + mesh ID. Rule-based trước (regex số răng FDI, từ điển vị trí), LLM fallback.
7. **Kiểm tra hợp lệ (Validation):** rule y khoa cơ bản (răng 11–48 hợp lệ, ngày không ở tương lai, giới tính – cơ quan phù hợp), tính độ tin cậy tổng hợp.
8. **Giải thích (RAG):** câu hỏi người dùng + dữ liệu đã xác nhận → truy xuất KnowledgeArticle (vector DB) → LLM trả lời có trích dẫn, có guardrail (BR-022, BR-023).
9. **Computer Vision nâng cao (v1.5+):** phân vùng tổn thương da trên ảnh chụp (U-Net / SAM), đánh số răng trên X-quang toàn cảnh (YOLO + dữ liệu công khai), chỉ dùng cho minh họa, không chẩn đoán.

Việc theo phase:

- **Discovery:** khảo sát model, tạo bộ dữ liệu đánh giá đầu tiên (golden set) ~50 bệnh án synthetic có nhãn đúng, chạy thử 3 phương án OCR, ghi ADR chọn phương án.
- **Foundation:** dựng pipeline end-to-end tối giản (notebook → service), định nghĩa JSON Schema, prompt v1, harness đánh giá tự động.
- **Build:** cải thiện từng bước theo metric, thêm normalization, mapping, RAG, guardrail; prompt versioning; caching kết quả.
- **Hardening:** red-teaming (prompt injection trong ảnh bệnh án, câu hỏi nguy hiểm), đo hallucination, kiểm tra thiên lệch (bệnh án viết tay vs in, ảnh điện thoại cũ vs mới).
- **Operate:** theo dõi drift (tỉ lệ người dùng sửa tăng?), học từ dữ liệu sửa (có consent), A/B prompt/model.

Tạo dữ liệu khi chưa có gì:

- Sinh bệnh án synthetic: dùng LLM tạo nội dung theo template từng Unit → render ra PDF/ảnh bằng HTML template của các mẫu phiếu Việt Nam → tạo biến thể (mờ, nghiêng, gập, chụp điện thoại, con dấu, chữ viết tay giả lập bằng font handwriting).
- Dữ liệu công khai: MIMIC-IV-Note / MTSamples (văn bản lâm sàng tiếng Anh — cần đăng ký và tuân thủ điều khoản), FUNSD/CORD (layout), bộ X-quang răng và ảnh da (ISIC) cho CV. Luôn đọc license trước khi dùng.
- Bộ từ điển: ICD-10 (bản tiếng Việt của Bộ Y tế), danh mục xét nghiệm, danh sách viết tắt y khoa tự xây dựng.
- Gán nhãn: Label Studio; quy định hướng dẫn gán nhãn (annotation guideline) và đo độ đồng thuận (bạn gán lại 10% sau 2 tuần để đo tính nhất quán của chính mình).
- **Deliverables:** Model/Prompt Card cho từng thành phần, Evaluation Report mỗi sprint, Dataset Card, ADR chọn model, Guardrail policy, AI Risk Assessment.

- **Công cụ:** Python, OpenCV, PaddleOCR, Hugging Face, PyTorch, LLM API (Claude/GPT/Gemini) hoặc model mở (Qwen2.5-VL, Llama) qua vLLM/Ollama, LangGraph hoặc code thuần, pgvector, MLflow hoặc Langfuse để theo dõi prompt/eval, Label Studio.
- **Rủi ro:** OCR chữ tay kém; LLM bịa thông tin; chi phí API tăng; gửi dữ liệu sức khỏe ra API bên thứ ba. **Giảm thiểu:** human review bắt buộc, trích dẫn bounding box, giới hạn ngân sách token, che thông tin định danh (PII redaction) trước khi gửi API, ưu tiên nhà cung cấp có cam kết không train trên dữ liệu và có vùng lưu trữ phù hợp.
- **Học:** OCR & document AI, prompt engineering, structured output, RAG, evaluation LLM, MLOps cơ bản.

6.5 Data Engineer (DE)

Mục tiêu: dữ liệu sạch, có lineage, có thể phân tích và tái huấn luyện, tách biệt rõ dữ liệu vận hành và dữ liệu phân tích.

- **Foundation:** thiết kế data model OLTP (PostgreSQL), object storage cho file gốc, quy ước đặt tên, migration (Alembic/Prisma), seed data cho danh mục Khoa/Unit/Region/ICD-10.
- **Build:** pipeline nạp danh mục chuẩn (ICD-10, LOINC subset, từ điển viết tắt) — ETL có version; pipeline sinh dữ liệu synthetic; pipeline đưa KnowledgeArticle → chunk → embedding → pgvector.
- **Analytics:** schema phân tích tách riêng (dữ liệu đã ẩn danh/giả danh hóa): fact_extraction_run, fact_user_correction, dim_unit, dim_model_version… → dashboard chất lượng AI và sản phẩm. Công cụ: dbt + DuckDB/Postgres, Metabase hoặc Superset.
- **Data quality:** Great Expectations / dbt tests: không null ở trường bắt buộc, mã ICD hợp lệ, ngày hợp lệ, phân bố độ tin cậy không lệch bất thường.
- **Governance:** data catalog đơn giản (Data Dictionary), phân loại dữ liệu (Public / Internal / Confidential / Sensitive-Health), chính sách lưu giữ & xóa, lineage từ file gốc → extraction → confirmed.
- **Deliverables:** ERD, Data Dictionary, ETL/ELT DAGs, Data Quality Report, Retention Policy, Analytics dashboard.
- **Công cụ:** PostgreSQL 16 + pgvector, MinIO/S3, Prefect hoặc Dagster (orchestration), dbt, DuckDB, Great Expectations, Metabase.
- **Rủi ro:** lẫn dữ liệu thật vào môi trường dev; schema thay đổi phá pipeline. **Giảm thiểu:** chỉ dữ liệu synthetic ở dev/staging, schema contract + migration test trong CI.

6.6 Backend Developer (BE)

Mục tiêu: API an toàn, nhất quán, dễ mở rộng thêm Unit; xử lý tác vụ nặng bất đồng bộ.

- **Kiến trúc: modular monolith** (một codebase, chia module rõ ràng) + **AI worker** tách riêng. Module: `identity`, `patient`, `document`, `extraction`, `anatomy` (Department/Unit/Region config), `clinical` (Condition/Finding/Observation), `knowledge`, `sharing`, `notification`, `audit`, `admin`. Lý do: một người vận hành microservices là quá tải; modular monolith vẫn dạy được ranh giới domain (DDD).
- **Foundation:** khung dự án, cấu hình theo môi trường (12-factor), logging có cấu trúc (JSON + correlation ID), xử lý lỗi chuẩn (RFC 7807 Problem Details), OpenAPI spec viết trước (API-first), health check `/healthz` `/readyz`.
- **Auth:** OAuth2/OIDC qua Keycloak (tự host) hoặc Auth0/Clerk/Supabase Auth; JWT ngắn hạn + refresh token xoay vòng; RBAC + kiểm tra ownership ở từng truy vấn (row-level security của PostgreSQL là lớp bảo vệ thứ hai).
- **Upload:** presigned URL lên object storage → callback → tạo job → worker xử lý → cập nhật trạng thái qua WebSocket/SSE. Quét virus (ClamAV), kiểm tra MIME thật, giới hạn kích thước.
- **State machine tài liệu:** `uploaded → validating → rejected | queued → ocr_running → extracting → extracted → in_review → confirmed | failed`. Mỗi chuyển trạng thái là event, có retry với exponential backoff và dead-letter queue.
- **API chính (REST, `/api/v1`):** auth, `/me`, `/profiles`, `/documents` (upload, status, pages), `/extractions/{id}` (get, patch, confirm), `/conditions`, `/findings`, `/observations`, `/timeline`, `/units` và `/units/{code}/config`, `/explain` (stream), `/shares`, `/consents`, `/admin/*`, `/audit`.
- **Chất lượng:** unit test (pytest/Jest), integration test với Testcontainers (Postgres, Redis, MinIO thật trong Docker), contract test với FE (schemathesis hoặc Pact), idempotency key cho POST quan trọng, pagination cursor, rate limiting.
- **Deliverables:** OpenAPI spec, ERD, sequence diagram các luồng chính, ADR (chọn framework, auth, queue), README chạy local trong 1 lệnh, coverage report.
- **Rủi ro:** lộ dữ liệu do thiếu kiểm tra ownership (IDOR); job treo; N+1 query. **Giảm thiểu:** test phân quyền tự động cho mọi endpoint, timeout + retry + DLQ, theo dõi query chậm.

6.7 Frontend Developer (FE) — Viewer 3D/2D

Mục tiêu: viewer mượt (≥ 50 FPS trên laptop phổ thông), dễ hiểu, hoạt động tốt trên mobile web, đạt accessibility.

- **Nền tảng:** Next.js (App Router) + TypeScript, Tailwind + shadcn/ui theo Design System, TanStack Query (server state), Zustand (UI state), React Hook Form + Zod (form), i18n VI/EN (next-intl).
- **Viewer 3D:** Three.js qua **React Three Fiber** + drei: OrbitControls (xoay, zoom, pan bằng chuột/chạm), raycasting để chọn vùng, highlight mesh theo mức độ, chế độ trong suốt (x-ray) để thấy nội tạng, camera preset (trước, sau, trái, phải), label 3D. Model định dạng glTF/GLB, nén Draco/Meshopt, mỗi mesh đặt tên theo `region_code`.
- **Nguồn mô hình 3D:** Z-Anatomy / BodyParts3D (giải phẫu mở — kiểm tra license CC BY-SA), Sketchfab (model có license phù hợp), hoặc tự làm/đơn giản hóa trong Blender. Học Blender cơ bản để tách mesh, đổi tên, giảm polygon.
- **Viewer 2D:** SVG có `id` cho từng vùng (toàn thân trước/sau, sơ đồ răng FDI, tim, phổi, thận, ống tiêu hóa). Tô màu, tooltip, click → panel chi tiết. 2D là chế độ mặc định trên mobile và là phương án dự phòng khi WebGL không có.
- **Unit viewer theo plugin:** mỗi Unit là một module đăng ký `{unitCode, Viewer2D, Viewer3D, legend, detailPanel}`; dữ liệu đến từ `/units/{code}/config` → thêm Unit không sửa core.
- **Timeline pre/post:** thanh trượt thời gian, chế độ so sánh song song (trước | sau), biểu đồ chỉ số theo thời gian (Recharts/ECharts), đánh dấu sự kiện điều trị.
- **Màn hình Review:** ảnh gốc (zoom, pan) + overlay bounding box, form trích xuất bên cạnh, click trường → nhảy tới vùng chữ trong ảnh.
- **Hiệu năng:** lazy load model 3D, LOD, code splitting theo route, ảnh qua CDN, Lighthouse ≥ 90 cho các trang không phải viewer.
- **Kiểm thử:** Vitest + Testing Library (component), Playwright (E2E, visual regression bằng screenshot cho viewer), axe-core (accessibility), Storybook cho component.
- **Deliverables:** Storybook, bộ asset 3D/2D đã chuẩn hóa tên, E2E suite, báo cáo Lighthouse và accessibility.
- **Rủi ro:** model 3D quá nặng; mapping mesh sai; WebGL lỗi trên máy yếu. **Giảm thiểu:** ngân sách kích thước (≤ 5 MB/model sau nén), test mapping tự động (mọi `region_code` trong config phải có mesh tương ứng), fallback 2D.

6.8 DevOps / Platform Engineer

Mục tiêu: từ commit đến production tự động, lặp lại được, có thể rollback trong < 10 phút.

- **Môi trường:** `local` (Docker Compose) → `dev` → `staging` → `production`. Staging giống production nhưng chỉ chứa dữ liệu synthetic.

- **Source control:** GitHub, trunk-based development với branch ngắn, Conventional Commits, branch protection (bắt buộc PR + CI xanh), CODEOWNERS (bạn), semantic versioning + changelog tự động.
- **CI (GitHub Actions):** lint → type check → unit test → build → integration test → SAST (Semgrep, CodeQL) → dependency scan (Dependabot/Trivy) → secret scan (gitleaks) → build image → scan image → push registry.
- **CD:** deploy tự động lên staging; production qua manual approval; chiến lược blue-green hoặc rolling; database migration chạy như một bước riêng, tương thích ngược (expand → migrate → contract).
- **Hạ tầng:** Infrastructure as Code bằng Terraform. Lộ trình học: (1) một VPS + Docker Compose + Caddy/Traefik; (2) cloud managed (AWS: ECS Fargate/App Runner, RDS, S3, SQS hoặc GCP: Cloud Run, Cloud SQL, GCS, Pub/Sub); (3) tùy chọn Kubernetes (k3s/EKS/GKE) + Helm + Argo CD để học GitOps.
- **Secret:** không bao giờ lưu trong repo; dùng GitHub Secrets + AWS Secrets Manager/GCP Secret Manager hoặc Doppler/Infisical.
- **Deliverables:** sơ đồ hạ tầng, Terraform modules, pipeline YAML, runbook deploy/rollback, môi trường ephemeral cho PR (tùy chọn).
- **Rủi ro:** chi phí cloud vượt; cấu hình lệch giữa môi trường. **Giảm thiểu:** budget alert, tắt staging ngoài giờ, mọi thứ qua IaC.

6.9 Security & Compliance Engineer

Mục tiêu: dữ liệu sức khỏe được bảo vệ theo nguyên tắc privacy-by-design; tuân thủ Luật Bảo vệ dữ liệu cá nhân 91/2025/QH15 (và Nghị định 356/2025/NĐ-CP hướng dẫn Luật), tham chiếu HIPAA/GDPR và OWASP.

- **Discovery:** phân loại dữ liệu, Data Protection Impact Assessment (DPIA), xác định cơ sở pháp lý xử lý (consent), threat model bằng **STRIDE** trên sơ đồ luồng dữ liệu (DFD).
- **Foundation — Secure SDLC:** security requirements (ASVS level 2), secure coding guideline, dependency policy, secret management, SAST/DAST/SCA trong CI.
- **Kiểm soát kỹ thuật:**
  - Mã hóa: TLS 1.2+ mọi nơi, HSTS; dữ liệu nghỉ mã hóa AES-256 (KMS); trường nhạy cảm mã hóa cấp ứng dụng (envelope encryption).
  - Danh tính: MFA, password policy theo NIST 800-63B, kiểm tra mật khẩu bị lộ (HIBP k-anonymity), session an toàn (cookie HttpOnly, Secure, SameSite).
  - Ứng dụng: chống OWASP Top 10 (IDOR, injection, XSS, CSRF, SSRF), CSP chặt, validate input bằng schema, giới hạn upload, quét malware.

    - AI: OWASP Top 10 for LLM — prompt injection (kể cả chữ ẩn trong ảnh bệnh án), lộ dữ liệu qua prompt, output không an toàn; PII redaction trước khi gửi LLM bên ngoài; log prompt đã che thông tin.
    - Hạ tầng: least privilege IAM, network segmentation (DB không public), WAF, backup mã hóa, CIS benchmark.
    - Giám sát: audit log bất biến, cảnh báo truy cập bất thường (đăng nhập từ quốc gia lạ, tải hàng loạt).
- **Hardening:** pentest tự thực hiện bằng OWASP ZAP, Burp Suite Community, kiểm tra theo ASVS checklist; xử lý lỗ hổng theo SLA (Critical 24h, High 7 ngày, Medium 30 ngày).
- **Compliance docs:** Privacy Policy, Terms of Service, Consent text, DPIA, Records of Processing, Incident Response Plan (thông báo vi phạm dữ liệu trong 72 giờ kể từ khi phát hiện theo NĐ 356/2025), Data Retention Policy, Vendor assessment (nhà cung cấp LLM/cloud).
- **Rủi ro:** rò rỉ dữ liệu sức khỏe là rủi ro nghiêm trọng nhất của dự án. **Giảm thiểu:** chỉ dùng dữ liệu synthetic cho tới khi qua checklist bảo mật; nếu public demo, cấm upload dữ liệu thật hoặc giới hạn người dùng mời.

6.10 QA Engineer (Quality Assurance — phòng ngừa lỗi)

Mục tiêu: chất lượng được xây vào quy trình, không phải kiểm ở cuối.

- **Test Strategy & Test Plan:** tháp kiểm thử (nhiều unit, vừa integration, ít E2E), môi trường test, dữ liệu test, tiêu chí vào/ra, quản lý lỗi (severity S1–S4, priority P1–P4).
- **Loại kiểm thử:** functional, regression, API/contract, E2E, cross-browser (Chrome, Safari, Firefox, mobile Safari/Chrome), performance (k6: 100 người dùng đồng thời, p95 API < 300 ms), load cho pipeline AI (100 tài liệu/giờ), security, accessibility, usability, **AI evaluation** (golden set chạy mỗi PR đổi prompt/model).
- **Test case từ acceptance criteria:** mỗi BR và US có ít nhất 1 test; kỹ thuật boundary value, equivalence partitioning, decision table (ví dụ quyền chia sẻ), state transition (state machine tài liệu).
- **Shift-left:** review yêu cầu trước khi code (testability), Definition of Done có test.
- **Deliverables:** Test Strategy, Test Plan, Test Cases (TestRail/Qase hoặc file Markdown trong repo), Bug Reports, Test Summary Report mỗi release, Automation suite.

6.11 QC (Quality Control — kiểm tra sản phẩm trước phát hành)

- **Release checklist:** toàn bộ test xanh, không còn bug S1/S2, metric AI không giảm so với release trước, migration đã thử trên bản sao staging, release note đầy đủ.
- **Kiểm tra nội dung y khoa:** mỗi KnowledgeArticle và mapping Unit mới được duyệt theo checklist (nguồn, ngày, ngôn ngữ dễ hiểu, không gây hoảng sợ, disclaimer).
- **Exploratory testing:** 2 giờ/sprint theo charter (ví dụ "thử phá màn Review bằng ảnh xấu, ảnh không phải bệnh án, bệnh án 30 trang").
- **UAT:** bạn đóng vai Patient/Clinician thực hiện kịch bản UAT; mời 3–5 người thật thử ở bản beta.
- **Đo chất lượng:** defect density, defect leakage (lỗi lọt ra production), escaped defects theo severity.

6.12 SRE / Maintenance & Support

Mục tiêu: hệ thống chạy ổn định, phát hiện sự cố trước người dùng, phục hồi nhanh.

- **Observability:** logs (Loki hoặc CloudWatch), metrics (Prometheus + Grafana), traces (OpenTelemetry → Tempo/Jaeger), error tracking (Sentry), uptime check (Uptime Kuma / Better Stack). LLM observability: Langfuse (token, chi phí, độ trễ, chất lượng).
- **SLI/SLO:** availability API 99.5%/tháng; p95 latency API < 300 ms; 95% tài liệu xử lý xong < 2 phút; error budget và chính sách đóng băng tính năng khi vượt budget.
- **Incident management:** mức độ SEV1–SEV4, on-call (chính bạn) với cảnh báo qua Telegram/Slack, runbook cho từng cảnh báo, post-mortem không đổ lỗi (blameless) trong 48 giờ.
- **Backup & DR:** backup DB hằng ngày + PITR, backup object storage có versioning; **RPO 24h, RTO 4h**; diễn tập khôi phục mỗi quý (restore thật vào môi trường tạm).
- **Bảo trì:** cập nhật dependency hằng tuần (Renovate), vá OS/image hằng tháng, xem lại chi phí hằng tháng, dọn dữ liệu theo retention, cập nhật nội dung y khoa hết hạn duyệt, đánh giá lại model khi nhà cung cấp ra phiên bản mới.
- **Support:** kênh phản hồi trong app, FAQ, phân loại ticket (bug / câu hỏi / yêu cầu xóa dữ liệu), SLA phản hồi 2 ngày làm việc.
- **Deliverables:** SLO doc, dashboards, alert rules, runbooks, DR plan + biên bản diễn tập, post-mortems, maintenance calendar.

7. Tech stack chi tiết và lý do chọn

Nguyên tắc chọn: **phổ biến trong doanh nghiệp (giá trị khi đi làm), có tài liệu tốt, một người vận hành được, chi phí thấp khi chưa có người dùng.** Mỗi lựa chọn ghi thành ADR (Architecture Decision Record) với các phương án đã cân nhắc.

Lớp	Lựa chọn chính	Phương án thay thế	Lý do
Frontend	Next.js 15 + React + TypeScript	Vite + React SPA, Nuxt	SSR cho trang công khai, routing, hệ sinh thái lớn
UI	Tailwind CSS + shadcn/ui + Radix	MUI, Ant Design	Accessible primitives, dễ dựng Design System riêng
3D	Three.js + React Three Fiber + drei	Babylon.js	Cộng đồng lớn nhất, phù hợp React
2D	SVG + D3 (tương tác)	Konva, Canvas	Mỗi vùng có id, dễ tô màu và accessibility
Biểu đồ	ECharts hoặc Recharts	Chart.js	Timeline chỉ số
Backend API	Python FastAPI	NestJS (Node), Spring Boot	Cùng ngôn ngữ với AI, async, OpenAPI tự sinh
ORM / migration	SQLAlchemy 2 + Alembic	Prisma (nếu chọn NestJS)	Chuẩn công nghiệp Python
AI worker	Python + Celery hoặc Dramatiq (Redis)	Temporal, AWS Step Functions	Job bất đồng bộ, retry; Temporal để học sau
OCR	PaddleOCR + VietOCR (local), so sánh với Google Document AI / Azure Document Intelligence	Tesseract, AWS Textract	Local cho dữ liệu nhạy cảm; cloud làm baseline độ chính xác
LLM	API có structured output (Claude, GPT, Gemini) qua lớp trừu tượng	Qwen2.5-VL / Llama tự host (vLLM, Ollama)	Bắt đầu nhanh bằng API; đổi nhà cung cấp không sửa code

Lớp	Lựa chọn chính	Phương án thay thế	Lý do
CV	OpenCV, PyTorch, Ultralytics YOLO, SAM	TensorFlow	Tiền xử lý ảnh, đánh số răng, phân vùng da
RAG	pgvector + embedding đa ngôn ngữ (bge-m3 / multilingual-e5)	Qdrant, Weaviate	Ít thành phần, cùng DB
Database	PostgreSQL 16	MySQL	JSONB, RLS, pgvector, phổ biến
Cache / queue	Redis 7	RabbitMQ, SQS	Cache, rate limit, broker
Object storage	S3 (prod) / MinIO (local)	GCS, Azure Blob	Lưu file gốc, mã hóa, presigned URL
Auth	Keycloak (OIDC)	Auth0, Clerk, Supabase Auth	Học chuẩn OIDC đầy đủ; tự host; MFA, RBAC
Realtime	Server-Sent Events / WebSocket	Pusher, Ably	Cập nhật trạng thái xử lý
Orchestration dữ liệu	Prefect hoặc Dagster + dbt	Airflow	Nhẹ hơn Airflow cho một người
MLOps / LLMOps	MLflow + Langfuse	Weights & Biases	Theo dõi thí nghiệm, prompt, eval, chi phí
Gán nhãn	Label Studio	CVAT	Hỗ trợ ảnh + văn bản
Container	Docker, Docker Compose	Podman	Môi trường giống nhau
IaC	Terraform	Pulumi	Chuẩn doanh nghiệp
Cloud	AWS (ECS Fargate, RDS, S3, SQS, KMS, CloudFront)	GCP (Cloud Run…), VPS + Coolify	Phổ biến nhất; giai đoạn đầu có thể dùng VPS
CI/CD	GitHub Actions	GitLab CI	Tích hợp sẵn với repo

Lớp	Lựa chọn chính	Phương án thay thế	Lý do
Observability	OpenTelemetry, Prometheus, Grafana, Loki, Sentry	Datadog, New Relic	Mã nguồn mở, học được bản chất
Security tools	Semgrep, CodeQL, Trivy, gitleaks, OWASP ZAP, Renovate	Snyk, SonarQube	Miễn phí cho dự án cá nhân
Test	pytest, Vitest, Testing Library, Playwright, k6, Testcontainers, Storybook	Cypress, JMeter	Bao phủ đủ tầng
Quản lý dự án	Linear hoặc Jira, Notion/Confluence, Figma, draw.io	GitHub Projects	Mô phỏng môi trường doanh nghiệp

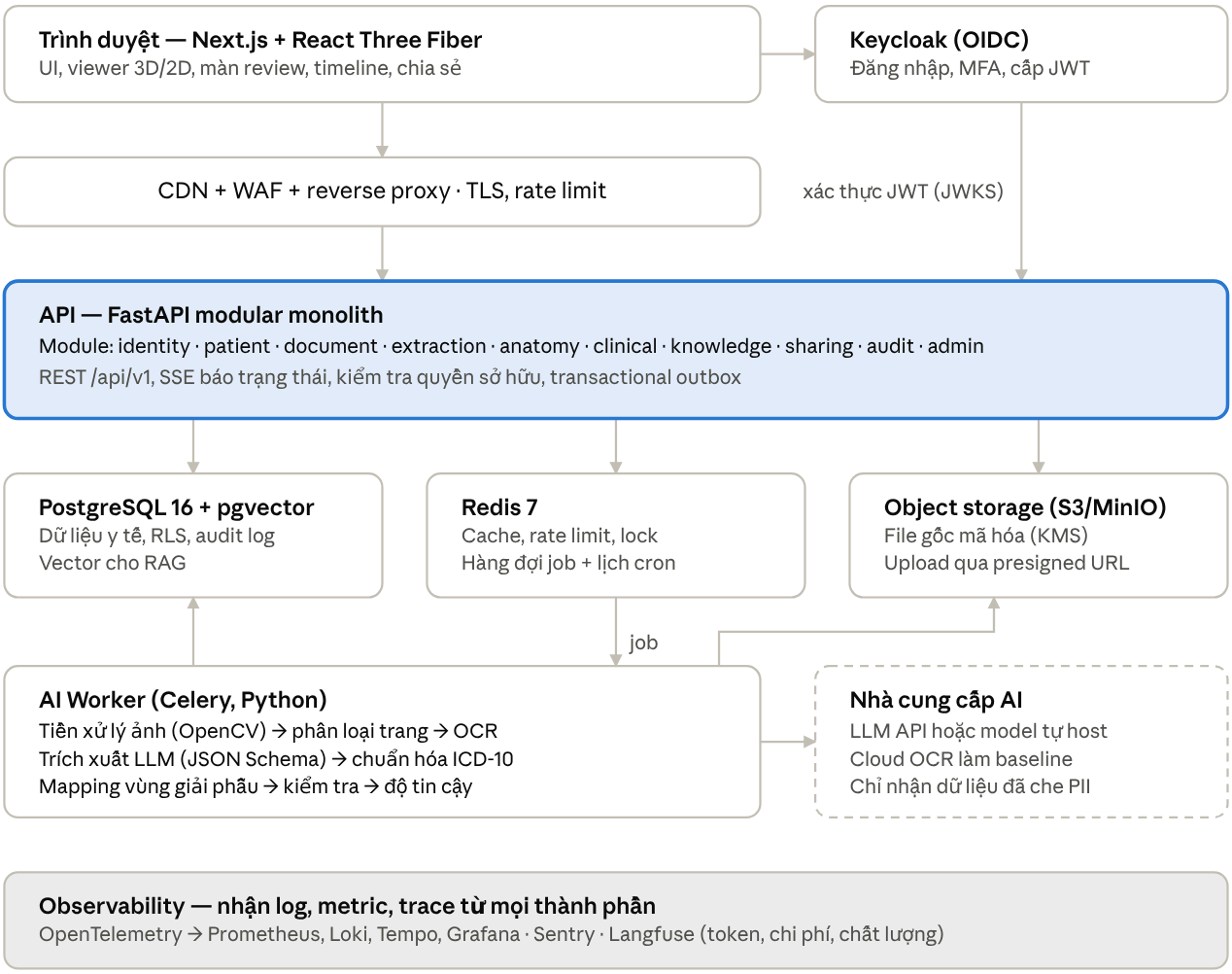
Cấu trúc repository (monorepo):

```
medilens/
├── apps/
|   ├── web/              # Next.js frontend
|   ├── api/              # FastAPI modular monolith
|   └── worker/           # AI pipeline worker
├── packages/
|   ├── anatomy-assets/   # GLB, SVG, unit configs
|   ├── api-client/       # TS client sinh từ OpenAPI
|   └── design-system/
├── ml/
|   ├── datasets/         # scripts sinh dữ liệu synthetic (không commit dữ
liệu thật)
|   ├── eval/             # golden set + harness đánh giá
|   └── notebooks/
├── data/                 # dbt, Prefect flows
├── infra/                # Terraform, Helm, docker-compose
├── docs/                 # BRD, SRS, ADR, runbooks, threat model
└── .github/workflows/
```

8. Kiến trúc hệ thống và data model

Kiến trúc gồm một **API modular monolith** xử lý mọi request đồng bộ và một **AI worker** xử lý tài liệu bất đồng bộ qua hàng đợi — đủ ranh giới để học kiến trúc doanh nghiệp, đủ đơn giản để một người vận hành.

Một API modular monolith và một AI worker, nối với nhau qua hàng đợi Redis



kiến trúc hệ thống · API, worker, 3 kho dữ liệu

Worker không nhận request trực tiếp từ người dùng; nó lấy job từ Redis, đọc file từ object storage và ghi kết quả vào PostgreSQL. Vẽ thêm theo **C4 model** (Context → Container → Component) trong `docs/architecture`.

8.1 Luồng xử lý một tài liệu

1. FE xin presigned URL → upload trực tiếp lên object storage (file không đi qua API).

2. FE gọi `POST /documents/{id}/complete` → API ghi `DocumentUploaded` vào outbox.
3. Worker chạy chuỗi job ở mục 9.1, cập nhật trạng thái; FE nhận qua SSE.
4. Người dùng review và xác nhận → `clinical.materialize` tạo Condition/BodyFinding/Observation.
5. FE gọi `/units/{code}/config` + `/findings` → viewer tô vùng theo `region_code`.

8.2 Data model (bảng chính)

Bảng	Cột quan trọng	Ghi chú
`users`	id (UUID), email, status, created_at	Đồng bộ từ Keycloak qua `sub`
`patient_profiles`	id, owner_user_id, display_name, birth_year, sex_at_birth, is_minor	Một user quản lý nhiều hồ sơ
`documents`	id, profile_id, storage_key, sha256, mime, pages, status, doc_type, uploaded_at	`sha256` chống trùng (BR-016)
`document_pages`	id, document_id, page_no, ocr_text, ocr_boxes (JSONB), quality_score	Bounding box cho màn review
`extraction_runs`	id, document_id, pipeline_version, model, prompt_version, raw_output (JSONB), confidence, cost_usd, status	Truy vết mọi lần chạy AI
`extraction_fields`	id, run_id, field_path, value, confidence, source_page, source_box, user_value, confirmed_at	Lưu cả giá trị AI và giá trị người dùng sửa
`encounters`	id, profile_id, date, facility, department_code	Một lần khám
`conditions`	id, profile_id, encounter_id, icd10_code, unit_code, status, severity, stage, onset_date	Trạng thái theo thời gian

Bảng	Cột quan trọng	Ghi chú
`body_findings`	id, condition_id, region_code, laterality, size_mm, severity, is_metastasis, observed_at	Dữ liệu vẽ lên viewer
`observations`	id, profile_id, loinc_code, name, value, unit, ref_low, ref_high, observed_at	Biểu đồ chỉ số
`departments`, `units`, `regions`	code, name_vi, name_en, parent_code, mesh_id, svg_id, std_code	Danh mục, có version
`unit_configs`	unit_code, version, config (JSONB), published_at	Cấu hình ở mục 3.2
`knowledge_articles`, `knowledge_chunks`	id, condition/region refs, body, sources, reviewer, reviewed_at, embedding (vector)	RAG
`share_grants`	id, profile_id, grantee_user_id, scope, expires_at, revoked_at	BR-030, BR-031
`consents`	id, user_id, type, terms_version, given_at, withdrawn_at	BR-002, BR-034
`audit_events`	id, actor_id, action, resource_type, resource_id, ip, user_agent, at	Append-only, phân vùng theo tháng
`outbox`	id, event_type, payload, created_at, published_at	Transactional outbox

Quy ước: khóa chính UUIDv7, mọi bảng có `created_at/updated_at`, xóa mềm bằng `deleted_at`, bật Row-Level Security theo `profile_id`, trường nhạy cảm (tên, ngày sinh) mã hóa cấp ứng dụng.

9. Cron, background jobs và events

Tách 3 loại: **job theo sự kiện** (chạy khi có hành động), **cron theo lịch** (chạy định kỳ) và **event nội bộ** (module này báo cho module khác). Mọi job phải idempotent, có timeout, retry giới hạn, ghi log với correlation ID, và gửi vào dead-letter queue khi thất bại hẳn.

9.1 Job theo sự kiện (queue)

Job	Kích hoạt	Việc làm	Timeout / Retry
`document.validate`	Upload xong	Kiểm tra MIME, virus, kích thước, độ mờ, tách trang PDF	60 s / 3
`document.preprocess`	Validate OK	Deskew, crop, khử nhiễu, tạo thumbnail	120 s / 3
`document.classify`	Preprocess xong	Phân loại loại trang	60 s / 3
`document.ocr`	Classify xong	OCR từng trang, lưu text + bounding box	300 s / 3
`extraction.run`	OCR xong	LLM trích xuất theo schema Unit, chuẩn hóa mã, mapping vùng	300 s / 2
`extraction.validate`	Trích xuất xong	Rule y khoa, tính độ tin cậy, đánh dấu cần review	30 s / 3
`clinical.materialize`	Người dùng xác nhận	Tạo/cập nhật Condition, BodyFinding, Observation; tính lại timeline	60 s / 5
`notification.send`	Nhiều sự kiện	Email/in-app (xử lý xong, chia sẻ mới, sắp hết hạn chia sẻ)	30 s / 5
`export.generate`	Người dùng yêu cầu	Tạo gói dữ liệu JSON/PDF, link tải có hạn 24h	600 s / 2
`account.delete`	Yêu cầu xóa	Xóa mềm ngay; lên lịch xóa cứng sau 30 ngày	300 s / 5
`knowledge.embed`	Bài viết được duyệt	Chunk + embedding + upsert vector	120 s / 3

9.2 Cron theo lịch (giờ Việt Nam, UTC+7)

Cron	Lịch	Việc làm
`share.expire`	Mỗi 15 phút	Vô hiệu hóa ShareGrant hết hạn, ghi audit
`job.reaper`	Mỗi 10 phút	Tìm job kẹt quá timeout → đánh dấu failed, retry hoặc DLQ
`upload.cleanup`	Mỗi giờ	Xóa upload dở dang/presigned URL không dùng sau 24h
`ai.eval.nightly`	02:00 hằng ngày	Chạy golden set với model/prompt hiện tại, so với baseline, cảnh báo nếu giảm > 3 điểm
`analytics.etl`	03:00 hằng ngày	dbt run + test: cập nhật bảng phân tích đã ẩn danh
`backup.verify`	04:00 hằng ngày	Kiểm tra backup đêm qua tồn tại, kích thước hợp lý, checksum
`account.purge`	05:00 hằng ngày	Xóa cứng tài khoản quá 30 ngày từ khi xóa mềm
`reminder.followup`	08:00 hằng ngày	Nhắc lịch tái khám mà người dùng đã đặt
`cost.report`	09:00 thứ Hai	Tổng hợp chi phí cloud + token LLM tuần trước, cảnh báo vượt ngân sách
`deps.audit`	10:00 thứ Hai	Quét CVE dependency/image, tạo issue
`knowledge.review_due`	1 hằng tháng	Liệt kê KnowledgeArticle quá 12 tháng chưa duyệt lại (BR-024)
`retention.enforce`	1 hằng tháng	Áp dụng chính sách lưu giữ cho log, file tạm, dữ liệu phân tích
`dr.drill`	Mỗi quý	Nhắc diễn tập khôi phục, tạo checklist
`access.review`	Mỗi quý	Rà soát tài khoản Admin/Clinician, khóa tài khoản không hoạt động

9.3 Event nội bộ (domain events)

`UserRegistered`, `ConsentGiven`, `ConsentWithdrawn`, `DocumentUploaded`, `DocumentRejected`, `ExtractionCompleted`, `ExtractionConfirmed`, `FindingCreated`, `ShareGranted`, `ShareRevoked`, `AccountDeletionRequested`, `KnowledgeArticleApproved`.

Dùng **transactional outbox pattern**: ghi event vào bảng `outbox` trong cùng transaction với dữ liệu, một tiến trình đọc outbox và đẩy vào queue. Đây là pattern doanh nghiệp quan trọng giúp không mất event khi hệ thống lỗi giữa chừng.

Lưu ý vận hành: cron chạy bằng Celery Beat (local/VPS) hoặc EventBridge Scheduler (AWS); chỉ một instance được chạy mỗi cron (distributed lock bằng Redis); mỗi cron có metric "lần chạy thành công gần nhất" và cảnh báo khi quá hạn (dead man's switch).

10. Metrics đánh giá khả năng của app

Đo ở 4 tầng: **AI**, **sản phẩm**, **kỹ thuật/vận hành**, **chất lượng quy trình**. Mỗi metric có định nghĩa, cách đo, ngưỡng MVP và ngưỡng mục tiêu. Metric AI đo trên **golden set cố định** (không dùng để chỉnh prompt) + **dev set** (dùng để chỉnh) để tránh overfit.

10.1 Metric AI (đo theo từng Unit và từng loại tài liệu)

Thành phần	Metric	Cách đo	MVP	Mục tiêu
Kiểm tra chất lượng ảnh	Precision/Recall khi từ chối ảnh xấu	So với nhãn tốt/xấu thủ công	≥ 0.85	≥ 0.95
Phân loại trang	Accuracy, macro-F1	Confusion matrix	≥ 0.85	≥ 0.95
OCR chữ in	CER (Character Error Rate), WER	So text với ground truth	CER ≤ 5%	CER ≤ 2%
OCR chữ tay	CER	Như trên	≤ 20%	≤ 10%
Trích xuất trường	Field-level Precision / Recall / F1 (exact & fuzzy match)	So JSON với nhãn	F1 ≥ 0.80	F1 ≥ 0.92
Chuẩn hóa mã ICD-10	Top-1 / Top-3 accuracy	So với mã đúng	Top-1 ≥ 0.75	≥ 0.90

Thành phần	Metric	Cách đo	MVP	Mục tiêu
Mapping giải phẫu	Region accuracy (đúng vùng + đúng bên)	So với nhãn	≥ 0.85	≥ 0.95
Số răng (FDI)	Tooth-level accuracy	So với nhãn	≥ 0.90	≥ 0.98
Độ tin cậy	Calibration (ECE), tỉ lệ lỗi trong nhóm conf ≥ 0.7	Reliability diagram	ECE ≤ 0.1	≤ 0.05
Giải thích RAG	Faithfulness, answer relevance, context precision	RAGAS / LLM-as-judge + chấm tay 50 mẫu	≥ 0.85	≥ 0.95
Hallucination	Tỉ lệ câu khẳng định không có nguồn	Chấm tay + judge	≤ 5%	≤ 1%
Guardrail	Tỉ lệ chặn đúng câu hỏi nguy hiểm / tỉ lệ chặn nhầm	Bộ 100 câu red-team	≥ 95% / ≤ 10%	≥ 99% / ≤ 5%
CV phân vùng (v1.5)	Dice / IoU	So với mask nhãn	Dice ≥ 0.75	≥ 0.85
CV phát hiện răng (v1.5)	mAP@0.5	COCO eval	≥ 0.80	≥ 0.90
Hiệu năng pipeline	Thời gian xử lý / tài liệu (p50, p95)	Tracing	p95 ≤ 3 phút	≤ 60 s
Chi phí	Chi phí AI / tài liệu	Token + compute	≤ $0.10	≤ $0.03

Metric production (không có nhãn): tỉ lệ trường bị người dùng sửa (correction rate), tỉ lệ tài liệu bị từ chối, tỉ lệ "unmapped", phân bố độ tin cậy theo thời gian (phát hiện drift).

10.2 Metric sản phẩm

Metric	Định nghĩa	Mục tiêu beta
North Star	Số hồ sơ đã xác nhận được xem trên viewer / tuần	Tăng 10%/tuần trong beta
Activation rate	% người đăng ký upload & xác nhận ≥ 1 tài liệu trong 7 ngày	≥ 40%

Metric	Định nghĩa	Mục tiêu beta
Time-to-first-insight	Thời gian từ upload tới lần đầu xem viewer	⩽ 5 phút
Review completion	% tài liệu đã trích xuất được người dùng xác nhận	⩾ 70%
Retention	D7 / D30	⩾ 25% / ⩾ 15%
Comprehension score	Sau khi xem, người dùng trả lời đúng 3 câu về bệnh của mình	⩾ 80%
SUS / CSAT	Điểm usability / hài lòng	SUS ⩾ 70, CSAT ⩾ 4/5
Task success	% người test hoàn thành luồng upload → viewer không cần trợ giúp	⩾ 80%

10.3 Metric kỹ thuật & vận hành

- **DORA:** deployment frequency (⩾ 1/tuần), lead time for changes (⩽ 1 ngày), change failure rate (⩽ 15%), MTTR (⩽ 4 giờ).
- **SLO:** availability ⩾ 99.5%, p95 API ⩽ 300 ms, p99 ⩽ 1 s, error rate 5xx ⩽ 0.5%.
- **Frontend:** LCP ⩽ 2.5 s, INP ⩽ 200 ms, CLS ⩽ 0.1; viewer 3D ⩾ 50 FPS (desktop), ⩾ 30 FPS (mobile); thời gian tải model ⩽ 3 s trên 4G.
- **Chi phí:** chi phí hạ tầng/tháng và chi phí/người dùng hoạt động.

10.4 Metric chất lượng & bảo mật

- Test coverage: BE ⩾ 80%, FE ⩾ 70%, phân quyền endpoint 100%.
- Defect leakage ⩽ 10%; không có bug S1 mở khi release.
- Lỗ hổng: 0 Critical/High mở quá SLA; thời gian vá trung bình.
- Accessibility: 0 lỗi axe mức serious/critical; WCAG 2.2 AA.
- Tài liệu: 100% tính năng có story + AC + test; 100% quyết định kiến trúc có ADR.

Cách báo cáo: một **Evaluation Report** mỗi sprint (bảng metric AI, so với sprint trước, lỗi điển hình) và một **Quality Dashboard** trên Grafana/Metabase. Đây cũng là phần mạnh nhất để đưa vào portfolio khi đi phỏng vấn.

11. Risk register theo từng mảng

Rủi ro lớn nhất không phải kỹ thuật mà là **an toàn người dùng (thông tin y khoa sai) và rò rỉ dữ liệu sức khỏe**; tiếp theo là **làm một mình nên quá tải và bỏ dở**. Điểm = Khả năng (1–5) × Tác động (1–5); ≥ 15 là đỏ, xem lại mỗi sprint.

ID	Mảng	Rủi ro	K	T	Điểm	Giảm thiểu	Phương án dự phòng
R01	Y khoa / an toàn	Người dùng hiểu nhầm minh họa là chẩn đoán, tự điều trị	3	5	15	Disclaimer mọi màn, ngôn ngữ "bệnh án ghi…", không tiên lượng, guardrail	Gỡ tính năng giải thích, chỉ giữ hiển thị
R02	Bảo mật	Rò rỉ dữ liệu sức khỏe (IDOR, cấu hình S3 sai, lộ secret)	3	5	15	Threat model, test phân quyền, RLS, mã hóa, scan secret, chỉ dữ liệu synthetic khi chưa audit	Incident Response Plan, thu hồi key, thông báo 72h
R03	Dự án	Một người ôm quá nhiều, kiệt sức, bỏ dở	4	4	16	MVP 3 Unit, timebox, buffer 20%, retro, cho phép cắt scope	Đóng băng ở milestone gần nhất và công bố như case study
R04	AI	LLM bịa thông tin (hallucination)	4	4	16	Structured output + trích dẫn bounding box, human review, RAG chỉ nguồn đã duyệt	Hạ ngưỡng tự động, buộc review mọi trường
R05	AI	OCR kém với chữ tay, ảnh điện thoại xấu	5	3	15	Kiểm tra chất lượng ảnh, hướng dẫn chụp, cloud OCR fallback	Cho phép nhập tay có gợi ý
R06	Dữ liệu	Không có dữ liệu thật để huấn luyện/đánh giá	5	3	15	Synthetic generator, dữ liệu công khai, tự gán nhãn	Giới hạn MVP vào bệnh án chữ in
R07	Pháp lý	Vi phạm Luật 91/2025 / NĐ 356/2025 khi xử lý dữ liệu nhạy cảm, gửi dữ liệu ra nước ngoài qua API	3	5	15	Consent rõ, DPIA, PII redaction, chọn vendor phù hợp, cân nhắc model tự host	Chỉ chạy demo với dữ liệu synthetic

ID	Mảng	Rủi ro	K	T	Điểm	Giảm thiểu	Phương án dự phòng
R08	Nội dung	Bài giải thích sai/lỗi thời	3	4	12	Nguồn chính thống, ngày duyệt, cron nhắc duyệt lại	Ẩn bài, hiển thị "hãy hỏi bác sĩ"
R09	Bản quyền	Model 3D/SVG/dataset vi phạm license	3	3	9	Ghi license từng asset trong `ATTRIBUTION.md`, chỉ dùng CC/Open	Thay asset tự làm đơn giản
R10	Frontend	Viewer 3D nặng, lag trên máy yếu/mobile	4	3	12	Nén, LOD, ngân sách kích thước, fallback 2D	Mặc định 2D trên mobile
R11	Mapping	Gắn sai vùng/bên (trái ↔ phải)	3	4	12	Rule bên trái/phải, test mapping, hiển thị văn bản gốc khi bấm vùng	Ẩn vùng khi độ tin cậy thấp (unmapped)
R12	Chi phí	Chi phí API LLM/cloud vượt ngân sách	3	3	9	Cache, model nhỏ cho bước đơn giản, budget alert, giới hạn upload/ngày	Chuyển sang model tự host
R13	Vendor	Nhà cung cấp LLM đổi giá/ngưng model, kết quả thay đổi	3	3	9	Lớp trừu tượng provider, eval nightly, pin phiên bản model	Đổi provider sau khi qua golden set
R14	Vận hành	Mất dữ liệu do lỗi migration/backup hỏng	2	5	10	Migration expand/contract, backup + verify, diễn tập DR	Restore PITR
R15	Kỹ thuật	Kiến trúc quá phức tạp so với một người (microservices, K8s sớm)	3	3	9	Modular monolith, K8s chỉ là mục tiêu học sau MVP	Quay lại Docker Compose/managed
R16	Đạo đức / UX	Hình ảnh di căn, nội dung ung thư gây sợ hãi, ảnh hưởng tâm lý	3	4	12	Ngôn ngữ trấn an, chế độ "chỉ xem tóm tắt", không hiển thị số liệu tiên lượng, link hỗ trợ tâm lý	Cho phép tắt phần "lan tới"

Rủi ro theo role (tóm tắt): BA – scope creep, yêu cầu mơ hồ · UX – thông tin quá tải · AI – hallucination, drift, chi phí · DE – lẫn dữ liệu thật, schema vỡ · BE – IDOR, job treo · FE – hiệu năng 3D, mapping mesh · DevOps – cấu hình lệch, chi phí · Security – rò rỉ, prompt injection

· QA/QC – test giả xanh, thiếu dữ liệu test thực tế · SRE – cảnh báo nhiễu, không diễn tập khôi phục.

12. Nguồn lực, chi phí, tài liệu cần có và Definition of Done

Dự án làm được với **~1.000–1.200 giờ công** và **chi phí tiền mặt khoảng $20–80/tháng** nếu tận dụng free tier và dữ liệu synthetic. Các con số chi phí dưới đây là **ước tính tham khảo**, cần kiểm tra lại giá thực tế tại thời điểm triển khai.

12.1 Nguồn lực con người & thời gian

Phase	Thời lượng (20 giờ/tuần)	Giờ công
0. Discovery	4 tuần	80
1. Foundation	6 tuần	120
2. Build MVP (6 sprint)	12 tuần	240
3. Hardening	6 tuần	120
4. Beta & Launch	4 tuần	80
5. v1.5 mở rộng + Operate	12–16 tuần	240–320
Học kỹ năng mới (song song)	Toàn dự án	150–200

Người hỗ trợ nên có (không bắt buộc): 1 bác sĩ/sinh viên y để góp ý nội dung (mời cà phê, 1 giờ/tháng), 5–8 người test usability, 1 mentor kỹ thuật review kiến trúc 1 lần/phase.

12.2 Phần cứng & chi phí (ước tính)

Hạng mục	Lựa chọn tiết kiệm	Chi phí ước tính/tháng
Máy phát triển	Laptop 16 GB RAM (32 GB nếu chạy model local); GPU không bắt buộc	Có sẵn
GPU (huấn luyện CV, model tự host)	Google Colab / Kaggle miễn phí, thuê GPU theo giờ khi cần	$0–20
Hosting giai đoạn đầu	1 VPS 4 vCPU / 8 GB + Docker Compose	$10–25

Hạng mục	Lựa chọn tiết kiệm	Chi phí ước tính/tháng
Cloud giai đoạn học enterprise	AWS/GCP free tier + credit sinh viên/startup	$0–50
LLM API	Giới hạn ngân sách theo tháng, cache	$5–30
Domain + email giao dịch	Domain .com/.vn, Resend/SES	$1–5
Công cụ	GitHub, Linear, Notion, Figma, Sentry, Grafana Cloud — gói miễn phí	$0

12.3 Bộ tài liệu một dự án doanh nghiệp cần có

Nhóm	Tài liệu	Role chịu trách nhiệm
Sản phẩm	Product Vision, Product Brief, Roadmap, OKR, Release Notes	PO/PM
Nghiệp vụ	BRD, SRS/PRD, Use Cases, User Stories + AC, Business Rules, Glossary, Traceability Matrix	BA
Thiết kế	IA, Wireframes, Design System, Prototype, Usability Report	UX/UI
Kiến trúc	Architecture Overview (C4 model), ADRs, ERD, Sequence diagrams, OpenAPI	BE / Architect
AI	Dataset Card, Model/Prompt Card, Evaluation Report, Guardrail Policy, AI Risk Assessment	AI/ML
Dữ liệu	Data Dictionary, Lineage, Data Quality Report, Retention Policy	DE
Hạ tầng	Infra diagram, IaC, CI/CD docs, Environment matrix	DevOps
Bảo mật & pháp lý	Threat Model, DPIA, Security Requirements, Pentest Report, Privacy Policy, Terms, Incident Response Plan	Security
Chất lượng	Test Strategy, Test Plan, Test Cases, Test Summary Report, UAT sign-off	QA/QC

Nhóm	Tài liệu	Role chịu trách nhiệm
Vận hành	SLO, Runbooks, On-call guide, DR Plan, Post-mortems, Maintenance calendar	SRE

12.4 Definition of Ready (story được phép bắt đầu)

- [ ] Có user story theo INVEST và acceptance criteria Gherkin
- [ ] Liên kết business rule (BR-xxx) và thiết kế UI (nếu có)
- [ ] Ước lượng ⩽ 3 ngày; phụ thuộc đã rõ
- [ ] Đã xác định dữ liệu test và yêu cầu bảo mật/quyền riêng tư

12.5 Definition of Done (story được coi là xong)

- [ ] Code qua PR, tự review bằng checklist Security + QA
- [ ] Unit/integration test viết mới, CI xanh, coverage không giảm
- [ ] Acceptance criteria pass (test tự động hoặc biên bản test tay)
- [ ] Không có lỗi SAST/SCA mức High trở lên
- [ ] Có log, metric, xử lý lỗi; quyền truy cập đã test
- [ ] Tài liệu cập nhật (OpenAPI, README, ADR nếu có quyết định mới)
- [ ] Đã deploy lên staging và kiểm tra smoke test
- [ ] Với thay đổi AI: chạy golden set, metric không giảm quá 1 điểm

12.6 Lộ trình học kỹ năng song song

1. **Tháng 1–2:** Scrum/BA cơ bản, Figma, FastAPI, PostgreSQL, Docker, Git workflow.
2. **Tháng 3–4:** OpenCV, OCR, LLM structured output, React Three Fiber, Blender cơ bản.
3. **Tháng 5–6:** RAG, evaluation LLM, OIDC/Keycloak, testing (Playwright, Testcontainers), GitHub Actions.
4. **Tháng 7–8:** Terraform + AWS, observability (OpenTelemetry, Grafana), OWASP ASVS, threat modeling.
5. **Tháng 9+:** MLOps, CV nâng cao (YOLO, SAM), Kubernetes/GitOps (tùy chọn), FHIR.

Phần II – Đặc tả chuyên sâu cấp doanh nghiệp

Phần I trả lời *làm gì và ai làm*. Phần II trả lời *phải đạt chuẩn gì*: mỗi yêu cầu có mã, mức bắt buộc (**MUST** / **SHOULD** / **MAY** theo RFC 2119), cách kiểm chứng và phase áp dụng. Đây là cách doanh nghiệp lớn viết đặc tả để audit, kiểm thử và bàn giao được. Mã yêu cầu dùng chung: `SEC` bảo mật, `DAT` dữ liệu, `DE` data engineering, `NFR` phi chức năng, `BE` backend, `FE` frontend, `OPS` vận hành.

13. Yêu cầu bảo mật chi tiết

Mục tiêu bảo mật của MediLens là **OWASP ASVS 5.0 Level 2** cho ứng dụng, **OWASP Top 10 for LLM** cho AI, **CIS AWS Foundations** cho hạ tầng, và tuân thủ **Luật Bảo vệ dữ liệu cá nhân số 91/2025/QH15 (hiệu lực từ 01/01/2026; hướng dẫn bởi Nghị định 356/2025/NĐ-CP, thay Nghị định 13/2023)** (dữ liệu sức khỏe là dữ liệu cá nhân nhạy cảm). Mỗi yêu cầu dưới đây phải có test tự động hoặc bằng chứng kiểm tra trong Security Evidence Pack trước cổng G3.

13.1 Mô hình phòng thủ nhiều lớp

1. **Danh tính** — ai được vào (Keycloak/Cognito, MFA, session).
2. **Ứng dụng** — được làm gì (RBAC + ownership + RLS).
3. **Dữ liệu** — dữ liệu được bảo vệ ra sao (mã hóa, che, xóa).
4. **AI** — mô hình có bị lừa hay làm lộ dữ liệu không (guardrail, redaction).
5. **Hạ tầng** — mạng, IAM, secret, image.
6. **Phát hiện & phản ứng** — log, cảnh báo, incident response.
7. **Quy trình** — Secure SDLC, review, pentest, đào tạo (bạn tự học).

13.2 Danh tính & xác thực (IAM người dùng)

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-ID-01	Xác thực qua OIDC Authorization Code + PKCE; không dùng Implicit flow	MUST	Review cấu hình IdP, test E2E
SEC-ID-02	Mật khẩu ≥ 12 ký tự, kiểm tra mật khẩu đã lộ (HIBP k-anonymity), không ép đổi định kỳ (NIST 800-63B)	MUST	Unit test policy

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-ID-03	MFA (TOTP/WebAuthn) bắt buộc cho Clinician, Admin; Patient được khuyến khích, bắt buộc khi bật chia sẻ	MUST	E2E test đăng nhập theo role
SEC-ID-04	Access token JWT ⩽ 15 phút, ký RS256/ES256; refresh token xoay vòng, phát hiện tái sử dụng → thu hồi cả chuỗi	MUST	Integration test
SEC-ID-05	Cookie phiên: `HttpOnly`, `Secure`, `SameSite=Lax/Strict`; không lưu token trong localStorage	MUST	Scan header, test FE
SEC-ID-06	Khóa tạm sau 5 lần sai, rate limit theo IP + tài khoản, CAPTCHA sau 3 lần sai	MUST	Test brute-force bằng k6
SEC-ID-07	Đăng xuất toàn bộ thiết bị; danh sách phiên đang hoạt động trong Settings	SHOULD	E2E
SEC-ID-08	Thông báo email khi đăng nhập từ thiết bị/quốc gia mới, khi đổi mật khẩu/MFA	SHOULD	E2E
SEC-ID-09	Đăng ký Clinician phải xác minh (upload chứng chỉ hành nghề, Admin duyệt)	SHOULD (v1.5)	Quy trình + audit

13.3 Phân quyền (Authorization)

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-AZ-01	Deny by default: mọi endpoint mặc định yêu cầu xác thực + policy rõ ràng	MUST	Test tự động liệt kê route không có policy → fail CI
SEC-AZ-02	Kiểm tra quyền sở hữu tài nguyên ở tầng service cho **mọi** truy vấn theo ID (chống IDOR/BOLA)	MUST	Ma trận test: user A truy cập tài nguyên user B → 404
SEC-AZ-03	PostgreSQL Row-Level Security theo `profile_id` làm lớp thứ hai	MUST	Test SQL trực tiếp với role ứng dụng

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-AZ-04	Quyền chia sẻ (ShareGrant) được kiểm tra theo phạm vi + thời hạn tại thời điểm truy cập, không cache quá 60 giây	MUST	Integration test hết hạn/thu hồi
SEC-AZ-05	Admin không đọc nội dung y tế; "break-glass" yêu cầu lý do, thời hạn 1 giờ, cảnh báo ngay, ghi audit	MUST	E2E + kiểm tra alert
SEC-AZ-06	Tách quyền: người viết nội dung y khoa không tự duyệt bài của mình (khi có ≥ 2 reviewer)	SHOULD	Workflow test
SEC-AZ-07	Mass assignment: chỉ nhận trường trong allowlist của DTO	MUST	Contract test

13.4 Bảo vệ dữ liệu

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-DP-01	TLS 1.2+ (ưu tiên 1.3) mọi kết nối, kể cả nội bộ VPC tới RDS; HSTS 1 năm, preload	MUST	SSL Labs A+, `rds.force_ssl=1`
SEC-DP-02	Mã hóa at-rest bằng AWS KMS customer-managed key cho RDS, S3, EBS, backup, SQS; xoay key hằng năm	MUST	AWS Config rule
SEC-DP-03	Mã hóa cấp ứng dụng (envelope encryption) cho trường định danh: họ tên, ngày sinh, số điện thoại, CCCD (nếu có)	MUST	Unit test + kiểm tra DB dump không đọc được
SEC-DP-04	S3 bucket: Block Public Access bật cấp account, bucket policy chỉ cho phép TLS, Object Ownership = BucketOwnerEnforced, versioning + Object Lock cho bucket audit	MUST	AWS Config, Access Analyzer

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-DP-05	Presigned URL upload/download ⩽ 5 phút, giới hạn content-type và kích thước	MUST	Integration test
SEC-DP-06	Không ghi PHI/PII vào log, trace, error tracking; middleware redaction + test kiểm tra log mẫu	MUST	Test tự động quét log
SEC-DP-07	Dữ liệu ở dev/staging chỉ là synthetic; cấm copy snapshot production xuống môi trường thấp	MUST	SCP chặn chia sẻ snapshot cross-account
SEC-DP-08	Xóa dữ liệu: crypto-shredding (xóa data key của user) để xóa cả bản trong backup	SHOULD	Runbook + test
SEC-DP-09	Watermark động trên ảnh khi chia sẻ; vô hiệu chuột phải chỉ là phụ, không coi là kiểm soát	SHOULD	E2E

13.5 Bảo mật ứng dụng & API

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-AP-01	Validate mọi input bằng schema (Pydantic/Zod), từ chối trường thừa	MUST	Contract + fuzz test (schemathesis)
SEC-AP-02	Chỉ dùng ORM/parameterized query; cấm nối chuỗi SQL	MUST	Semgrep rule
SEC-AP-03	Output encoding mặc định của React; cấm `dangerouslySetInnerHTML` trừ khi qua DOMPurify	MUST	ESLint rule
SEC-AP-04	Content-Security-Policy chặt (không `unsafe-inline` cho script, dùng nonce), `frame-ancestors 'none'`, `X-Content-Type-Options`, `Referrer-Policy`, `Permissions-Policy`	MUST	Scan header CI

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-AP-05	Chống CSRF: SameSite cookie + CSRF token cho request thay đổi trạng thái	MUST	Test ZAP
SEC-AP-06	Chống SSRF: worker chỉ gọi allowlist domain (LLM, OCR); không tải URL do người dùng nhập	MUST	Egress qua proxy/VPC endpoint
SEC-AP-07	Upload: kiểm tra magic bytes, giới hạn kích thước, quét malware (ClamAV/GuardDuty Malware Protection for S3), xử lý file trong sandbox, chuyển PDF → ảnh để loại script nhúng	MUST	Test với EICAR, PDF độc hại mẫu
SEC-AP-08	Rate limit theo user/IP/endpoint; quota upload/ngày; giới hạn token LLM/ngày/user	MUST	k6 test
SEC-AP-09	Lỗi không lộ stack trace; trả Problem Details với `traceId`	MUST	Test
SEC-AP-10	CORS chỉ cho phép origin của app	MUST	Test
SEC-AP-11	Phiên bản API, deprecation có thông báo; endpoint cũ không quên bảo vệ (inventory API)	SHOULD	OpenAPI diff

13.6 Bảo mật AI / LLM

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-AI-01	**Prompt injection gián tiếp**: văn bản OCR từ bệnh án được coi là *dữ liệu*, đặt trong delimiter, system prompt cấm làm theo chỉ dẫn trong tài liệu	MUST	Bộ test 50 ảnh chứa chỉ dẫn độc hại
SEC-AI-02	Che PII (tên, số điện thoại, CCCD, địa chỉ, mã bệnh nhân) trước khi gửi LLM bên ngoài; map lại sau khi nhận kết quả	MUST	Test redaction recall ≥ 99% trên bộ mẫu

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-AI-03	Output LLM phải qua JSON Schema validation; không thực thi, không render HTML từ output	MUST	Unit test
SEC-AI-04	Chatbot giải thích chỉ truy xuất dữ liệu của chính người dùng (filter `profile_id` ở tầng retrieval, không phụ thuộc prompt)	MUST	Test cross-user retrieval
SEC-AI-05	Guardrail chủ đề: chặn kê đơn, liều thuốc, tiên lượng sống; phát hiện khẩn cấp → 115	MUST	Red-team set 100 câu
SEC-AI-06	Hợp đồng/điều khoản nhà cung cấp LLM: không dùng dữ liệu để train, thời gian lưu tối thiểu, vùng xử lý được ghi trong Vendor Assessment	MUST	Tài liệu
SEC-AI-07	Giới hạn token, timeout, circuit breaker để chống "denial of wallet"	MUST	Test tải
SEC-AI-08	Log prompt/response đã che PII, giữ 30 ngày, truy cập hạn chế	SHOULD	Review cấu hình Langfuse
SEC-AI-09	Model/prompt version được ký và lưu; thay đổi prompt đi qua PR + eval	MUST	CI

13.7 Hạ tầng & cloud

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-IN-01	Multi-account AWS (Organizations): management, security/log-archive, dev, staging, prod	MUST (trước prod)	Sơ đồ account
SEC-IN-02	Không dùng root user; MFA phần cứng cho root; truy cập người qua IAM Identity Center, quyền tạm thời	MUST	Security Hub

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-IN-03	Workload dùng IAM role (ECS task role), least privilege, không access key dài hạn; CI dùng GitHub OIDC → AssumeRole	MUST	IAM Access Analyzer
SEC-IN-04	RDS, Redis, worker trong private subnet; chỉ ALB ở public subnet; Security Group theo nguyên tắc tối thiểu	MUST	Terraform review, Config
SEC-IN-05	VPC endpoint cho S3, Secrets Manager, KMS, ECR, CloudWatch để traffic không ra internet	SHOULD	Terraform
SEC-IN-06	AWS WAF trên CloudFront/ALB: managed rules (Core, Known Bad Inputs, SQLi), rate-based rule	MUST	WAF logs
SEC-IN-07	Image container tối giản (distroless/slim), chạy non-root, read-only root FS, scan ECR (Inspector) – không deploy nếu có CVE Critical	MUST	CI gate
SEC-IN-08	Secret trong Secrets Manager, xoay tự động mật khẩu DB 30 ngày	MUST	Config rule
SEC-IN-09	GuardDuty, Security Hub (CIS + AWS Foundational), Config, CloudTrail (org trail, log-archive account, Object Lock) bật ở mọi account	MUST	Security Hub score ≥ 90%
SEC-IN-10	IaC scan (Checkov/tfsec) trong CI; cấm thay đổi console tay ở prod (drift detection)	MUST	CI + Config

13.8 Log, giám sát & phản ứng sự cố

Mã	Yêu cầu	Mức	Kiểm chứng
SEC-LG-01	Audit log nghiệp vụ: ai, hành động, tài nguyên, kết quả, IP, user-agent, traceId; append-only, giữ ≥ 3 năm	MUST	Test + S3 Object Lock
SEC-LG-02	Đồng bộ thời gian (NTP/Amazon Time Sync), timestamp UTC ISO-8601	MUST	Review
SEC-LG-03	Cảnh báo: đăng nhập sai hàng loạt, break-glass, tải xuống bất thường, thay đổi IAM, tắt CloudTrail, finding GuardDuty High	MUST	Diễn tập
SEC-LG-04	Incident Response Plan: phân loại, ngăn chặn, loại bỏ, khôi phục, bài học; thông báo cơ quan chức năng trong 72 giờ kể từ khi phát hiện vi phạm (NĐ 356/2025, mẫu 08) và thông báo chủ thể dữ liệu khi cần	MUST	Tabletop exercise mỗi 6 tháng
SEC-LG-05	Lưu băng chứng (forensics): snapshot, giữ log, chain of custody	SHOULD	Runbook

13.9 Secure SDLC — cổng bảo mật trong pipeline

Giai đoạn	Hoạt động bắt buộc	Công cụ	Điều kiện chặn
Yêu cầu	Security requirements + abuse cases cho mỗi epic	Template trong SRS	Epic không có abuse case
Thiết kế	Threat model STRIDE cập nhật khi có luồng dữ liệu mới	OWASP Threat Dragon	Threat High chưa có biện pháp
Code	Pre-commit: gitleaks, lint bảo mật	pre-commit	Có secret
Build	SAST, SCA, IaC scan, license scan	Semgrep, CodeQL, Trivy, Checkov	Finding High/Critical

Giai đoạn	Hoạt động bắt buộc	Công cụ	Điều kiện chặn
Image	Container scan, SBOM (CycloneDX), ký image	Trivy/Inspector, Syft, cosign	CVE Critical
Staging	DAST, API fuzz	OWASP ZAP, schemathesis	Finding High
Release	Security sign-off checklist	Bạn đóng vai Security	Thiếu bằng chứng
Vận hành	Vulnerability management SLA, pentest hằng năm	Inspector, Security Hub	Quá SLA

13.10 Mapping tuân thủ

Cập nhật pháp lý: Luật Bảo vệ dữ liệu cá nhân 91/2025/QH15 được thông qua ngày 26/6/2025 và có hiệu lực từ 01/01/2026. **Nghị định 356/2025/NĐ-CP** hướng dẫn Luật, có hiệu lực cùng ngày và **thay thế Nghị định 13/2023**; nghị định quy định các biểu mẫu (mẫu 08 thông báo vi phạm trong 72 giờ kể từ khi phát hiện, mẫu 09 đánh giá chuyển dữ liệu ra nước ngoài, mẫu 10 đánh giá tác động xử lý) và tiêu chuẩn người phụ trách bảo vệ dữ liệu. Consent, DPIA và hồ sơ lập trước 01/01/2026 cần được rà soát theo quy định mới. Điểm cần chú ý: consent phải tự nguyện, rõ ràng và riêng cho từng mục đích; DPIA và hồ sơ đánh giá chuyển dữ liệu ra nước ngoài (OTIA) nộp trong 60 ngày kể từ khi bắt đầu xử lý/chuyển dữ liệu. Đây là tóm tắt để học, không phải tư vấn pháp lý. Nguồn: Luật 91/2025/QH15, Allen & Gledhill, Luật Việt An — điểm mới của Nghị định 356/2025.

Yêu cầu pháp lý / chuẩn	Nội dung chính	Đáp ứng bằng
Luật 91/2025 + NĐ 356 – Đồng ý	Đồng ý rõ ràng, riêng cho dữ liệu nhạy cảm, có thể rút lại	BR-002, BR-034, bảng `consents`
Luật 91/2025 + NĐ 356 – Quyền chủ thể	Truy cập, chỉnh sửa, xóa, hạn chế, phản đối, rút đồng ý	Export, sửa, xóa tài khoản, BR-032
Luật 91/2025 + NĐ 356 – Đánh giá tác động	Hồ sơ đánh giá tác động xử lý dữ liệu cá nhân	DPIA (mục 6.9)
Luật 91/2025 + NĐ 356 – Vi phạm	Thông báo trong 72 giờ	SEC-LG-04

Yêu cầu pháp lý / chuẩn	Nội dung chính	Đáp ứng bằng
Luật 91/2025 + NĐ 356 – Chuyển dữ liệu ra nước ngoài	Hồ sơ đánh giá tác động chuyển dữ liệu ra nước ngoài	Vendor Assessment, ưu tiên region gần, PII redaction
HIPAA Security Rule (tham chiếu)	Administrative / Physical / Technical safeguards	13.2–13.8, AWS HIPAA-eligible services
OWASP ASVS L2	~280 yêu cầu kiểm chứng	Checklist trong repo `docs/security/asvs.md`
OWASP Top 10 for LLM	Prompt injection, data leakage, excessive agency…	13.6

Lưu ý: đây là tài liệu học tập, không phải tư vấn pháp lý. Trước khi đưa dữ liệu thật của người khác lên hệ thống, nên tham khảo luật sư hoặc chuyên gia bảo vệ dữ liệu.

14. Yêu cầu dữ liệu (Data Requirements)

Mọi dữ liệu trong MediLens phải **được phân loại, có chủ sở hữu, có thời hạn lưu, có thước đo chất lượng và truy vết được nguồn gốc**. Đây là yêu cầu chung cho cả BE, DE và AI; DE chịu trách nhiệm thực thi và báo cáo.

14.1 Phân loại dữ liệu

Mức	Ví dụ	Lưu ở đâu	Kiểm soát bắt buộc
C4 – Nhạy cảm sức khỏe (PHI)	Ảnh bệnh án, văn bản OCR, chẩn đoán, chỉ số xét nghiệm, BodyFinding	RDS (prod), S3 bucket `phi-*`	KMS CMK riêng, RLS, audit mọi lần đọc, không rời prod, không ở log
C3 – Định danh cá nhân (PII)	Họ tên, email, số điện thoại, ngày sinh, IP	RDS (mã hóa trường), Keycloak/Cognito	Mã hóa trường, che trong log, xóa theo yêu cầu
C2 – Nội bộ	Cấu hình Unit, prompt, metric AI, log đã che	RDS, S3 `internal-*`, CloudWatch	IAM theo role

Mức	Ví dụ	Lưu ở đâu	Kiểm soát bắt buộc
C1 – Công khai	Bài viết y khoa đã duyệt, asset 3D/2D, trang marketing	S3 + CloudFront	Kiểm soát toàn vẹn (chỉ CI được ghi)
C0 – Synthetic	Bệnh án giả, golden set	S3 `ml-*`, repo (không ảnh thật)	Gắn nhãn `synthetic=true`, không trộn với C4

14.2 Yêu cầu dữ liệu (DAT-xxx)

Mã	Yêu cầu	Mức
DAT-01	Mỗi bảng, bucket, topic có trong Data Catalog với: chủ sở hữu (role), mức phân loại, mô tả, thời hạn lưu	MUST
DAT-02	Mỗi bản ghi lâm sàng truy vết được tới `document_id` + `extraction_run_id` + trang + bounding box (lineage cấp bản ghi)	MUST
DAT-03	Phân biệt rõ giá trị AI (`ai_value`) và giá trị người dùng xác nhận (`user_value`); không ghi đè	MUST
DAT-04	Mọi thời gian lưu UTC (`timestamptz`), hiển thị theo múi giờ người dùng; ngày khám lưu kiểu `date` không múi giờ	MUST
DAT-05	Đơn vị đo chuẩn hóa theo UCUM (mmol/L, mg/dL…) và lưu cả giá trị gốc + đơn vị gốc	MUST
DAT-06	Mã chuẩn: ICD-10 (chẩn đoán), LOINC (xét nghiệm), SNOMED CT/FMA (giải phẫu), FDI (răng), TNM (ung thư); bảng mã có version và ngày hiệu lực	MUST
DAT-07	Danh mục (Department/Unit/Region/mã chuẩn) là **master data**: chỉ thay đổi qua PR + migration, có lịch sử	MUST

Mã	Yêu cầu	Mức
DAT-08	Dữ liệu phân tích phải được giả danh hóa (pseudonymize) bằng HMAC với key riêng; không chứa C3	MUST
DAT-09	Công bố thống kê chỉ khi nhóm ≥ 10 người (k-anonymity k ≥ 10)	MUST
DAT-10	Dữ liệu dùng để đánh giá/huấn luyện từ người dùng chỉ lấy khi có consent opt-in, được ẩn danh, ghi trong Dataset Card	MUST
DAT-11	Thay đổi schema theo expand → migrate → contract; không xóa cột trong cùng release thêm cột mới	MUST
DAT-12	Backup có thể khôi phục được kiểm chứng định kỳ (xem OPS)	MUST
DAT-13	Export dữ liệu người dùng theo định dạng máy đọc được (JSON + FHIR Bundle ở v2)	SHOULD
DAT-14	Data contract giữa producer và consumer (schema, ngữ nghĩa, SLA, chất lượng) cho mọi luồng sang analytics	SHOULD

14.3 Vòng đời dữ liệu & thời hạn lưu

Dữ liệu	Tạo	Dùng	Lưu nóng	Lưu trữ	Xóa
Ảnh/PDF gốc	Upload	OCR, review, xem lại	S3 Standard đến khi user xóa	S3 Glacier Instant sau 180 ngày không truy cập (Intelligent-Tiering)	Khi xóa tài khoản: soft 0 ngày, hard 30 ngày
Text OCR, extraction	Pipeline	Review, đánh giá	RDS	—	Theo tài liệu gốc
Dữ liệu lâm sàng đã xác nhận	User confirm	Viewer, timeline	RDS	—	Theo tài khoản
Upload dở dang	Presign	—	24 giờ	—	Lifecycle rule S3
Audit log	Mọi truy cập	Điều tra, tuân thủ	CloudWatch 90 ngày	S3 + Object Lock 3 năm	Tự hết hạn

Dữ liệu	Tạo	Dùng	Lưu nóng	Lưu trữ	Xóa
Log ứng dụng	Runtime	Debug	30 ngày	1 năm (đã che)	Tự hết hạn
Prompt/response LLM (đã che)	Pipeline	Debug, eval	30 ngày	—	Tự hết hạn
Dữ liệu phân tích	ETL	Dashboard	2 năm	—	Rolling
Backup DB	AWS Backup	DR	35 ngày PITR	Bản tháng 1 năm (vault account riêng)	Tự hết hạn

14.4 Chất lượng dữ liệu (6 chiều)

Chiều	Định nghĩa	Ví dụ kiểm tra	Ngưỡng
Completeness	Trường bắt buộc có giá trị	`condition.icd10_code` not null khi confirmed	100%
Validity	Đúng định dạng/miền giá trị	Răng ∈ {11–18, 21–28, 31–38, 41–48, 51–85}; ICD-10 có trong bảng mã	100%
Accuracy	Đúng với thực tế	So golden set; tỉ lệ người dùng sửa	Xem mục 10
Consistency	Không mâu thuẫn	Giới tính – cơ quan; `observed_at` ≥ ngày sinh	100%
Timeliness	Đủ mới	Analytics cập nhật < 24h; tài liệu xử lý < 2 phút	SLA
Uniqueness	Không trùng	`sha256` tài liệu; một Condition/Encounter/mã	100%

Kiểm tra chạy ở 3 chỗ: **khi ghi** (validation BE), **trong pipeline** (dbt tests/Great Expectations), **định kỳ** (cron data-quality report). Vi phạm MUST → chặn pipeline + cảnh báo; vi phạm SHOULD → ghi vào báo cáo.

14.5 Dữ liệu cho AI

- **Golden set:** ≥ 200 tài liệu synthetic + public, phân tầng theo Unit × loại tài liệu × chất lượng ảnh (tốt / trung bình / xấu) × in/viết tay; khóa version, không dùng để chỉnh prompt.

- **Dev set:** ≥ 300 tài liệu cho phát triển; **Red-team set:** 100 câu hỏi + 50 ảnh có prompt injection.
- **Annotation guideline:** định nghĩa từng trường, ví dụ đúng/sai, quy tắc vùng mờ; đo độ đồng thuận (Cohen's kappa ≥ 0.8 khi tự gán lại).
- **Dataset Card** cho mỗi bộ: nguồn, license, quy trình tạo, phân bố, giới hạn, ngày tạo, version (lưu S3 + DVC hoặc versioning S3).
- **Không bao giờ** đưa dữ liệu C4 thật vào golden set mà không có consent và ẩn danh hóa.

14.6 Trách nhiệm dữ liệu (RACI rút gọn)

Hoạt động	DE	BE	AI	Security	PO
Định nghĩa schema OLTP	C	R/A	C	C	I
Data catalog & phân loại	R/A	C	C	C	I
Pipeline analytics	R/A	I	C	C	I
Dataset AI	C	I	R/A	C	I
Chính sách lưu giữ & xóa	R	R	I	A	C
Phản hồi yêu cầu chủ thể dữ liệu	C	R	I	A	I

15. Data Engineering chi tiết

DE của MediLens phục vụ 4 nhu cầu: **(1) danh mục chuẩn** cho app, **(2) dữ liệu cho AI** (synthetic, golden set, embedding), **(3) phân tích sản phẩm & chất lượng AI**, **(4) tuân thủ** (lineage, retention, xóa). Kiến trúc phân tích theo mô hình **medallion (bronze → silver → gold)** trên S3, tách hẳn khỏi database vận hành.

15.1 Các tầng dữ liệu

Tầng	Nội dung	Định dạng	Nơi lưu	Ai đọc
Source (OLTP)	Bảng nghiệp vụ	PostgreSQL	RDS prod	Chỉ app
Bronze (raw)	Bản sao thay đổi (CDC) hoặc export hằng ngày, đã **giả danh hóa ngay khi trích**, sự kiện app	Parquet, phân vùng `dt=`	S3 `analytics-bronze`	DE

Tầng	Nội dung	Định dạng	Nơi lưu	Ai đọc
Silver (clean)	Làm sạch, chuẩn kiểu, dedupe, join danh mục, áp data contract	Parquet / Apache Iceberg	S3 `analytics-silver`	DE, AI
Gold (mart)	Bảng fact/dim cho dashboard và eval AI	Iceberg / Postgres analytics	S3 `analytics-gold` + Athena	PO, AI, Dashboard
ML datasets	Golden/dev/red-team set, synthetic, label	JSONL + ảnh, versioned	S3 `ml-datasets`	AI
Vector	Chunk + embedding bài viết y khoa đã duyệt	pgvector	RDS	API (RAG)

15.2 Danh sách pipeline

Pipeline	Nguồn → Đích	Lịch	Công cụ	SLA
`ref_catalog_load`	File ICD-10, LOINC subset, từ điển viết tắt, mapping Unit → bảng master	Khi có PR thay đổi	Python + Alembic data migration	Trước deploy
`synthetic_generate`	Template Unit + LLM → bệnh án giả (PDF/ảnh) + nhãn	Theo yêu cầu	Prefect flow	—
`dataset_build`	Synthetic + public + label (Label Studio export) → golden/dev set có version	Khi có nhãn mới	Prefect + DVC/S3 versioning	—
`oltp_extract`	RDS → Bronze (giả danh hóa HMAC, bỏ C3)	02:30 hằng ngày	AWS Glue job hoặc Python trên ECS + `pg_dump` bảng chọn lọc / DMS CDC (giai đoạn sau)	Xong trước 03:00

Pipeline	Nguồn → Đích	Lịch	Công cụ	SLA
`events_ingest`	Sự kiện sản phẩm (event outbox) → Bronze	Liên tục / 15 phút	Kinesis Data Firehose → S3	Trễ ⩽ 15 phút
`transform_silver_gold`	Bronze → Silver → Gold	03:00 hằng ngày	dbt (dbt-athena hoặc dbt-postgres)	Xong trước 06:00
`ai_quality_mart`	`extraction_runs` + `extraction_fields` + correction → fact AI	03:30 hằng ngày	dbt	Trước 06:00
`knowledge_index`	Bài viết duyệt → chunk → embedding → pgvector	Khi duyệt bài	Worker job	⩽ 10 phút
`retention_enforce`	Xóa/archive theo bảng 14.3	Hằng tháng	Python + S3 Lifecycle	Báo cáo
`dsr_delete`	Yêu cầu xóa chủ thể dữ liệu → xóa ở OLTP, S3, analytics, vector	Theo sự kiện	Worker + Prefect	⩽ 30 ngày

15.3 Mô hình dữ liệu Gold (star schema)

- **fact_document_processing**: document_key, unit_key, date_key, doc_type, pages, status_final, time_to_extract_s, time_to_confirm_s, ocr_engine, model_version_key, cost_usd.
- **fact_field_extraction**: run_key, field_path, unit_key, confidence_bucket, was_corrected, correction_type (sai giá trị / thiếu / thừa), match_exact, match_fuzzy.
- **fact_user_activity**: user_pseudo_id, date_key, event_type, session_id, device_class.
- **fact_explain_query**: date_key, unit_key, guardrail_triggered, citations_count, latency_ms, tokens, feedback (👍/👎).
- **dim_unit, dim_date, dim_model_version, dim_prompt_version, dim_doc_type, dim_region.**

Các metric ở mục 10 phải tính được hoàn toàn từ Gold, có định nghĩa trong **metrics layer** (dbt semantic layer hoặc file YAML định nghĩa metric) để mọi dashboard dùng cùng một công thức.

15.4 Yêu cầu DE (DE-xxx)

Mã	Yêu cầu	Mức
DE-01	Pipeline idempotent: chạy lại cùng ngày cho cùng kết quả (ghi đè theo partition)	MUST
DE-02	Mọi pipeline có owner, lịch, SLA, cảnh báo thất bại và "dead man's switch"	MUST
DE-03	Dữ liệu rời RDS sang analytics phải giả danh hóa trước khi ghi Bronze; key HMAC nằm trong Secrets Manager, chỉ job DE đọc được	MUST
DE-04	Schema Bronze/Silver được quản lý (Glue Data Catalog), thay đổi schema phá vỡ → fail pipeline	MUST
DE-05	dbt test trên mọi model Silver/Gold: unique, not_null, accepted_values, relationships + test tùy chỉnh theo 14.4	MUST
DE-06	Backfill có tài liệu, chạy được theo khoảng ngày, không trùng	MUST
DE-07	Lineage cột từ nguồn tới dashboard (dbt docs / OpenLineage)	SHOULD
DE-08	Chi phí truy vấn Athena giới hạn bằng workgroup (bytes scanned limit)	SHOULD
DE-09	Dataset ML có version bất biến, Dataset Card, checksum	MUST
DE-10	Data quality report hằng tuần gửi PO + AI	SHOULD

15.5 Data contract mẫu (event `ExtractionConfirmed`)

```
contract: extraction_confirmed.v1
owner: backend
consumers: [analytics, ai-eval]
classification: C2   # đã giả danh hóa, không chứa giá trị lâm sàng thô
schema:
  event_id:        {type: uuid, required: true}
  occurred_at:     {type: timestamp_utc, required: true}
  user_pseudo_id:  {type: string, required: true, note: HMAC-SHA256}
  document_id:     {type: uuid, required: true}
  unit_code:       {type: string, required: true, enum_ref: units}
  fields_total:    {type: int, min: 1}
  fields_corrected:{type: int, min: 0}
  model_version:   {type: string, required: true}
  prompt_version:  {type: string, required: true}
quality:
  - fields_corrected <= fields_total
  - freshness: delivered within 15 minutes
sla: 99% events delivered within 15 minutes
breaking_change_policy: new version v2, run v1 and v2 in parallel for 30 days
```

15.6 Công cụ & dịch vụ cho DE (theo phase)

Phase	Lựa chọn tiết kiệm	Lựa chọn enterprise (học)
MVP	Postgres schema `analytics` riêng + dbt-postgres + cron + Metabase	—
v1.5	S3 + Parquet + Athena + dbt-athena + Prefect trên ECS	Glue Data Catalog, Lake Formation phân quyền cột
v2	Iceberg tables, Firehose cho event, QuickSight/Superset	DMS CDC, MWAA (Airflow managed), OpenLineage

15.7 Rủi ro đặc thù DE

- Lộ PHI sang analytics → giả danh hóa tại nguồn, Lake Formation chặn cột, review data contract.
- Pipeline "xanh" nhưng dữ liệu sai → test ngữ nghĩa (tỉ lệ sửa không thể âm, tổng khớp OLTP ±0.5%).

- Chi phí Athena tăng do quét toàn bảng → phân vùng theo ngày, Parquet, giới hạn workgroup.
- Xóa dữ liệu không đồng bộ giữa các kho → pipeline `dsr_delete` có checklist từng kho và báo cáo hoàn tất.

16. Solution Architecture

Solution Architect chịu trách nhiệm **mọi quyết định khó đảo ngược**: ranh giới hệ thống, mẫu tích hợp, lựa chọn nền tảng, và các thuộc tính chất lượng (quality attributes). Đầu ra chính là **Solution Architecture Document (SAD)** theo C4 + arc42, bộ ADR và các NFR có số đo.

16.1 Yêu cầu phi chức năng (NFR)

Mã	Thuộc tính	Yêu cầu đo được	Cách đạt	Kiểm chứng
NFR-01	Availability	API 99.5%/tháng (≤ 3h36m downtime)	Multi-AZ ALB/ECS, RDS Multi-AZ ở prod	CloudWatch SLO
NFR-02	Latency	p95 ≤ 300 ms, p99 ≤ 1 s cho API đọc	Index, cache Redis, pagination	k6
NFR-03	Throughput	50 req/s ổn định, 200 req/s đỉnh 5 phút	Auto scaling ECS theo CPU + request count	Load test
NFR-04	Xử lý tài liệu	95% xong < 2 phút; 100 tài liệu/giờ	Queue SQS + worker autoscale theo độ sâu queue	Load test pipeline
NFR-05	Scalability	Tăng 10× người dùng không đổi kiến trúc	Stateless API, worker tách, storage S3	Review
NFR-06	Durability	0 mất tài liệu đã upload thành công	S3 (11 nines), xác nhận chỉ sau khi ghi DB	Chaos test
NFR-07	Recoverability	RPO ≤ 24h (mục tiêu 5 phút với PITR), RTO ≤ 4h	AWS Backup, PITR, IaC dựng lại	DR drill
NFR-08	Security	ASVS L2, 0 High mở quá SLA	Mục 13	Security sign-off

Mã	Thuộc tính	Yêu cầu đo được	Cách đạt	Kiểm chứng
NFR-09	Privacy	Tuân thủ Luật 91/2025 + NĐ 356/2025	Mục 13–14	DPIA
NFR-10	Accessibility	WCAG 2.2 AA	Design System, axe	Audit
NFR-11	Usability	SUS ⩾ 70; người mới hoàn thành luồng chính ⩽ 5 phút	Usability test	Báo cáo
NFR-12	Maintainability	Thêm 1 Unit mới ⩽ 3 ngày công, không sửa core	Unit config + plugin viewer	Thực hiện thử ở v1.5
NFR-13	Observability	100% request có traceId; mọi cảnh báo có runbook	OpenTelemetry	Review
NFR-14	Portability	Đổi nhà cung cấp LLM/OCR ⩽ 2 ngày	Adapter pattern, eval harness	Thử đổi provider
NFR-15	Cost	⩽ $100/tháng ở 100 MAU; chi phí AI ⩽ $0.10/tài liệu	Serverless/Fargate Spot cho worker, cache	Cost report
NFR-16	i18n	VI + EN đầy đủ, dễ thêm ngôn ngữ	next-intl, nội dung y khoa song ngữ	Review
NFR-17	Compatibility	2 phiên bản mới nhất Chrome, Safari, Firefox, Edge; iOS 16+, Android 10+	Test matrix	Playwright

16.2 Quality attribute scenarios (ví dụ)

- **Availability:** *Khi* một AZ mất kết nối *trong giờ cao điểm*, *hệ thống* tiếp tục phục vụ API với lỗi 5xx < 1% và tự phục hồi trong 5 phút, không mất tài liệu đang xử lý (message quay lại queue).
- **Security:** *Khi* người dùng A đổi ID trong URL sang tài liệu của B, *hệ thống* trả 404, ghi audit và cảnh báo nếu ⩾ 10 lần/phút.

- **Modifiability:** *Khi* thêm Unit "Thận – Tiết niệu", *đội* chỉ thêm config, asset 2D/3D, schema trích xuất và nội dung, *trong* ≤ 3 ngày công, không deploy lại core API.
- **Cost:** *Khi* lưu lượng tăng gấp 5 trong 1 ngày, *chi phí AI* không vượt ngân sách ngày nhờ quota per-user và circuit breaker.

16.3 Danh sách ADR cần viết (ADR backlog)

#	Quyết định	Phương án	Khuyến nghị
ADR-001	Kiểu kiến trúc	Monolith / Modular monolith / Microservices	Modular monolith + AI worker
ADR-002	Ngôn ngữ backend	Python FastAPI / NestJS / Spring Boot	FastAPI
ADR-003	Identity provider	Keycloak tự host / Amazon Cognito / Auth0	Cognito trên AWS (ít vận hành); Keycloak nếu muốn học sâu OIDC
ADR-004	Compute	ECS Fargate / EKS / Lambda / App Runner	ECS Fargate (API + worker)
ADR-005	Hàng đợi	SQS / Redis (Celery) / EventBridge	SQS cho job, EventBridge cho domain event
ADR-006	OCR	PaddleOCR tự host / Textract / Document AI / LLM vision	Hybrid: PaddleOCR/VietOCR chính; LLM vision trên Bedrock cho chữ tay; Textract chỉ cho tài liệu tiếng Anh (Textract chưa hỗ trợ tiếng Việt)
ADR-007	LLM	Amazon Bedrock / API trực tiếp / tự host	Bedrock (dữ liệu không rời AWS, IAM, VPC endpoint)
ADR-008	Vector store	pgvector / OpenSearch / Bedrock Knowledge Bases	pgvector
ADR-009	Định dạng 3D	glTF/GLB + Draco / FBX / USDZ	glTF/GLB
ADR-010	Mẫu tích hợp event	Transactional outbox / dual-write	Outbox

#	Quyết định	Phương án	Khuyến nghị
ADR-011	Multi-tenant	Không (B2C) / theo tổ chức	Single-tenant B2C, `org_id` dự phòng cho B2B
ADR-012	Region AWS	ap-southeast-1 Singapore / ap-southeast-7 Thailand / khác	Singapore (đủ dịch vụ, gần VN); kiểm tra lại Bedrock model availability
ADR-013	Chuẩn dữ liệu y tế	Tự định nghĩa / FHIR-aligned	FHIR-aligned naming, export FHIR ở v2
ADR-014	Frontend rendering	SSR / SPA / hybrid	Next.js hybrid; viewer client-only

Mẫu ADR (Michael Nygard): *Title, Status, Context, Decision, Consequences, Alternatives considered, Date*.

16.4 Mẫu tích hợp & độ bền

- **Async request–reply:** upload trả 202 + `document_id`; FE theo dõi qua SSE; không giữ HTTP mở trong lúc OCR.
- **Retry + idempotency:** mọi consumer xử lý trùng an toàn (khóa idempotency = `event_id`); retry exponential backoff + jitter; tối đa N lần → DLQ + cảnh báo.
- **Circuit breaker + fallback:** LLM provider lỗi > 50% trong 1 phút → mở circuit, chuyển provider dự phòng hoặc giữ job trong queue.
- **Bulkhead:** worker OCR và worker LLM là hai service/queue riêng để lỗi một bên không làm nghẽn bên kia.
- **Saga đơn giản:** xóa tài khoản = chuỗi bước có bù trừ (đánh dấu → xóa S3 → xóa DB → xóa analytics → xóa vector → xác nhận).
- **Strangler/Adapter:** mọi dịch vụ bên ngoài (OCR, LLM, email) qua interface `Provider` để thay thế được.

16.5 Môi trường & phát hành

Môi trường	Mục đích	Dữ liệu	Quy mô	Deploy
local	Phát triển	Synthetic seed	Docker Compose	Tay

Môi trường	Mục đích	Dữ liệu	Quy mô	Deploy
dev	Tích hợp liên tục	Synthetic	Nhỏ nhất, tắt ban đêm	Tự động mỗi merge
staging	Kiểm thử trước phát hành, UAT, load test	Synthetic quy mô lớn	Giống prod (single-AZ được)	Tự động, sau đó gắn tag release
prod	Người dùng thật	Thật	Multi-AZ	Manual approval, blue/green

Feature flag (AWS AppConfig hoặc Unleash) để bật tắt Unit/tính năng mà không deploy; release train 2 tuần/lần theo sprint; hotfix đi nhánh riêng nhưng vẫn qua CI.

16.6 Governance kiến trúc (một người vẫn làm)

- **Architecture Review** ở cuối mỗi phase: đối chiếu NFR, ADR, rủi ro; ghi biên bản.
- **Fitness functions** tự động: test kiểm tra module không import chéo trái phép (import-linter), kích thước bundle FE, p95 latency trên staging, chi phí/ngày.
- **Tech radar** cá nhân: Adopt / Trial / Assess / Hold cho công nghệ trong dự án.
- **Definition of Architecture Done:** sơ đồ C4 cập nhật, ADR đầy đủ, NFR có test, threat model cập nhật, runbook tồn tại.

17. Backend chi tiết

Backend phải **đúng (phân quyền, dữ liệu), bền (job, retry), quan sát được (log/trace/metric) và dễ mở rộng (thêm Unit không sửa core)**. Mục này là "coding standard + API standard" mà một team BE doanh nghiệp sẽ ký vào.

17.1 Cấu trúc module (Clean / Hexagonal trong modular monolith)

```
apps/api/src/medilens/
├── core/                # config, logging, security, db session, errors,
telemetry
├── shared/              # kiểu dùng chung, pagination, idempotency, outbox
├── modules/
|   ├── identity/
|   |   ├── api/         # router FastAPI, DTO (Pydantic)
|   |   ├── application/  # use case / service, policy phân quyền
|   |   ├── domain/      # entity, value object, domain event, rule (BR-xxx)
|   |   └── infra/       # repository SQLAlchemy, adapter bên ngoài
|   ├── patient/  document/  extraction/  anatomy/  clinical/
|   ├── knowledge/  sharing/  notification/  audit/  admin/
└── main.py
apps/worker/src/medilens_worker/
├── jobs/                # validate, preprocess, classify, ocr, extract,
materialize…
├── providers/           # ocr_paddle.py, ocr_textract.py, llm_bedrock.py
(interface Provider)
└── pipeline/            # state machine, retry, DLQ
```

Quy tắc phụ thuộc: `api → application → domain`; `infra` cài đặt interface của `domain`. Module chỉ gọi nhau qua `application` service công khai hoặc domain event; **không** truy vấn bảng của module khác. Kiểm tra bằng import-linter trong CI.

17.2 Chuẩn API (BE-API-xxx)

Mã	Chuẩn	Mức
BE-API-01	OpenAPI 3.1 là nguồn sự thật; FE client sinh tự động; PR thay đổi API phải kèm OpenAPI diff	MUST
BE-API-02	URL danh từ số nhiều, kebab-case: `/api/v1/medical-documents/{id}/pages`	MUST
BE-API-03	Versioning theo URL (`/v1`); thay đổi phá vỡ → `/v2` , giữ v1 tối thiểu 90 ngày, header `Deprecation` , `Sunset`	MUST
BE-API-04	JSON field `camelCase` ở API, `snake_case` trong DB; thời gian ISO-8601 UTC	MUST

Mã	Chuẩn	Mức
BE-API-05	Pagination cursor (`?limit=&cursor=`), limit tối đa 100	MUST
BE-API-06	Lọc/sắp xếp theo allowlist (`?status=confirmed&sort=-observedAt`)	MUST
BE-API-07	Lỗi theo RFC 9457 Problem Details: `type` , `title` , `status` , `detail` , `instance` , `traceId` , `errors[]`	MUST
BE-API-08	`Idempotency-Key` bắt buộc cho POST tạo tài nguyên quan trọng (upload complete, share, export)	MUST
BE-API-09	Optimistic concurrency: `ETag` + `If-Match` cho PATCH extraction/condition	MUST
BE-API-10	Tác vụ dài: trả `202 Accepted` + `Location` tới tài nguyên trạng thái	MUST
BE-API-11	Rate limit header `RateLimit-Limit` , `RateLimit-Remaining` , `Retry-After`	SHOULD
BE-API-12	Stream giải thích LLM qua SSE, có heartbeat, hủy được	SHOULD

Bảng mã lỗi nghiệp vụ (trích):

HTTP	`type`	Khi nào
400	`/errors/validation`	Sai schema
401	`/errors/unauthenticated`	Thiếu/hết hạn token
403	`/errors/consent-required`	Chưa đồng ý điều khoản (BR-002)
404	`/errors/not-found`	Không tồn tại **hoặc không có quyền** (tránh lộ tồn tại)
409	`/errors/duplicate-document`	Trùng tài liệu (BR-016)
409	`/errors/version-conflict`	ETag không khớp
413	`/errors/file-too-large`	> 20 MB (BR-010)

HTTP	`type`	Khi nào
415	`/errors/unsupported-media`	Không phải JPG/PNG/HEIC/PDF
422	`/errors/low-quality-image`	Ảnh mờ (BR-011)
422	`/errors/unconfirmed-fields`	Còn trường vàng chưa xác nhận (BR-012)
429	`/errors/rate-limited`	Vượt quota
503	`/errors/ai-unavailable`	Circuit breaker AI mở

17.3 Chuẩn code & chất lượng (BE-CODE-xxx)

- Python 3.12, type hints đầy đủ, `mypy --strict` cho `domain` và `application`; `ruff` (lint + format); không `print`, dùng logger cấu trúc.
- Async end-to-end (asyncpg, httpx); không gọi blocking I/O trong event loop; CPU-bound (OCR, xử lý ảnh) chỉ ở worker.
- Transaction ở tầng application, một use case một transaction; outbox ghi cùng transaction.
- Mỗi BR-xxx có hàm/rule tên rõ (`ensure_fields_confirmed()`), có unit test mang tên mã rule.
- Config qua biến môi trường + Pydantic Settings; secret đọc từ Secrets Manager lúc khởi động; không giá trị mặc định cho secret.
- Logging JSON: `timestamp, level, service, env, traceId, spanId, userPseudoId, route, status, latencyMs` — không có PHI.
- Migration Alembic: mỗi migration có downgrade (hoặc ghi rõ lý do không thể), chạy thử trên bản sao staging trong CI.

17.4 Hiệu năng & dữ liệu

Hạng mục	Chuẩn
Query	Không N+1 (dùng `selectinload`), mọi query theo `profile_id` có index, `EXPLAIN` cho query > 50 ms
Connection pool	Pool theo số task ECS; dùng RDS Proxy khi số kết nối tăng

Hạng mục	Chuẩn
Cache	Redis/ElastiCache cho unit config (TTL 10 phút, invalidate khi publish), session rate limit; **không cache PHI**
Payload	Gzip/Brotli; danh sách trả tóm tắt, chi tiết qua endpoint riêng
Timeout	Client gọi ngoài: connect 2 s, read 30 s (LLM 120 s), có retry giới hạn
Ngân sách	API p95 ⩽ 300 ms; endpoint timeline ⩽ 500 ms với 5 năm dữ liệu

17.5 Kiểm thử backend

Tầng	Phạm vi	Công cụ	Ngưỡng
Unit	domain, rule BR, mapper	pytest, hypothesis (property-based cho parser răng/đơn vị)	Coverage domain ⩾ 90%
Integration	repository, outbox, RLS, S3 presign	pytest + Testcontainers (Postgres, LocalStack)	Luồng chính 100%
Contract	OpenAPI ↔ thực tế, FE ↔ BE	schemathesis, Pact (tùy chọn)	0 vi phạm
Authorization	Ma trận role × endpoint × ownership	pytest parametrize sinh từ OpenAPI	100% endpoint
Worker	Từng job + chuỗi pipeline với provider giả	pytest, moto	Luồng lỗi + retry + DLQ
Performance	API đọc/ghi, upload	k6	NFR-02/03
Migration	Upgrade/downgrade trên DB có dữ liệu	Alembic + Testcontainers	Pass

17.6 Checklist review PR backend

- [ ] Endpoint mới có policy phân quyền + test IDOR

- [ ] Input validate bằng DTO, output không lộ trường nội bộ
- [ ] Không log PHI/PII; lỗi trả Problem Details
- [ ] Transaction + outbox đúng; consumer idempotent
- [ ] Migration tương thích ngược
- [ ] OpenAPI cập nhật, client FE sinh lại
- [ ] Có metric/trace cho đường đi mới
- [ ] Test unit + integration; coverage không giảm

18. Frontend chi tiết

Frontend là nơi người bệnh *hiểu* bệnh của mình, nên tiêu chuẩn FE gồm 4 trụ: **dễ hiểu & không gây hoảng sợ, nhanh, truy cập được (a11y), an toàn**. Viewer 3D/2D là thành phần phức tạp nhất và có pipeline asset riêng.

18.1 Kiến trúc ứng dụng

```
apps/web/src/
├── app/[locale]/                # Next.js App Router, VI/EN
|   ├── (public)/                # landing, about, privacy — SSR/SSG
|   ├── (auth)/                  # login, register, mfa
|   └── (app)/                   # dashboard, documents, review, viewer,
timeline, share, settings, admin
├── features/                    # theo domain: documents/, review/,
viewer/, timeline/, explain/, sharing/
|   └── viewer/
|       ├── core/                # Canvas, camera, controls, raycast,
highlight, legend
|       ├── units/               # plugin: dental/, cardiology/, oncology/
(Viewer2D, Viewer3D, DetailPanel)
|       └── registry.ts          # đăng ký unit plugin
├── components/ui/               # Design System (shadcn) — không chứa logic
nghiệp vụ
├── lib/api/                     # client sinh từ OpenAPI + TanStack Query
hooks
├── lib/auth/                    # OIDC (next-auth/Auth.js hoặc Amplify),
guard
└── styles/tokens.css            # design tokens (màu mức độ BR-020,
spacing, typography)
```

- **Server state:** TanStack Query (cache, retry, invalidation theo key `['documents', id]`); **UI state:** Zustand (camera preset, unit đang chọn, chế độ x-ray); **form:** React Hook Form + Zod (schema dùng chung với API client).
- **Rendering:** trang công khai SSG; trang app render client sau khi xác thực; viewer `dynamic(() => import(...), { ssr: false })`.
- **Realtime:** EventSource (SSE) cho trạng thái tài liệu, tự kết nối lại, fallback polling 5 giây.

18.2 Pipeline asset 3D/2D (quan trọng nhất của FE)

1. **Nguồn:** Z-Anatomy/BodyParts3D (CC BY-SA), model tự làm Blender; ghi license vào `ATTRIBUTION.md`.
2. **Chuẩn hóa trong Blender:** đơn vị mét, trục Y-up, gốc tọa độ giữa khung chậu; tách mesh theo `region_code` của Unit config (ví dụ `tooth_36`, `heart_lv`, `lung_r_upper`); đặt tên mesh = `region_code`.
3. **Tối ưu:** decimate tới ngân sách polygon (toàn thân ≤ 150k tam giác, Unit chi tiết ≤ 80k), gộp material, texture ≤ 1024px KTX2.
4. **Xuất:** glTF 2.0 binary (`.glb`), nén Draco hoặc Meshopt bằng `gltf-transform`; tạo 2 mức LOD.
5. **Kiểm tra tự động trong CI:** script đọc GLB, so danh sách mesh với `regions[]` của Unit config → thiếu/thừa thì fail; kiểm tra kích thước ≤ 5 MB; render thumbnail để visual regression.
6. **2D SVG:** mỗi vùng là `<path id="region_code">`, có `<title>` song ngữ cho screen reader; tối ưu bằng SVGO nhưng giữ `id`.
7. **Phân phối:** S3 + CloudFront, cache bất biến theo hash tên file, `Content-Encoding` phù hợp.

18.3 Yêu cầu viewer (FE-VW-xxx)

Mã	Yêu cầu	Mức
FE-VW-01	Xoay/zoom/pan bằng chuột, chạm (pinch), bàn phím (mũi tên, +/−); nút reset camera	MUST
FE-VW-02	Click/tap vùng → panel chi tiết; hover → tooltip tên vùng VI/EN	MUST
FE-VW-03	Tô màu theo mức độ (BR-020) kèm biểu tượng/nhãn; chú giải (legend) luôn hiển thị	MUST

Mã	Yêu cầu	Mức
FE-VW-04	Chế độ x-ray (độ trong suốt da/cơ) để thấy nội tạng; lớp bật/tắt: xương, cơ, nội tạng, mạch, hạch	MUST
FE-VW-05	Di căn: đường nối cơ quan nguyên phát → vị trí di căn (BR-021), tách lớp "tham khảo"	MUST (Ung bướu)
FE-VW-06	Danh sách vùng dạng văn bản thay thế đầy đủ cho viewer (a11y)	MUST
FE-VW-07	Timeline: thanh trượt ngày, so sánh song song 2 thời điểm, animation chuyển trạng thái	SHOULD
FE-VW-08	Phát hiện WebGL yếu/không có → tự chuyển 2D, thông báo nhẹ	MUST
FE-VW-09	Chụp ảnh viewer để chia sẻ với bác sĩ (kèm watermark)	MAY
FE-VW-10	`prefers-reduced-motion` → tắt animation	MUST

18.4 Ngân sách hiệu năng

Chỉ số	Ngân sách
JS initial (route app)	≤ 200 KB gzip; viewer chunk tải riêng ≤ 350 KB gzip
LCP / INP / CLS	≤ 2.5 s / ≤ 200 ms / ≤ 0.1 (p75 thực tế, đo bằng web-vitals → CloudWatch RUM)
Model 3D	≤ 5 MB, tải ≤ 3 s trên 4G; hiển thị 2D trong lúc tải
FPS	≥ 50 desktop, ≥ 30 mobile tầm trung; draw calls ≤ 100
Bộ nhớ GPU	Dispose geometry/texture khi rời trang (tránh rò rỉ)

CI chặn PR nếu bundle vượt ngân sách (size-limit) hoặc Lighthouse CI < 90 ở trang công khai.

18.5 Accessibility & nội dung

- WCAG 2.2 AA: tương phản ≥ 4.5:1, focus rõ, điều hướng bàn phím mọi luồng, nhãn form, thông báo lỗi gắn với trường, `aria-live` cho trạng thái xử lý.
- Ngôn ngữ: lớp 6–8 (plain language), thuật ngữ y khoa có tooltip giải thích; luôn có disclaimer "thông tin minh họa, không thay thế bác sĩ".
- Nội dung nhạy cảm (ung thư, di căn): mở đầu bằng tóm tắt nhẹ nhàng, chi tiết ở dạng mở rộng; có liên kết hỗ trợ.
- i18n: không nối chuỗi; định dạng ngày/số theo locale; RTL không cần ở v1.

18.6 Bảo mật frontend (FE-SEC-xxx)

Mã	Yêu cầu	Mức
FE-SEC-01	Token chỉ trong cookie HttpOnly do BFF/route handler quản lý; không localStorage	MUST
FE-SEC-02	CSP với nonce, không inline script; Trusted Types khi có thể	MUST
FE-SEC-03	Không render HTML từ LLM; markdown qua renderer an toàn + DOMPurify	MUST
FE-SEC-04	Không đưa PHI vào URL query (dùng ID), không vào analytics/RUM	MUST
FE-SEC-05	Dependency audit, lockfile, chỉ tải script từ domain của app	MUST
FE-SEC-06	Xóa cache TanStack Query + state khi logout	MUST

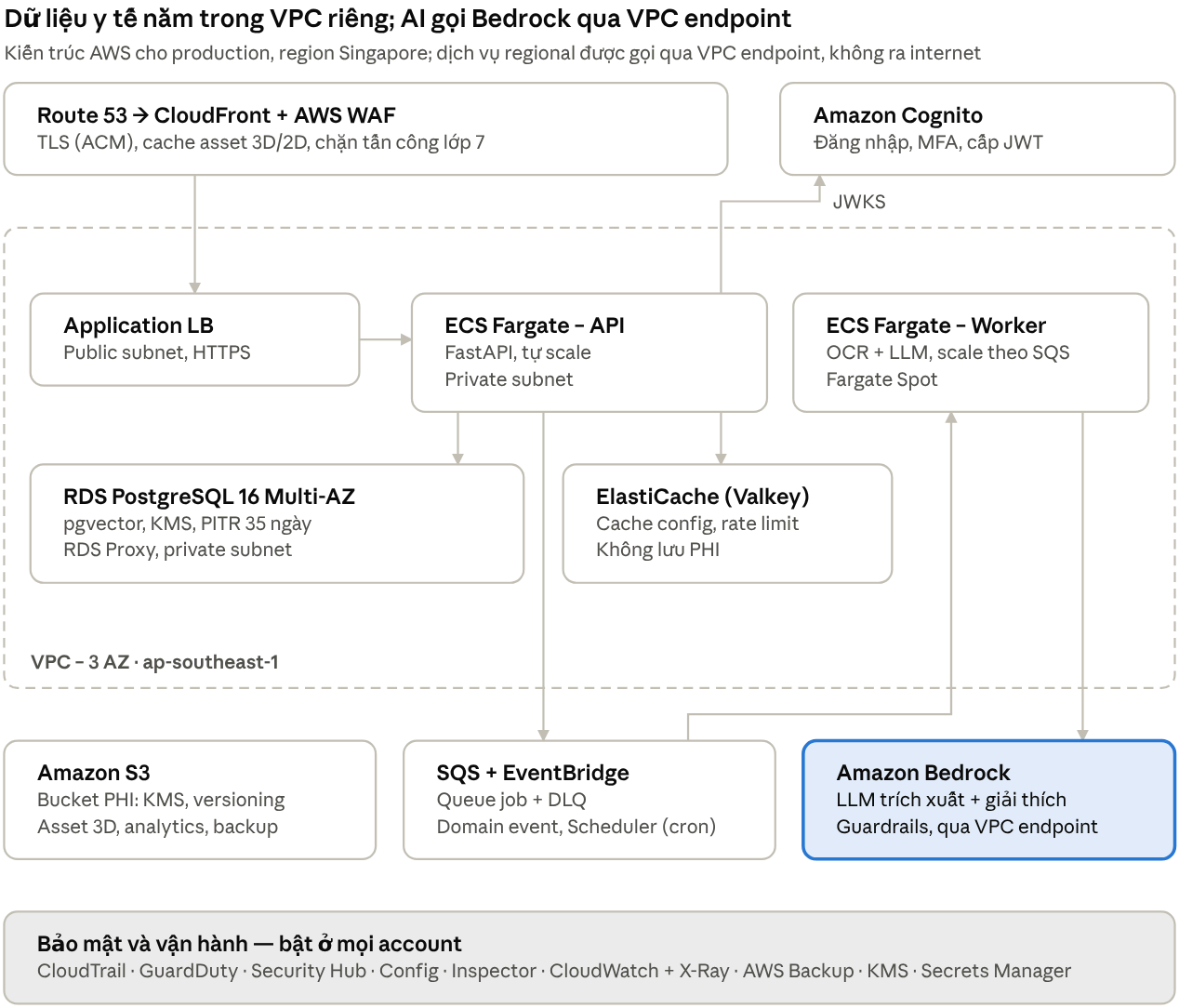
18.7 Kiểm thử frontend

Tầng	Công cụ	Phạm vi
Unit/component	Vitest + Testing Library	Hook, form, component Design System, mapper màu mức độ
Storybook + interaction	Storybook test runner, Chromatic (tùy chọn)	Mọi component UI, trạng thái loading/empty/error

Tầng	Công cụ	Phạm vi
Viewer	Playwright screenshot ở camera preset cố định, `toHaveScreenshot` với ngưỡng	Mỗi Unit, mỗi mức độ
E2E	Playwright với API mock (MSW) và với staging thật	Luồng đăng ký → upload → review → viewer → share
A11y	axe-core trong Playwright, kiểm tra tay bằng NVDA/VoiceOver mỗi release	0 lỗi serious
Cross-browser	Playwright projects: Chromium, WebKit, Firefox, mobile viewport	Luồng chính

19. Lựa chọn dịch vụ AWS

Khuyến nghị: **ECS Fargate + RDS PostgreSQL + S3 + SQS + Bedrock + Cognito** tại region **Singapore (ap-southeast-1)**, dựng bằng Terraform, nhiều account qua AWS Organizations. Bộ này phổ biến ở doanh nghiệp, ít vận hành cho một người, và giữ dữ liệu y tế trong AWS (kể cả khi gọi LLM). Bedrock có mặt ở cả Singapore và Thailand (ap-southeast-7), nhưng danh sách model khác nhau theo region — kiểm tra trang Regional availability trước khi chốt ADR-012.



kiến trúc AWS production · VPC 3 AZ, dịch vụ qua VPC endpoint

Worker đọc file từ S3 và ghi kết quả vào RDS (không vẽ để sơ đồ gọn); API chỉ cấp presigned URL, file đi thẳng từ trình duyệt lên S3.

19.1 Cấu trúc tài khoản (landing zone)

Account	Mục đích	Ghi chú
management	AWS Organizations, billing, IAM Identity Center	Không chạy workload
security	GuardDuty/Security Hub delegated admin, IAM Access Analyzer	Chỉ đọc

Account	Mục đích	Ghi chú
log-archive	CloudTrail org trail, Config, VPC Flow Logs, audit log ứng dụng	S3 Object Lock
shared-services	ECR, Route 53 hosted zone, artifact	Tùy chọn
dev / staging	Phát triển, kiểm thử	Chỉ dữ liệu synthetic; tắt ngoài giờ
prod	Người dùng thật	Multi-AZ, SCP chặt
backup-vault	AWS Backup vault cross-account	Chống ransomware/xóa nhầm

SCP tối thiểu: chặn region không dùng, chặn tắt CloudTrail/GuardDuty/Config, chặn tạo IAM user có access key, chặn chia sẻ snapshot ra ngoài, bắt buộc mã hóa S3/EBS. Giai đoạn đầu có thể chỉ dùng 3 account (management, nonprod, prod) rồi tách dần; AWS Control Tower giúp dựng nhanh nếu muốn học.

19.2 Thiết kế mạng

- VPC `/16` mỗi môi trường (dev 10.10.0.0/16, staging 10.20.0.0/16, prod 10.30.0.0/16), 3 AZ.
- Mỗi AZ 3 lớp subnet: **public** (ALB, NAT), **private-app** (ECS task), **private-data** (RDS, ElastiCache — không có route ra internet).
- NAT Gateway: 1 cái ở dev/staging (tiết kiệm), 1 cái/AZ ở prod; công cụ cập nhật qua NAT, còn dịch vụ AWS đi qua **VPC endpoint** (Gateway cho S3; Interface cho SQS, Bedrock Runtime, Secrets Manager, KMS, ECR, CloudWatch Logs, STS).
- Security Group tham chiếu lẫn nhau: ALB → API (8000), API/Worker → RDS (5432), API → ElastiCache (6379); không mở 0.0.0.0/0 ngoài ALB 443.
- VPC Flow Logs → log-archive; Route 53 Resolver DNS Firewall (tùy chọn) chặn domain độc.

19.3 Bảng lựa chọn dịch vụ

Nhu cầu	Dịch vụ chọn	Vì sao	Phương án khác (khi nào dùng)
DNS, CDN, chống tấn công	Route 53, CloudFront, AWS WAF, ACM, Shield Standard	TLS miễn phí, cache asset 3D gần người dùng, WAF managed rules	Cloudflare (rẻ hơn, ngoài AWS)
Frontend Next.js	ECS Fargate (container `web`) sau ALB, asset tĩnh qua S3 + CloudFront	Một mô hình deploy cho mọi service	AWS Amplify Hosting (nhanh nhất), Vercel (ngoài AWS)
API	ECS Fargate + ALB	Không quản lý server, autoscale, học container	App Runner (đơn giản hơn), Lambda + API Gateway (ít traffic), EKS (khi cần học K8s)
AI worker	ECS Fargate (Spot cho tác vụ có thể làm lại), scale theo độ sâu SQS	OCR cần RAM/CPU, thời gian chạy dài hơn giới hạn Lambda	AWS Batch / ECS trên EC2 GPU (khi tự host model CV/LLM), SageMaker endpoint
Xác thực	Amazon Cognito (User Pool, MFA, Hosted UI/OIDC)	Managed, tích hợp IAM, giá theo MAU	Keycloak trên ECS (học OIDC sâu, tự vận hành)
CSDL	RDS for PostgreSQL 16 (Multi-AZ ở prod) + RDS Proxy	pgvector, RLS, quen thuộc	Aurora PostgreSQL (khi cần scale đọc/serverless v2)
Cache	ElastiCache (Valkey/Redis)	Rate limit, cache config	Bỏ qua ở MVP (dùng Postgres)
Lưu file	S3 (Intelligent-Tiering), S3 Object Lock cho audit	Bền, rẻ, presigned URL	—
Hàng đợi	SQS Standard + DLQ (Celery hỗ trợ SQS làm broker)	Không quản lý, rẻ	Amazon MQ (RabbitMQ) nếu cần routing phức tạp

Nhu cầu	Dịch vụ chọn	Vì sao	Phương án khác (khi nào dùng)
Domain event & cron	EventBridge bus + EventBridge Scheduler	Thay cron server, có retry/DLQ	Step Functions (luồng nhiều bước có trạng thái — ví dụ xóa tài khoản)
LLM	Amazon Bedrock (Converse API, structured output, Guardrails, VPC endpoint)	Dữ liệu không rời AWS, IAM, nhiều model	API trực tiếp của nhà cung cấp; tự host trên EC2 GPU
OCR	PaddleOCR/VietOCR trong worker; LLM vision trên Bedrock cho chữ tay	Textract chưa hỗ trợ tiếng Việt	Textract cho tài liệu tiếng Anh
PII redaction	Amazon Comprehend (PII tiếng Anh) + rule/regex + NER tự xây cho tiếng Việt	Comprehend không phủ hết tiếng Việt nên cần lớp riêng	Model NER mở (PhoBERT fine-tune)
Email	Amazon SES	Rẻ, DKIM/SPF	Resend
Secret, key	Secrets Manager, KMS (CMK theo mục đích: phi, app, logs)	Xoay vòng, audit	SSM Parameter Store (cấu hình không bí mật)
Feature flag	AWS AppConfig	Rollout an toàn, rollback	Unleash
Container registry	ECR (scan bằng Inspector)	Tích hợp ECS	GHCR
CI/CD	GitHub Actions + OIDC → IAM role; ECS deploy (rolling hoặc blue/green với CodeDeploy)	Không cần access key	CodePipeline/CodeBuild
IaC	Terraform (state trong S3 + DynamoDB lock hoặc S3 native locking)	Chuẩn đa cloud	AWS CDK

Nhu cầu	Dịch vụ chọn	Vì sao	Phương án khác (khi nào dùng)
Quan sát	CloudWatch Logs/Metrics/Alarms, X-Ray qua ADOT, CloudWatch RUM, Synthetics canary	Native, ít vận hành	Amazon Managed Grafana + Prometheus; Datadog
Bảo mật	GuardDuty (kèm Malware Protection for S3), Security Hub, Config, Inspector, IAM Access Analyzer, CloudTrail, Macie (quét PII trong S3)	Phát hiện + tuân thủ liên tục	—
Backup	AWS Backup (RDS, S3) + vault cross-account	Một chỗ quản lý, khóa vault	Snapshot thủ công
Analytics	S3 + Glue Data Catalog + Athena + Lake Formation; QuickSight	Serverless, trả theo truy vấn	Redshift Serverless (khi dữ liệu lớn)
Chi phí	AWS Budgets, Cost Explorer, Cost Anomaly Detection, tag `project/env/owner`	FinOps	—

19.4 Lộ trình áp dụng AWS theo phase

Phase	Hạ tầng	Mục tiêu học
Foundation	Docker Compose local (Postgres, MinIO, LocalStack cho SQS/S3) + 1 account AWS nonprod: ECR, ECS Fargate, RDS single-AZ, S3, SQS, Cognito, CloudWatch	ECS, IAM role, Terraform cơ bản
Build MVP	Thêm Bedrock, EventBridge Scheduler, Secrets Manager, KMS CMK, WAF, CloudFront	Serverless integration, bảo mật dữ liệu

Phase	Hạ tầng	Mục tiêu học
Hardening	Organizations + account prod riêng, GuardDuty/Security Hub/Config/CloudTrail org, AWS Backup cross-account, VPC endpoints, RDS Multi-AZ	Landing zone, compliance, DR
Operate / v1.5	Athena/Glue/Lake Formation, AppConfig, CloudWatch RUM/Synthetics, Cost Anomaly Detection	Data platform, FinOps
Tùy chọn	EKS + Argo CD, SageMaker cho model CV	K8s, MLOps

19.5 Ước tính chi phí (tham khảo)

Con số dưới đây là **ước tính thô, chưa tra giá hiện tại** — hãy lập bảng riêng trên AWS Pricing Calculator. Các khoản lớn nhất thường là: NAT Gateway, RDS Multi-AZ, Fargate chạy 24/7, ALB, và token LLM.

Cấu hình	Thành phần chính	Mức chi phí ước tính/tháng
Nonprod tối giản	1 Fargate task nhỏ, RDS t4g.micro single-AZ, không NAT (dùng VPC endpoint + public subnet có kiểm soát) hoặc tắt ngoài giờ	Thấp (vài chục USD)
Prod nhỏ (100 MAU)	2 API task + worker Spot, RDS Multi-AZ nhỏ, 1–2 NAT, ALB, WAF, CloudFront	Trung bình (100–250 USD)
Tiết kiệm	Graviton (arm64), Fargate Spot cho worker, Savings Plans khi ổn định, tắt dev/staging ban đêm bằng Scheduler, S3 Intelligent-Tiering, cache kết quả LLM	—

19.6 Đối chiếu AWS Well-Architected

Trụ cột	Áp dụng trong MediLens
Operational Excellence	IaC, runbook, CI/CD, post-mortem, canary

Trụ cột	Áp dụng trong MediLens
Security	Mục 13, multi-account, KMS, VPC endpoint, GuardDuty
Reliability	Multi-AZ, SQS + DLQ, retry, AWS Backup, DR drill
Performance Efficiency	Fargate autoscale, CloudFront, cache, Graviton
Cost Optimization	Spot, Budgets, tag, tắt nonprod, Intelligent-Tiering
Sustainability	Graviton, scale-to-zero cho worker khi không có job

Tự chạy **Well-Architected Tool** (miễn phí trong console) cuối phase Hardening và lưu báo cáo vào `docs/architecture`.

20. Vận hành & bảo trì (Maintain)

Sau khi ra mắt, phần lớn công sức của một sản phẩm doanh nghiệp năm ở **vận hành**: giữ hệ thống chạy, an toàn, rẻ và đúng. Vận hành của MediLens theo thực hành **ITIL 4 rút gọn + SRE**: có lịch định kỳ, có quy trình thay đổi, có quy trình sự cố, có vòng đời cho model AI và nội dung y khoa.

20.1 Lịch bảo trì định kỳ

Tần suất	Việc	Role	Băng chứng
Hăng ngày (tự động)	Kiểm tra backup, eval AI nightly, data quality, cost anomaly, cron dead-man	SRE/DE/AI	Dashboard + cảnh báo
Hăng ngày (10 phút)	Xem dashboard SLO, lỗi Sentry mới, DLQ, finding GuardDuty	SRE	Ghi chú daily
Hăng tuần	Merge PR Renovate (dependency), triage bug, review correction rate AI, review cost	DevOps/QA/AI	Changelog
Hăng tuần	Ngày bảo trì (2 giờ): dọn nợ kỹ thuật nhỏ, cập nhật runbook	Tất cả	Ticket

Tần suất	Việc	Role	Bằng chứng
Hằng tháng	Vá base image + rebuild, rotate secret không tự động, xem lại IAM Access Analyzer, retention cleanup, báo cáo SLO/error budget	DevOps/Security/SRE	Báo cáo tháng
Hằng tháng	Duyệt lại nội dung y khoa đến hạn, xem phản hồi người dùng	BA/Medical reviewer	Danh sách duyệt
Hằng quý	DR drill (restore RDS + S3 vào account tạm), access review, tabletop sự cố, đánh giá lại model/provider mới, cập nhật threat model	SRE/Security/AI	Biên bản
Hằng quý	Load test lại trên staging, xem capacity, Well-Architected review	SRE	Báo cáo
6 tháng	Pentest tự thực hiện theo ASVS, xem lại DPIA và chính sách quyền riêng tư	Security	Báo cáo
Hằng năm	Nâng phiên bản lớn (PostgreSQL, Python, Node, Next.js), xoay KMS key, xem lại kiến trúc & roadmap, gia hạn domain	Tất cả	ADR/Release

20.2 Quản lý thay đổi (Change Management)

Loại	Ví dụ	Quy trình	Phê duyệt
Standard (đã chuẩn hóa)	Merge Renovate patch, deploy tính năng đã qua CI	Pipeline tự động	Không cần thêm
Normal	Migration schema, đổi model/prompt AI, thêm Unit, đổi IAM	RFC ngắn (mục đích, rủi ro, rollback, kiểm thử) trong PR	Bạn đóng vai CAB, checklist

Loại	Ví dụ	Quy trình	Phê duyệt
Emergency	Vá lỗ hổng Critical, hotfix sự cố SEV1	Làm trước, viết RFC trong 24 giờ	Ghi nhận sau

Mọi thay đổi production đều có: ticket, PR, kết quả CI, kế hoạch rollback, người kiểm tra sau deploy (smoke test), ghi vào changelog. Cửa sổ freeze: không deploy thay đổi Normal khi error budget đã hết.

20.3 Quản lý sự cố & vấn đề

Mức	Định nghĩa	Phản hồi	Ví dụ
SEV1	Lộ dữ liệu, toàn hệ thống ngừng	Ngay lập tức, cập nhật mỗi 30 phút	Bucket PHI public, RDS down
SEV2	Tính năng chính hỏng cho nhiều người	≤ 1 giờ	Pipeline AI dừng, đăng nhập lỗi
SEV3	Lỗi một phần, có cách vòng	≤ 1 ngày làm việc	Một Unit hiển thị sai màu
SEV4	Nhỏ, thẩm mỹ	Theo sprint	Lỗi chính tả

Vòng đời: phát hiện → phân loại → giảm thiểu (rollback/feature flag/scale) → khắc phục → **post-mortem không đổ lỗi trong 48 giờ** (timeline, nguyên nhân gốc bằng 5 Whys, action item có hạn) → **problem management**: gom sự cố lặp lại thành ticket sửa tận gốc. Trang trạng thái (status page) công khai khi có beta.

20.4 Quản lý lỗ hổng & bản vá

Mức CVSS	SLA khắc phục	Nguồn phát hiện
Critical (9.0+)	24 giờ (hoặc biện pháp giảm thiểu)	Inspector, Dependabot, Trivy, GuardDuty
High (7.0–8.9)	7 ngày	Như trên + ZAP
Medium	30 ngày	Như trên

Mức CVSS	SLA khắc phục	Nguồn phát hiện
Low	90 ngày hoặc chấp nhận rủi ro có ghi lại	Như trên

20.5 FinOps (quản lý chi phí)

- Tag bắt buộc `project`, `env`, `owner`, `cost-center` (Config rule kiểm tra).
- AWS Budgets: cảnh báo 50/80/100% ngân sách tháng; Cost Anomaly Detection hằng ngày.
- Chi phí theo đơn vị: **USD/tài liệu xử lý**, **USD/người dùng hoạt động**, **USD/1.000 câu hỏi giải thích** — theo dõi trên dashboard.
- Tối ưu định kỳ: right-size task Fargate theo CPU/RAM thực tế, Graviton, Spot cho worker, tắt nonprod ban đêm, xem NAT data processing, cache LLM, model nhỏ hơn cho bước đơn giản (phân loại trang).

20.6 Vòng đời model AI & prompt (MLOps/LLMOps)

1. **Đăng ký:** mỗi cấu hình (provider, model ID, prompt version, tham số) có ID và Model/Prompt Card.
2. **Đánh giá trước phát hành:** golden set + red-team set; điều kiện: không giảm > 1 điểm F1 ở bất kỳ Unit nào, guardrail ≥ ngưỡng.
3. **Phát hành dần:** shadow mode (chạy song song, không hiển thị) → canary 10% (AppConfig) → 100%.
4. **Giám sát:** correction rate, phân bố confidence, tỉ lệ unmapped, latency, chi phí; cảnh báo drift khi lệch > 20% so với tuần trước.
5. **Rollback:** đổi flag về cấu hình trước trong < 5 phút.
6. **Ngừng dùng:** khi provider thông báo deprecate model, lên kế hoạch đổi trong 30 ngày; giữ khả năng tái hiện kết quả cũ (lưu `model_version` trong mỗi `extraction_run`).

20.7 Vòng đời nội dung y khoa & Unit

- KnowledgeArticle: nháp → duyệt (nguồn, ngày, ngôn ngữ) → xuất bản → duyệt lại sau 12 tháng → lưu trữ.
- Unit config: thay đổi qua PR, test mapping tự động, bản nháp trên staging, publish có version; viewer cache bị vô hiệu khi version đổi.
- Danh mục mã (ICD-10, LOINC): cập nhật khi có bản mới, migration dữ liệu có kiểm thử.

20.8 Support & phản hồi người dùng

Loại yêu cầu	Kênh	SLA phản hồi	Xử lý
Lỗi	In-app feedback (đính kèm traceId, không đính kèm PHI)	2 ngày làm việc	Bug ticket
Câu hỏi sử dụng	FAQ, email	2 ngày làm việc	Cập nhật FAQ
Yêu cầu dữ liệu cá nhân (xem/xóa/rút đồng ý)	Settings + email	Xác nhận 72 giờ, hoàn tất ⩽ 30 ngày	Quy trình DSR, audit
Báo cáo lỗ hổng	`security.txt`, email riêng	72 giờ	Vulnerability disclosure policy

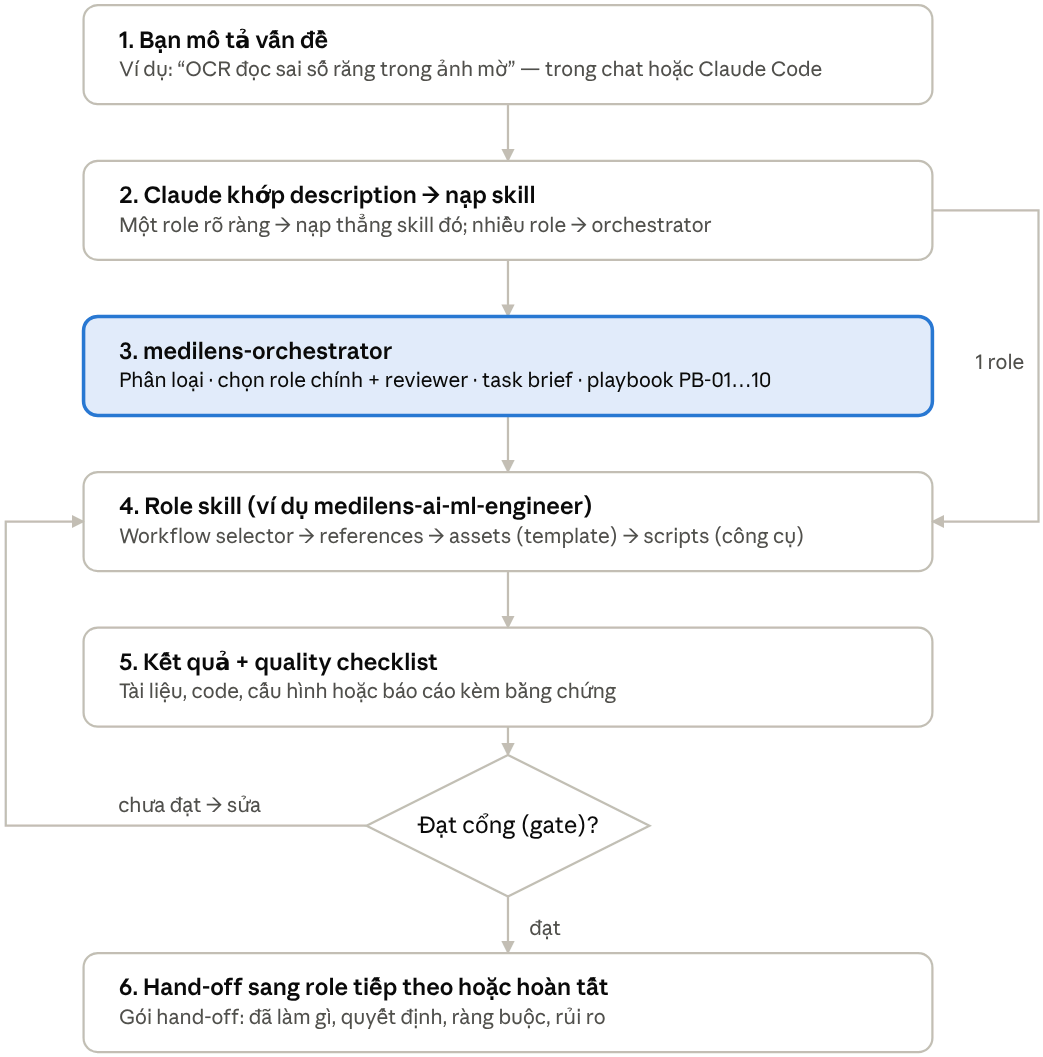
20.9 Tài liệu vận hành bắt buộc

- [ ] Runbook cho mỗi alarm (triệu chứng, kiểm tra, khắc phục, leo thang)
- [ ] Runbook deploy, rollback, restore DB, restore S3, xoay secret, xử lý DLQ, đổi provider LLM
- [ ] On-call guide và danh sách liên hệ (nhà cung cấp, cơ quan chức năng khi vi phạm dữ liệu)
- [ ] Service catalog: mỗi service có owner, SLO, dashboard, repo, runbook
- [ ] Maintenance calendar và biên bản các lần DR drill

21. AI Agent theo role: bộ Skill

Mỗi role của dự án có một **Agent Skill theo chuẩn Anthropic** (thư mục có `SKILL.md` với frontmatter `name` + `description`, kèm `references/`, `assets/`, `scripts/`), cộng một skill **`medilens-orchestrator`** để định tuyến. Tổng cộng 14 skill, 175 file, đóng gói trong `medilens-skills-full.zip` (gửi kèm trong chat); thư mục `dist/` có zip riêng từng skill để upload.

Mỗi vấn đề được định tuyến tới đúng skill của role, và chỉ đi tiếp khi qua cổng



luồng agent → skill · định tuyến, thực hiện, cổng, hand-off

Claude chỉ nạp phần `description` của mọi skill vào ngữ cảnh; nội dung đầy đủ và các file reference chỉ được đọc khi skill được dùng, nên bộ skill lớn vẫn không tốn ngữ cảnh.

21.1 Danh sách skill

Skill	Role	Khi nào được gọi	Output chính	Script
`medilens-orchestrator`	Điều phối	Việc nhiều role, không rõ ai phụ trách, kế hoạch end-to-end	Routing, task brief, playbook PB-01…10, hand-off	—
`medilens-business-analyst`	BA	Yêu cầu, user story, Gherkin, business rule, glossary, UAT	BRD, SRS, story, BR catalog, traceability	`check_traceability.py`
`medilens-product-manager`	PO/PM	Ưu tiên, sprint, roadmap, OKR, rủi ro, trễ tiến độ	Sprint plan, status, risk register, decision log	`rice_score.py`
`medilens-ux-ui-designer`	UX/UI	Màn hình, luồng, viewer, câu chữ, accessibility	Screen spec, design tokens, usability test	—
`medilens-solution-architect`	Solution Architect	Chọn công nghệ, ADR, NFR, mẫu tích hợp	ADR, NFR, C4, design note	—

Skill	Role	Khi nào được gọi	Output chính	Script
`medilens-ai-ml-engineer`	AI/ML	OCR, CV, LLM, mapping, RAG, guardrail, eval, dữ liệu giả	Schema, prompt, eval report, model card	`eval_extraction.py`, `blur_check.py`, `fdi_parser.py`, `pii_redact.py`
`medilens-data-engineer`	DE	Phân loại dữ liệu, pipeline, dbt, DQ, contract, retention, xóa dữ liệu	Catalog, pipeline spec, contract, DSR checklist	`pseudonymize.py`, `dq_check.py`
`medilens-backend-engineer`	BE	API, phân quyền, migration, worker, outbox	Code theo template, test authz, OpenAPI	—
`medilens-frontend-engineer`	FE	Trang, component, viewer 3D/2D, plugin Unit, hiệu năng	Code, plugin, asset GLB/SVG chuẩn	`check_glb_regions.py`
`medilens-cloud-devops-engineer`	Cloud/DevOps	Dịch vụ AWS, Terraform, CI/CD, deploy, chi phí	Terraform module, workflow CI/CD, Dockerfile	—

Skill	Role	Khi nào được gọi	Output chính	Script
`medilens-security-engineer`	Security	Threat model, review, OWASP, Luật BVDLCN, sự cố	Threat model, DPIA, vendor assessment, sign-off	`scan_log_for_pii.py`
`medilens-qa-engineer`	QA	Chiến lược test, test case, automation, load test	Test plan, test case, Playwright, k6	—
`medilens-qc-release-gatekeeper`	QC	GO/NO-GO, exploratory, duyệt nội dung y khoa, UAT	Readiness report, content review	`release_gate.py`
`medilens-sre-operations`	SRE/Maintain	SLO, alarm, sự cố, runbook, DR, bảo trì	Runbook, post-mortem, DR record, ops report	`error_budget.py`

21.2 Cấu trúc một skill (ví dụ AI/ML)

```
medilens-ai-ml-engineer/
├── SKILL.md                        # frontmatter + Workflow selector W1…W10 +
quy tắc an toàn
├── references/
|   ├── project-context.md          # ngữ cảnh chung (có trong mọi skill)
|   ├── pipeline-spec.md            # hợp đồng từng stage, ngưỡng, xử lý lỗi
|   ├── extraction-schemas.md       # JSON Schema dental / cardiology /
oncology
|   ├── prompt-library.md           # prompt phân loại, trích xuất, mapping,
giải thích, judge
|   ├── evaluation-methodology.md
|   ├── guardrails-and-rag.md
|   ├── synthetic-data-recipe.md
|   └── medical-glossary-vi-en.md
├── assets/                         # eval report, model card, dataset card
└── scripts/                        # eval_extraction.py, blur_check.py,
fdi_parser.py, pii_redact.py
```

21.3 Ví dụ cách agent xử lý vấn đề

Bạn nói	Skill được gọi	Agent làm gì
“OCR đọc sai số răng trong ảnh chụp mờ”	ai-ml-engineer (W6)	Lấy 30 lỗi, gắn nhãn nguyên nhân, chạy `blur_check.py` và `fdi_parser.py`, sửa bước lớn nhất, chạy lại eval
“Thêm khoa Thận – Tiết niệu”	orchestrator → PB-02	BA → UX → AI (schema) → DE (danh mục) → FE (GLB/SVG) → BE (config) → QA → QC, mỗi bước có gate
“User A xem được tài liệu của user B”	security-engineer (W8) → backend (W5)	Xử lý sự cố, chặn ngay, sửa bằng test authz, đánh giá nghĩa vụ thông báo
“Có release bản 1.0 được không?”	qc-release-gatekeeper (W1)	Gom metrics, chạy `release_gate.py`, viết readiness report GO/NO-GO

Bạn nói	Skill được gọi	Agent làm gì
“Hóa đơn AWS tháng này tăng gấp đôi”	cloud-devops-engineer (W6)	Phân tích Cost Explorer theo tag, tìm NAT/Fargate/token, đề xuất cắt giảm
“Web báo lỗi 500 liên tục”	sre-operations (W3)	Khai báo SEV, rollback/tắt flag trước, điều tra bằng traceId, post-mortem

21.4 Cài đặt và quản trị skill

- **Claude Code:** chép thư mục skill vào `.claude/skills/` trong repo MediLens (commit để version theo code) hoặc `~/.claude/skills/`; gọi trực tiếp bằng `/medilens-<role>`.
- **claude.ai / Claude app:** tải từng zip trong `dist/` lên phần Skills.
- **Quản trị:** skill là “quy trình dạng code” — thay đổi qua PR, tăng `metadata.version`, ghi lý do; khi quy trình thực tế đổi (ví dụ thêm Unit, đổi nhà cung cấp LLM) thì cập nhật `project-context.md` và đóng gói lại.
- **Giới hạn:** agent là trợ lý; quyết định GO/NO-GO, chấp nhận rủi ro, nội dung pháp lý và y khoa vẫn do bạn (và chuyên gia khi có dữ liệu thật) chịu trách nhiệm.

Phần III – Rà soát theo chuẩn dự án lớn và mở rộng

Rà soát Phần I–II theo vòng đời của các dự án phần mềm y tế lớn cho thấy kế hoạch đã mạnh về kỹ thuật nhưng còn thiếu **5 mảng**: khởi tạo & quản trị dự án, **pháp lý thiết bị y tế (SaMD)**, **an toàn lâm sàng**, **quản trị dữ liệu & license**, và **vận hành sau ra mắt (hypercare, hỗ trợ, đóng dự án)**. Phần III bổ sung các mảng này, thêm 9 role, mở rộng input sang bệnh án số, mô tả bằng text và ảnh CT, và đưa ra chiến lược chọn model tiết kiệm chi phí. Lộ trình mới dài **52 tuần (26 sprint)**, thay cho lộ trình 32 tuần ở mục 5; chi tiết từng ngày năm trong file Excel kèm theo.

22. Gap analysis: vòng đời dự án lớn so với MediLens

Bảng dưới đối chiếu các bước mà dự án y tế số quy mô doanh nghiệp thường bắt buộc có với kế hoạch hiện tại. Cột *Trạng thái* cho biết bước đó đã có trong Phần I–II hay được bổ sung ở Phần III.

22.1 Bảng đối chiếu theo vòng đời

Giai đoạn	Bước / tài liệu bắt buộc ở dự án lớn	Trạng thái	Bổ sung cụ thể
Khởi tạo	Project Charter, Business Case, Feasibility Study	Bổ sung	Charter 2 trang (mục tiêu, phạm vi, ngân sách, rủi ro, tiêu chí thành công); business case có phương án "không làm"
Khởi tạo	Stakeholder register, Communication plan, Governance (Steering Committee)	Bổ sung	Steering = bạn + 1 mentor + 1 bác sĩ cố vấn, họp cuối mỗi phase; báo cáo tháng
Khởi tạo	Intended Use Statement & phân loại thiết bị y tế (SaMD)	**Bổ sung – quan trọng**	Xem 22.2; quyết định ghi thành Regulatory Decision Record
Lập kế hoạch	Baseline phạm vi/tiến độ/chi phí, WBS, quản lý thay đổi baseline	Có một phần	Baseline ghi ở file Excel; mọi thay đổi baseline qua Change Request
Lập kế hoạch	Quality Management Plan (QMS rút gọn), kiểm soát tài liệu	Bổ sung	Tài liệu có mã, version, người duyệt; quy trình CAPA (khắc phục – phòng ngừa)
Lập kế hoạch	Clinical Risk Management Plan, Hazard Log	**Bổ sung – quan trọng**	Áp dụng nguyên tắc ISO 14971: nhận diện mối nguy → đánh giá → kiểm soát → rủi ro tồn dư; Clinical Safety Officer ký duyệt
Lập kế hoạch	Procurement & vendor management, License register (dataset, asset 3D, phần mềm, thuật ngữ y khoa)	Bổ sung	Sổ license (mục 25), quét license mã nguồn mở trong CI

Giai đoạn	Bước / tài liệu bắt buộc ở dự án lớn	Trạng thái	Bổ sung cụ thể
Lập kế hoạch	Ethics review khi dùng dữ liệu bệnh nhân thật từ cơ sở y tế	Bổ sung	Thỏa thuận chia sẻ dữ liệu + phê duyệt hội đồng đạo đức của đối tác trước khi nhận dữ liệu
Lập kế hoạch	Responsible AI: AI impact assessment, phân tầng rủi ro model, minh bạch	Bổ sung	AI Impact Assessment mỗi khi thêm model/use case; đánh giá thiên lệch theo nhóm (tuổi, giới, chất lượng ảnh, chữ tay)
Thiết kế	Design controls: user needs → design input → design output → verification → validation	Có một phần	Chuỗi truy vết mở rộng: BR/FR → spec → code → test → usability/clinical validation (22.3)
Thiết kế	Usability engineering (IEC 62366 – formative & summative)	Có một phần	Thêm summative usability test ở Hardening với kịch bản sử dụng sai (use-error)
Thiết kế	Interoperability & thuật ngữ (FHIR, DICOM, ICD-10, LOINC, SNOMED CT)	Có một phần	Role Clinical Informaticist; license thuật ngữ; nhập bệnh án số (mục 26)
Xây dựng	Secure SDLC, kiến trúc, code, test	Đã có	Bổ sung thiết kế dịch vụ bảo mật dữ liệu (mục 24)
Kiểm chứng	System V&V, clinical/expert validation (đồng thuận với bác sĩ về mapping và nội dung)	Bổ sung	Nghiên cứu xác thực với ≥ 2 bác sĩ trên 100 hồ sơ synthetic; đo agreement
Kiểm chứng	Pentest độc lập, Vulnerability Disclosure Program	Có một phần	Pentest bên ngoài trước khi có dữ liệu thật; `security.txt` + VDP
Phát hành	Release management, Go/No-Go, release notes	Đã có	Thêm cổng Regulatory và Clinical Safety vào release gate
Phát hành	Hypercare 2–4 tuần, mô hình hỗ trợ L1/L2/L3, tài liệu người dùng, đào tạo	Bổ sung	Role Support & Customer Success, Technical Writer

Giai đoạn	Bước / tài liệu bắt buộc ở dự án lớn	Trạng thái	Bổ sung cụ thể
Phát hành	Go-to-market: định vị, kiểm soát tuyên bố marketing (không tuyên bố chẩn đoán)	Bổ sung	Claims review do Regulatory duyệt
Vận hành	Service management, SLA, BCP, cải tiến liên tục	Đã có	Bổ sung Business Continuity Plan và post-market surveillance (theo dõi sự cố an toàn lâm sàng)
Đóng dự án	Lessons learned, nghiệm thu, bàn giao, kế hoạch ngừng dịch vụ & tiêu hủy dữ liệu	Bổ sung	Closure report mỗi phase; Decommission plan (xuất dữ liệu cho người dùng, xóa an toàn, thông báo)

22.2 Pháp lý thiết bị y tế (SaMD) — cần quyết định sớm

Ở Việt Nam, định nghĩa trang thiết bị y tế bao gồm cả **phần mềm** dùng cho mục đích y tế như chẩn đoán hoặc theo dõi (Pure Global). Văn bản gốc là Nghị định 98/2021/NĐ-CP, đã được sửa đổi bởi Nghị định 07/2023 và Nghị định 04/2025. Việc phân loại A–D theo Thông tư 05/2022 và các sửa đổi sau đó. Cách xếp loại phụ thuộc vào **mục đích sử dụng (intended use)**. Vì vậy:

1. **Viết Intended Use Statement ngay ở Discovery.** Ví dụ: *"MediLens giúp người dùng xem lại và hiểu thông tin đã được ghi trong hồ sơ y tế của chính họ dưới dạng hình minh họa và nội dung giáo dục có nguồn. MediLens không chẩn đoán, không đề xuất điều trị, không phân tích hình ảnh để phát hiện bệnh."*
2. **Giữ sản phẩm trong phạm vi minh họa/giáo dục** ở v1: không tự phát hiện tổn thương trên ảnh, không chấm điểm nguy cơ, không gợi ý điều trị. Mọi tính năng vượt ranh giới này (ví dụ CV tự phát hiện tổn thương trên CT) phải qua đánh giá lại.
3. **Ghi Regulatory Decision Record**: intended use, lập luận vì sao (không) là thiết bị y tế, tham chiếu văn bản, ngày rà soát lại. Nếu thương mại hóa hoặc mở rộng sang CT, hỏi ý kiến luật sư/chuyên gia đăng ký trang thiết bị y tế và kiểm tra cổng thông tin của Bộ Y tế.
4. **Kiểm soát tuyên bố**: landing page, store listing, nội dung LLM không được dùng từ như "chẩn đoán", "phát hiện bệnh", "thay thế bác sĩ".

5. **Tham chiếu quốc tế để học**: khung SaMD của IMDRF, IEC 62304 (vòng đời phần mềm y tế), ISO 14971 (quản lý rủi ro), IEC 62366 (khả năng sử dụng), ISO 13485 (QMS). Dự án cá nhân không bắt buộc chứng nhận, nhưng áp dụng tinh thần các chuẩn này là đúng cách dự án lớn vận hành.

Bối cảnh bệnh án điện tử: Thông tư 13/2025/TT-BYT (hiệu lực 21/7/2025) yêu cầu bệnh viện triển khai bệnh án điện tử trước 30/9/2025 và các cơ sở khác trước 31/12/2026. Thông tư không quy định về ứng dụng bên thứ ba hay API cho bệnh nhân, nên tích hợp trực tiếp phụ thuộc quy chế riêng của từng cơ sở. MediLens vì thế vẫn lấy bản bệnh án mà người dùng tự có (ảnh, PDF, file xuất).

22.3 Chuỗi kiểm soát thiết kế (design controls) áp dụng cho MediLens

1. **User needs** (persona, phỏng vấn) → `UN-xxx`
2. **Design inputs** (BR, FR, NFR, SEC, yêu cầu an toàn lâm sàng `CS-xxx`) → BRD/SRS
3. **Design outputs** (kiến trúc, API, schema, prompt, UI spec, code)
4. **Verification** (unit/integration/E2E/eval AI: "làm đúng spec chưa?")
5. **Validation** (summative usability, đánh giá bởi bác sĩ: "đáp ứng đúng nhu cầu và an toàn chưa?")
6. **Design transfer / release** (release gate, hồ sơ phát hành)
7. **Post-market** (phản hồi, sự cố an toàn, cập nhật hazard log)

Ma trận truy vết mở rộng thêm cột `UN`, `CS` (clinical safety requirement) và `VAL` (validation evidence). Script `check_traceability.py` của skill BA được dùng tương tự.

22.4 Cổng mới bổ sung vào roadmap

Cổng	Thời điểm	Tiêu chí
G0-R (Regulatory)	Cuối Discovery	Intended Use + Regulatory Decision Record được duyệt
G1-D (Data licence)	Trước khi train/fine-tune bất kỳ model nào	Mọi dataset có license hợp lệ cho mục đích sử dụng, Dataset Card đầy đủ
G2-CS (Clinical safety)	Trước beta	Hazard log không còn rủi ro "không chấp nhận được"; Clinical Safety Case được ký

Cổng	Thời điểm	Tiêu chí
G3-P (External pentest)	Trước khi nhận dữ liệu thật	Không còn High/Critical; báo cáo pentest lưu hồ sơ
G5-H (Hypercare exit)	4 tuần sau launch	Không S1/S2 mới trong 2 tuần, SLO đạt, backlog hỗ trợ ổn định

23. Các role còn thiếu và cách bổ sung

Dự án y tế lớn luôn có những người **không phải kỹ sư** nhưng có quyền chặn phát hành: bác sĩ phụ trách an toàn lâm sàng, người phụ trách pháp lý/quyền riêng tư, và người quản lý dữ liệu. MediLens bổ sung **9 role**. Mỗi role có một skill mới trong bộ skill (tổng 23 skill). Với 3 role có dấu ★, bạn vẫn đóng vai để học, nhưng **cần một người thật** trước khi dùng dữ liệu thật hoặc ra mắt công khai.

23.1 Danh sách role bổ sung

Role	Vì sao dự án lớn cần	Trách nhiệm chính	Phase tham gia	Skill
★ Clinical Safety Officer / Bác sĩ cố vấn	Nội dung y khoa sai có thể gây hại; cần người có chuyên môn chịu trách nhiệm	Hazard log, Clinical Safety Case, duyệt mapping vùng giải phẫu và nội dung, xác thực lâm sàng, theo dõi sự cố an toàn sau ra mắt	Discovery → Operate	`medilens-clinical-safety-officer`
★ Regulatory, Privacy & Legal (gồm DPO)	Pháp lý thiết bị y tế, Luật BVDLCN, hợp đồng, license	Intended use, Regulatory Decision Record, DPIA/OTIA, consent, điều khoản, kiểm soát tuyên bố, AI governance policy	Discovery → Operate	`medilens-regulatory-privacy-officer`

Role	Vì sao dự án lớn cần	Trách nhiệm chính	Phase tham gia	Skill
Clinical Informaticist	Chuẩn dữ liệu y tế quyết định khả năng tích hợp và chất lượng mã hóa	Mô hình FHIR, ICD-10/LOINC/SNOMED mapping, DICOM, nhập bệnh án số, license thuật ngữ	Foundation → v2	`medilens-clinical-informaticist`
★ Data Curator & Annotation Lead	Model chỉ tốt bằng dữ liệu; dữ liệu y tế cần license và gán nhãn chuyên môn	Thu thập dữ liệu, sổ license, hướng dẫn gán nhãn, điều phối người gán nhãn (sinh viên y), QA nhãn, Dataset Card	Discovery → Operate	`medilens-data-curator`
MLOps Engineer	Model cần được phục vụ, giám sát, tối ưu chi phí như một hệ thống	Model registry, model router (phân tầng), cache, batch, serving GPU, cost dashboard, drift	Build → Operate	`medilens-mlops-engineer`
Medical Imaging Engineer	CT/DICOM là miền kỹ thuật riêng	Tiếp nhận DICOM, de-identification, viewer lát cắt, segmentation, dựng mesh, căn chỉnh với mô hình mẫu	v1.5 → v2	`medilens-medical-imaging-engineer`
3D Medical Artist	Mô hình giải phẫu cần đúng, đẹp, nhẹ và có license	Dựng/chỉnh mesh, đặt tên theo region code, biến thể giải phẫu, thư viện thiết bị cấy ghép, LOD	Foundation → v2	`medilens-3d-medical-artist`
Technical Writer & Localization	Tài liệu và bản dịch y khoa sai gây hiểu nhầm	Hướng dẫn người dùng, FAQ, tài liệu API, release notes, dịch VI/EN có glossary, kiểm tra thuật ngữ	Build → Operate	`medilens-technical-writer`

Role	Vì sao dự án lớn cần	Trách nhiệm chính	Phase tham gia	Skill
Support & Customer Success	Sau ra mắt cần người tiếp nhận phản hồi và sự cố	Mô hình hỗ trợ L1/L2/L3, hypercare, knowledge base, phân loại phản hồi an toàn lâm sàng, đo hài lòng	Beta → Operate	`medilens-support-success`

23.2 Các vai trò dự án lớn khác (gộp vào role sẵn có)

Vai trò ở doanh nghiệp	Gộp vào	Ghi chú
Scrum Master / Delivery Manager	Product Manager	Bảo vệ nghi thức sprint, gỡ vướng
Release Manager	QC Release Gatekeeper	Lịch phát hành, Go/No-Go
DBA	Backend + Data Engineer	Tuning, backup, migration
FinOps Analyst	Cloud/DevOps + MLOps	Chi phí hạ tầng và chi phí token
Penetration Tester	Security (tự làm) + thuê ngoài trước G3-P	Không tự kiểm định chính mình ở cổng cuối
Accessibility Specialist	UX/UI + QA	Kiểm tra với trình đọc màn hình
Ethics / Responsible AI	Regulatory & Privacy + Clinical Safety	AI impact assessment

23.3 Khi nào cần người thật

Mốc	Người cần có	Hình thức gợi ý
Cuối Discovery	Bác sĩ cố vấn (1–2 giờ/tháng)	Mentor/bạn học ngành y; ký Clinical Safety Case ở G2-CS
Trước khi nhận dữ liệu thật	Luật sư/chuyên gia bảo vệ dữ liệu	Tư vấn một lần về DPIA, consent, OTIA, intended use

Mốc	Người cần có	Hình thức gợi ý
Trước khi gán nhãn quy mô lớn	2–3 sinh viên y khoa	Hợp đồng ngắn, NDA, chỉ làm trên dữ liệu synthetic/đã khử định danh
Trước G3-P	Pentester độc lập	Thuê theo gói hoặc chương trình bug bounty nhỏ

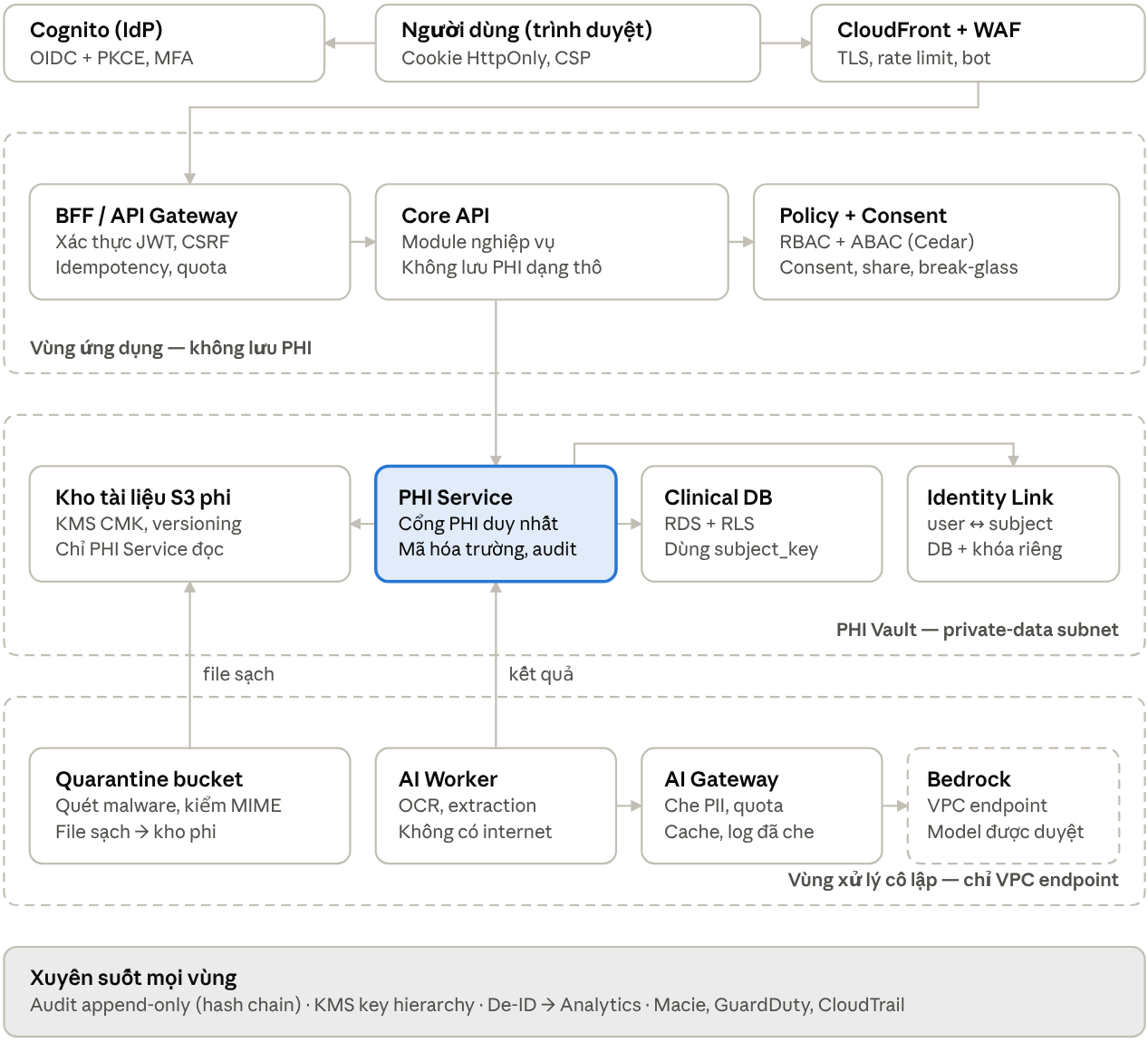
23.4 RACI bổ sung (role mới)

Quyết định	CSO	Reg/Priv	Clin. Inf.	Data Curator	MLOps	Imaging	3D Artist	Writer	Support
Nội dung y khoa được xuất bản	A	C	C	I	I	I	I	R	I
Mapping vùng giải phẫu	A	I	R	C	I	C	R	I	I
Dùng một dataset để train	C	A	C	R	C	C	I	I	I
Đổi model/provider	C	C	I	C	R	I	I	I	I
Thêm input CT	A	A	C	C	C	R	C	I	I
Phát hành ra công chúng	A	A	I	I	C	I	I	C	C
Phản hồi liên quan an toàn	A	C	I	I	I	I	I	I	R

24. Thiết kế backend & service bảo mật dữ liệu y tế

Nguyên tắc trung tâm: **chỉ một service — PHI Service — được đọc/ghi dữ liệu y tế**, danh tính người dùng được **tách khỏi** dữ liệu lâm sàng bằng khóa giả danh `subject_key`, mỗi hồ sơ có **khóa mã hóa riêng** để xóa bằng crypto-shredding, và vùng xử lý AI **không có internet**, chỉ gọi LLM qua AI Gateway. Thiết kế này vẫn nằm trong modular monolith (ADR-001): PHI Service và AI Gateway là hai service chạy riêng vì chúng là ranh giới bảo mật, không phải vì cần scale riêng.

PHI chỉ đi qua một cổng là PHI Service; worker xử lý không có internet



vùng tin cậy và đường đi của dữ liệu y tế

Core API không bao giờ truy vấn trực tiếp Clinical DB hay S3 phi; mọi yêu cầu đi qua PHI Service, nơi kiểm tra policy, giải mã trường và ghi audit trong cùng một chỗ.

24.1 Danh sách service và kiểm soát

Service	Trách nhiệm	Lớp dữ liệu	Lưu trữ	Ai được gọi	Kiểm soát chính
BFF / API Gateway	Xác thực, phiên, CSRF, rate limit, idempotency	C2	Redis (không PHI)	Trình duyệt	JWT kiểm audience/issuer, cookie HttpOnly, WAF phía trước
Core API	Nghiệp vụ không chứa PHI: Unit config, knowledge, sharing metadata, notification	C1–C2	RDS schema `core`	BFF	Không có quyền IAM/DB tới dữ liệu PHI
Policy & Consent	Quyết định truy cập: role + quyền sở hữu + share + consent + break-glass	C2	RDS schema `policy`	Core API, PHI Service	Policy viết bằng Cedar (Amazon Verified Permissions hoặc thư viện Cedar trong service), có test
PHI Service	Cổng duy nhất đọc/ghi C4: tài liệu, OCR, extraction, finding, observation	C4	Clinical DB, S3 phi	Core API, AI Worker (bằng IAM role riêng)	Gọi Policy mỗi request; mã hóa trường; ghi audit; trả về tối thiểu trường cần thiết
Identity Link	Ánh xạ `user_id` ↔ `subject_key`	C3	DB riêng + CMK riêng	Chỉ PHI Service	Tách danh tính khỏi dữ liệu lâm sàng; lộ Clinical DB không lộ danh tính
Ingestion (quarantine)	Nhận file qua presigned URL, quét malware, kiểm MIME, chuyển file sạch vào S3 phi	C4	S3 quarantine (TTL 24 h)	Trình duyệt (PUT có điều kiện)	Bucket riêng, không ai đọc ngoài scanner; GuardDuty Malware Protection for S3
AI Worker	OCR, extraction, mapping	C4 (trong bộ nhớ)	Không lưu lâu dài; ghi kết quả qua PHI Service	SQS	Subnet không route internet; chỉ VPC endpoint tới S3, SQS, AI Gateway
AI Gateway	Mọi lời gọi LLM đi qua đây: che PII, policy prompt, quota, cache, định tuyến model, log đã che, đo chi phí	C4 → C2	Cache theo hash (KMS), log 30 ngày	AI Worker, Explain service	Allowlist model; guardrails; circuit breaker; không cho gọi trực tiếp Bedrock từ nơi khác (IAM deny)

Service	Trách nhiệm	Lớp dữ liệu	Lưu trữ	Ai được gọi	Kiểm soát chính
De-ID service	Xuất dữ liệu giả danh/khử định danh sang analytics và dataset	C4 → C2/C0	S3 analytics	Pipeline DE	HMAC, bỏ trường C3, kiểm k-anonymity
Audit service	Ghi sự kiện truy cập, append-only, chuỗi hash chống sửa	C2	RDS + S3 Object Lock	Mọi service	Không có API xóa/sửa; mỗi bản ghi chứa hash bản ghi trước

24.2 Phân cấp khóa (key hierarchy)

Khóa	Loại	Bảo vệ	Xoay vòng	Ghi chú
`kms/phi`	KMS CMK	S3 phi, Clinical DB, backup PHI	Hằng năm (tự động)	Chỉ role PHI Service, AI Worker (decrypt S3)
`kms/identity`	KMS CMK	Identity Link DB	Hằng năm	Chỉ PHI Service
DEK theo hồ sơ	Data key (envelope) sinh từ `kms/phi`	Trường nhạy cảm và văn bản OCR của một hồ sơ	Khi yêu cầu	Xóa DEK = xóa mềm không thể khôi phục (crypto-shredding)
`kms/app`	KMS CMK	Secrets, cache, SQS	Hằng năm	—
`kms/logs`	KMS CMK	CloudWatch Logs, audit S3	Hằng năm	Account log-archive
HMAC key analytics	Secret	Giả danh hóa	Khi nghi lộ	Chỉ De-ID service đọc

24.3 Ma trận truy cập dữ liệu

Chủ thể	C4 của chính mình	C4 được chia sẻ	C4 người khác	C3	Analytics (C2)
Patient	Đọc/ghi/xóa	—	Không	Chính mình	Không
Caregiver	Hồ sơ người được giám hộ	—	Không	Chính mình	Không
Clinician	—	Đọc theo phạm vi + thời hạn	Không	Tên người chia sẻ	Không
Admin	—	—	Chỉ break-glass (1 h, có lý do, cảnh báo)	Theo nhiệm vụ	Đọc dashboard
AI Worker (máy)	Xử lý tài liệu được giao qua job	—	Không	Không	Không
Data Engineer	Không	Không	Không	Không	Đọc/ghi
AI/ML Engineer	Không (chỉ synthetic/đã consent + khử định danh)	Không	Không	Không	Đọc

24.4 Các luồng bảo mật chính

1. **Upload:** BFF cấp presigned PUT tới bucket quarantine (5 phút, giới hạn kích thước/loại) → GuardDuty Malware Protection quét → Lambda/worker kiểm magic bytes, chuyển PDF thành ảnh → PHI Service ghi metadata, chuyển object sang S3 phi → xóa bản quarantine.
2. **Đọc finding cho viewer:** Core API gọi PHI Service với principal → Policy (Cedar) trả permit/deny kèm lý do → PHI Service đọc theo `subject_key`, giải mã trường cần thiết, ghi audit → trả DTO tối thiểu.
3. **Gọi LLM:** Worker gửi văn bản tới AI Gateway → che PII → kiểm quota/ngân sách → tra cache → chọn model theo tầng (mục 28) → Bedrock qua VPC endpoint → kiểm JSON Schema → trả kết quả, log đã che.
4. **Analytics:** De-ID service đọc qua PHI Service bằng role riêng, HMAC định danh, bỏ C3, ghi Bronze; không ai có cả khóa HMAC và quyền đọc analytics.
5. **Xóa tài khoản:** Step Functions: thu hồi phiên → xóa DEK của hồ sơ → xóa object S3 (mọi version) → xóa bản ghi Identity Link → xóa dòng analytics theo pseudo id → xác nhận.

6. **Admin khẩn cấp:** không SSH; truy cập qua SSM Session Manager có ghi phiên; break-glass tạo quyền tạm qua IAM Identity Center, tự hết hạn.

24.5 Phương án theo mức độ trưởng thành

Mức	Khi nào	Thiết kế
A — MVP học tập	Chỉ dữ liệu synthetic	PHI Service là module riêng trong monolith, schema DB riêng, role DB riêng; RLS; AI Gateway là thư viện dùng chung
B — Beta có dữ liệu thật	Trước G3-P	PHI Service và AI Gateway tách thành ECS service riêng với IAM role riêng; Identity Link DB riêng; DEK theo hồ sơ; worker subnet không internet
C — Doanh nghiệp	Khi có đối tác bệnh viện	Account AWS riêng cho PHI Vault, PrivateLink giữa account; Verified Permissions; Macie quét định kỳ; SIEM; pentest hằng năm

24.6 Yêu cầu bổ sung (SEC-AR-xx)

Mã	Yêu cầu	Mức
SEC-AR-01	Chỉ PHI Service có quyền IAM/DB tới Clinical DB và S3 phi; kiểm bằng IAM Access Analyzer và test	MUST
SEC-AR-02	Clinical DB không chứa email, tên, số điện thoại; chỉ `subject_key`	MUST
SEC-AR-03	Worker subnet không có route tới NAT/Internet Gateway	MUST
SEC-AR-04	Mọi lời gọi LLM đi qua AI Gateway; IAM deny `bedrock:InvokeModel*` cho mọi role khác	MUST
SEC-AR-05	Audit log có chuỗi hash, kiểm tính toàn vẹn hằng ngày	SHOULD
SEC-AR-06	DEK theo hồ sơ, xóa tài khoản bằng crypto-shredding	SHOULD (MUST từ mức B)

Mã	Yêu cầu	Mức
SEC-AR-07	Policy truy cập viết dạng code (Cedar) và có test cho mọi quy tắc BR-006, BR-030, BR-031	MUST
SEC-AR-08	DICOM được khử định danh (PS3.15) trước mọi bước xử lý; bản gốc chỉ chủ sở hữu tải lại được	MUST (v2)
SEC-AR-09	File PDF/DOCX/ZIP nhập vào chỉ được parse trong worker sandbox sau khi quét malware; từ chối macro, JavaScript action, liên kết ngoài và zip bomb	MUST

25. Chiến lược dữ liệu: thu thập, license, đủ bao nhiêu, duy trì

Dữ liệu y tế khác dữ liệu thông thường ở ba điểm: **nhạy cảm** (cần consent và khử định danh), **bị ràng buộc license** (nhiều bộ dữ liệu cấm thương mại hoặc cấm phân phối lại), và **cần chuyên môn để gán nhãn**. Chiến lược của MediLens đi theo 4 tầng, từ rủi ro thấp đến cao: **(1) synthetic tự tạo → (2) dữ liệu công khai có license phù hợp → (3) dữ liệu người dùng tự nguyện đóng góp (opt-in) → (4) dữ liệu từ cơ sở y tế đối tác**. Chỉ lên tầng tiếp theo khi đã qua cổng của tầng trước.

25.1 Mỗi thành phần AI cần dữ liệu gì

Thành phần	Dữ liệu cần	Nhãn	Bộ đánh giá tối thiểu	Bộ huấn luyện/tinh chỉnh (nếu có)
Kiểm tra chất lượng ảnh	Ảnh chụp tài liệu tốt/xấu	tốt/xấu + lý do	300 ảnh	Không cần train (ngưỡng)
Phân loại trang	Trang bệnh án theo 9 loại	loại trang	30/loại (≈ 270)	200–500/loại nếu train classifier
OCR tiếng Việt	Dòng chữ in + viết tay	text chuẩn	2.000 dòng	Chỉ khi fine-tune VietOCR: 10k+ dòng
Trích xuất trường	Bệnh án đủ loại theo Unit	JSON theo schema	200/Unit (golden)	1.000–3.000 tài liệu/Unit nếu distill model nhỏ
Chuẩn hóa mã	Cặp (cụm từ → ICD-10/LOINC)	mã đúng	500 cặp	Từ điển + embedding, ít cần train

Thành phần	Dữ liệu cần	Nhãn	Bộ đánh giá tối thiểu	Bộ huấn luyện/tinh chỉnh (nếu có)
Mapping giải phẫu	Cụm từ vị trí → region_code	region + bên	300 cụm từ/Unit	Rule + LLM, không train
Giải thích RAG	Bài viết y khoa đã duyệt + câu hỏi	câu trả lời chuẩn, nguồn	200 câu hỏi + 100 red-team	Không train
Mô tả bằng text	Câu mô tả triệu chứng VI/EN	thực thể + vị trí	300 câu	Không train ở v1
CT (v2)	CT có segmentation cơ quan	mask cơ quan	30–50 ca đối chiếu	Dùng model có sẵn (TotalSegmentator)
Răng trên X-quang (v1.5+)	Ảnh panorama có đánh số răng	bbox + số FDI	100 ảnh	700+ ảnh (tham chiếu quy mô DENTEX)

25.2 Nguồn dữ liệu và license (đã kiểm tra)

Nguồn	Nội dung	License / điều kiện	Dùng được cho MediLens?
Synthetic tự sinh	Bệnh án giả theo template từng Unit	Của bạn	Có — nguồn chính cho dev và golden set
VinDr-CXR (Việt Nam)	X-quang ngực có chú thích bác sĩ	PhysioNet Credentialed Health Data License 1.5.0; cần tài khoản credentialed, khóa CITI, ký DUA	Chỉ nghiên cứu/học tập theo DUA; không phân phối lại; không dùng trong sản phẩm thương mại nếu DUA không cho phép
MIMIC-IV-Note và các bộ PhysioNet credentialed khác	Ghi chú lâm sàng tiếng Anh	Credentialed DUA tương tự	Như trên; chỉ dùng để học/ đánh giá nội bộ

Nguồn	Nội dung	License / điều kiện	Dùng được cho MediLens?
Bộ dữ liệu trên TCIA (ví dụ LIDC-IDRI cho CT phổi)	CT, giải phẫu bệnh, ung thư	Phần lớn CC BY 3.0/4.0 cho cả mục đích thương mại; một số bộ hạn chế; bộ đầu–cổ có thể dựng lại khuôn mặt chuyển sang giấy phép hạn chế (TCIA Data Usage Policy)	Có, với trích dẫn đúng; kiểm tra license từng bộ
Medical Segmentation Decathlon	10 bài toán: 6 CT (gan, phổi, tụy, đại tràng, mạch gan, lách), 4 MRI	CC BY-SA 4.0 (cho phép thương mại, sản phẩm phái sinh phải chia sẻ cùng license)	Có — lưu ý điều khoản share-alike với dữ liệu phái sinh
TotalSegmentator trên NCI IDC	Segmentation giải phẫu tự động trên CT (chủ yếu NLST)	CC BY 4.0	Có — dùng tham chiếu cho pipeline CT
DENTEX	X-quang răng toàn cảnh, đánh số răng và bệnh lý	CC BY-NC-SA 4.0	Chỉ phi thương mại (học tập, đánh giá); không dùng trong bản thương mại
MTSamples (bản trên Kaggle)	~5.000 bản ghi chép lâm sàng tiếng Anh	Bản Kaggle ghi CC0 nhưng là dữ liệu cào từ mtsamples.com, điều khoản gốc chưa rõ (clinspacy docs)	Chỉ học tập/đánh giá nội bộ; không đưa vào sản phẩm
ViMQ	Câu hỏi y tế tiếng Việt có nhãn ý định và thực thể	Không thấy license công bố	Liên hệ tác giả trước khi dùng
ICD-10 bản tiếng Việt (Bộ Y tế)	Danh mục mã bệnh	Văn bản quản lý nhà nước	Có — nạp làm master data
LOINC	Mã xét nghiệm	Miễn phí, theo điều khoản LOINC, cần đăng ký	Có

Nguồn	Nội dung	License / điều kiện	Dùng được cho MediLens?
SNOMED CT	Thuật ngữ lâm sàng	Quốc gia không phải thành viên phải xin license qua MLDS, phí theo phân loại World Bank, có thể được miễn phí (SNOMED International)	Chỉ dùng khi có license; v1 dùng ICD-10 + từ điển riêng
BodyParts3D / Z-Anatomy	Mô hình giải phẫu 3D	CC BY-SA	Có, ghi attribution, chia sẻ cùng license phần chỉnh sửa asset

Quy tắc đọc license: `NC` = cấm thương mại; `SA` = sản phẩm phái sinh phải dùng cùng license; `DUA` = cấm phân phối lại, thường giới hạn mục đích; phải kiểm tra riêng **quyền huấn luyện model** và **quyền dùng model đã huấn luyện trong sản phẩm**. Mỗi dataset vào **License Register** trước khi tải về (cổng G1-D).

25.3 Thu thập dữ liệu thật (khi đã sẵn sàng)

Kênh	Cách làm	Điều kiện bắt buộc
Người dùng đóng góp (opt-in)	Sau khi xác nhận kết quả, người dùng chọn "Đóng góp hồ sơ đã ẩn danh để cải thiện MediLens"	Consent riêng, rõ mục đích, rút lại được; khử định danh tự động + kiểm tra ngẫu nhiên; chỉ dùng cho phiên bản dataset sau ngày consent
Bác sĩ/sinh viên y viết ca bệnh giả	Thuê viết 200–500 bệnh án giả sát thực tế theo từng Unit	Hợp đồng chuyển giao quyền, NDA, không dựa trên bệnh nhân thật
Đối tác cơ sở y tế	Nhận bộ hồ sơ đã khử định danh cho nghiên cứu	Thỏa thuận chia sẻ dữ liệu, phê duyệt hội đồng đạo đức của đối tác, DPIA, tuân thủ quy chế bệnh án điện tử của cơ sở, OTIA nếu xử lý ngoài Việt Nam

Kênh	Cách làm	Điều kiện bắt buộc
Gán nhãn bởi sinh viên y	Gán trên dữ liệu synthetic/đã khử định danh	Hướng dẫn gán nhãn, NDA, trả công minh bạch, bác sĩ duyệt 10–20%

Khử định danh: văn bản dùng `pii_redact.py` + NER và người kiểm tra ngẫu nhiên. Tham chiếu 18 loại định danh của HIPAA Safe Harbor như checklist. Ảnh DICOM dùng confidentiality profile của chuẩn DICOM PS3.15, xóa tag định danh và kiểm tra chữ in trên ảnh (burned-in) bằng OCR.

25.4 Bao nhiêu là đủ?

- **Bộ đánh giá:** cỡ mẫu theo khoảng tin cậy $n = z^2 \cdot p(1-p) / e^2$. Với độ chính xác kỳ vọng p = 0,85, sai số e = ±5%, độ tin cậy 95% (z = 1,96): n ≈ 196 → **≈ 200 mẫu cho mỗi nhóm** cần báo cáo riêng (mỗi Unit, mỗi loại tài liệu chính). Muốn ±3% thì cần ≈ 545 mẫu.
- **Bộ huấn luyện:** quyết định bằng **learning curve**. Train với 10%, 25%, 50%, 100% dữ liệu; nếu điểm còn tăng rõ ở 100% thì thu thêm, nếu đã bão hòa thì dừng. Con số ở bảng 25.1 chỉ là điểm xuất phát.
- **Độ phủ quan trọng hơn số lượng:** mỗi nhóm (chữ in/chữ tay, ảnh tốt/xấu, mỗi loại phiếu, VI/EN) cần ≥ 30 mẫu trong golden set để phát hiện thiên lệch.
- **Chất lượng nhãn:** Cohen's kappa ≥ 0,8 giữa hai người gán; bất đồng do bác sĩ phân xử.

25.5 Duy trì dữ liệu để luôn dùng được cho model

Hoạt động	Tần suất	Chi tiết
Dataset registry	Mỗi phiên bản	Mỗi dataset có ID, version bất biến, checksum, Dataset Card, license, nguồn, ngày tạo, model nào đã dùng
License register	Khi thêm nguồn; rà soát mỗi quý	Kiểm tra license còn hiệu lực, điều kiện trích dẫn, giới hạn thương mại
Làm mới golden set	Mỗi quý	Thêm 10–20% mẫu mới phản ánh lỗi thực tế; giữ phần lõi cố định để so sánh theo thời gian

Hoạt động	Tần suất	Chi tiết
Theo dõi drift	Hăng tuần	Phân bố loại tài liệu, chất lượng ảnh, tỉ lệ sửa của người dùng; lệch > 20% → thu dữ liệu bổ sung
Rút consent	Theo sự kiện	Loại khỏi các phiên bản dataset sau đó; model kế tiếp train lại không có dữ liệu đó; ghi lineage
Gán nhãn lại	Khi đổi schema	Script chuyển đổi nhãn + kiểm tra mẫu; schema version gắn với dataset version
Lưu trữ & xóa	Theo bảng 14.3	Dataset synthetic giữ lâu dài; dữ liệu đóng góp giữ theo thời hạn đã công bố
Lineage dữ liệu → model	Mỗi lần train/đổi prompt	Model card ghi dataset version; có thể truy ngược model nào dùng dữ liệu nào

25.6 Checklist cổng G1-D (trước khi train/tinh chỉnh)

- [ ] Mọi nguồn có trong License Register, license cho phép đúng mục đích (huấn luyện, thương mại nếu cần)
- [ ] Dataset Card đầy đủ; checksum; version bất biến
- [ ] Không có dữ liệu thật thiếu consent; khử định danh đã kiểm tra mẫu
- [ ] Phân tầng đủ nhóm; nhãn đạt kappa ≥ 0,8
- [ ] Golden set tách biệt, không rò rỉ vào tập train (kiểm tra trùng băng hash)
- [ ] Regulatory & Privacy và Data Curator đã ký

26. Input đa phương thức: ảnh chụp, bệnh án số, mô tả text, ảnh CT

Mỗi loại input có pipeline riêng nhưng cùng đổ về **một mô hình finding chung**. Trong đó mỗi finding mang *loại nguồn* (theo hồ sơ / người dùng tự mô tả / suy ra từ ảnh CT), *băng chứng gốc*, *độ tin cậy* và *trạng thái xác nhận*. Viewer hiển thị khác nhau theo loại nguồn để người dùng không nhầm "mình mô tả" với "bác sĩ đã ghi".

Bốn loại input, một mô hình chung: mỗi finding ghi rõ nguồn và mức xác nhận



4 loại input · pipeline riêng · một mô hình finding chung

Khi các nguồn mâu thuẫn (ví dụ người dùng mô tả đau bên trái, hồ sơ ghi bên phải), hồ sơ được ưu tiên và cả hai được hiển thị kèm cảnh báo "thông tin không khớp — hãy hỏi bác sĩ".

26.1 Đặc tả từng loại input

Input	Định dạng & giới hạn	Xử lý	Kết quả	Cách hiển thị	Rủi ro chính
Ảnh chụp bệnh án	JPG/PNG/HEIC, ≤ 20 MB/ảnh, ≤ 30 trang	Pipeline mục 6.4	Finding `record`, có bounding box	Nét liền, màu mức độ	OCR sai, chữ tay

Input	Định dạng & giới hạn	Xử lý	Kết quả	Cách hiển thị	Rủi ro chính
Bệnh án số	PDF có lớp chữ, DOCX, FHIR Bundle (JSON) xuất từ cổng bệnh viện (nếu có)	Phát hiện lớp chữ → trích text trực tiếp (pdfplumber, python-docx); PDF scan → về pipeline ảnh; FHIR → map Condition/Observation trực tiếp, không cần LLM	Finding `record`, độ tin cậy cao hơn	Như ảnh chụp	PDF chứa script/macro → chuyển thành ảnh/text trong sandbox; FHIR sai profile
Mô tả bằng text	Tối đa 2.000 ký tự, VI/EN	Guardrail khẩn cấp trước → NER (triệu chứng, vị trí cơ thể, thời gian) → mapping vùng	Finding `patient_reported`, không có mã chẩn đoán	Nét đứt, biểu tượng "bạn mô tả", không tô màu mức độ	Biến thành công cụ kiểm tra triệu chứng (symptom checker) — cấm; chỉ hiển thị vị trí và gợi ý câu hỏi cho bác sĩ
Ảnh CT (DICOM)	ZIP một hoặc vài series CT, ≤ 1 GB (cấu hình), chỉ modality CT ở v2	Kiểm tra DICOM → khử định danh (PS3.15, xóa tag, kiểm chữ in trên ảnh) → lưu → segmentation cơ quan → dựng mesh → căn với mô hình mẫu	Mesh cơ quan của chính người dùng + vị trí tổn thương **theo báo cáo đọc phim**	Lớp "CT của bạn" tách riêng; trình xem lát cắt	Chi phí GPU, dung lượng lớn, nguy cơ trở thành SaMD

26.2 Mô hình finding chung (ví dụ)

```
{
  "findingId": "0191…",
  "subjectKey": "sk_…",
  "sourceType": "record | patient_reported | image_derived",
  "evidence": [{"kind": "document", "documentId": "…", "page": 2, "bbox":
[120, 340, 610, 372], "quote": "K phổi phải T2N1M0"}],
  "condition": {"icd10": "C34.1", "text": "Ung thư thùy trên phổi phải"},
  "region": {"code": "lung_r_upper", "laterality": "right",
"mappingConfidence": 0.92, "precision": "segment"},
  "severity": "severe",
  "observedAt": "2026-03-02",
  "status": "confirmed",
  "organStatus": "present"
}
```

Quy tắc: `image_derived` chỉ mô tả **giải phẫu** (cơ quan của bạn trông thế nào), không bao giờ tự tạo finding bệnh lý. Vị trí tổn thương trên CT lấy từ báo cáo của bác sĩ chẩn đoán hình ảnh đi kèm (ví dụ "nốt 12 mm hạ phân thùy S6"), được đặt vào mesh cơ quan tương ứng.

26.3 Pipeline CT chi tiết (v2)

1. **Upload:** ZIP qua presigned multipart upload vào quarantine; giới hạn kích thước và số file.
2. **Kiểm tra:** đọc header DICOM (pydicom), chỉ nhận Modality = CT, đủ lát cắt liên tục, độ dày lát ⩽ 5 mm.
3. **Khử định danh:** áp dụng Basic Application Confidentiality Profile (xóa/thay tag tên, ngày sinh, mã bệnh nhân, tên cơ sở…), đổi UID, OCR kiểm tra chữ in trên ảnh; giữ bản gốc mã hóa chỉ để người dùng tải lại.
4. **Lưu trữ:** S3 phi (Singapore). Lưu ý: AWS HealthImaging hiện chỉ có ở us-east-1, us-west-2, ap-southeast-2 (Sydney), eu-west-1, eu-west-2 — **chưa có ở Singapore**.
5. **Segmentation:** TotalSegmentator chạy trên GPU theo yêu cầu (AWS Batch với GPU Spot hoặc SageMaker Asynchronous Inference, scale về 0 khi không dùng); CPU làm phương án dự phòng chậm hơn.
6. **Dựng mesh:** marching cubes từ mask → làm mượt → giảm polygon → GLB, đặt tên mesh theo region_code qua bảng ánh xạ nhãn TotalSegmentator → region_code.
7. **Căn chỉnh:** xem mục 27 (đưa mesh của bạn về hệ tọa độ mô hình mẫu).

8. **Hiển thị:** trình xem lát cắt (OHIF/Cornerstone3D) + lớp 3D "CT của bạn"; nhãn rõ "hình minh họa giải phẫu, không phải kết quả đọc phim".

26.4 Phương án triển khai cho từng loại input

Input	Phương án A (đơn giản, rẻ)	Phương án B (cân bằng — khuyến nghị)	Phương án C (doanh nghiệp)
Ảnh chụp	LLM vision đọc trực tiếp ảnh	OCR local + LLM trích xuất từ text, LLM vision chỉ cho vùng chữ tay	Thêm model layout riêng (LayoutLM) fine-tune trên dữ liệu Việt Nam
Bệnh án số	Chỉ PDF có lớp chữ	PDF + DOCX + FHIR Bundle	Tích hợp trực tiếp cổng bệnh viện khi có thỏa thuận (SMART on FHIR)
Mô tả text	Chỉ lưu và hiển thị nguyên văn trong timeline	NER + mapping vùng, nhãn `patient_reported`	Thêm nhập bằng giọng nói (speech-to-text)
CT	Chỉ trình xem lát cắt + báo cáo đọc phim	Segmentation cơ quan + mesh của bạn + vị trí theo báo cáo	DICOMweb (Orthanc) + lưu trữ chuyên dụng (HealthImaging nếu chấp nhận region khác và đã làm OTIA)

26.5 Yêu cầu nghiệp vụ mới

Mã	Quy tắc
BR-040	Finding `patient_reported` không được gán mã ICD-10, không tô màu mức độ, luôn hiển thị nhãn "bạn mô tả".
BR-041	Mô tả text có dấu hiệu khẩn cấp → hiển thị số 115 trước mọi nội dung khác (giống BR-023).
BR-042	Ảnh CT chỉ được dùng để dựng giải phẫu minh họa; không tự động phát hiện hay đo tổn thương (giữ ngoài phạm vi SaMD — mục 22.2).

Mã	Quy tắc
BR-043	DICOM phải qua khử định danh trước khi vào bất kỳ bước xử lý nào; bản gốc chỉ người dùng tải lại được.
BR-044	Khi các nguồn mâu thuẫn, ưu tiên `record` > `image_derived` > `patient_reported` và hiển thị cảnh báo không khớp.
BR-045	Bệnh án số có lớp chữ được trích trực tiếp, không chạy OCR; FHIR hợp lệ được map không qua LLM.

27. Xử lý lệch giữa cơ thể người bệnh và mô hình mẫu

Mô hình 3D mẫu là một cơ thể "trung bình". Người dùng thật có thể khác về kích thước, giới, tuổi, thiếu cơ quan sau phẫu thuật, có dụng cụ cấy ghép hoặc biến thể giải phẫu. Nguyên tắc xử lý: **không bao giờ vẽ sai vị trí một cách tự tin**. MediLens chọn template gần nhất, đánh dấu trạng thái cơ quan theo hồ sơ, hiển thị độ chính xác của vị trí, và khi có CT thì dùng chính cơ thể người dùng.

27.1 Phân loại các loại lệch và cách xử lý

#	Loại lệch	Ví dụ	Nhận biết từ đâu	Cách xử lý	Hiển thị
1	Vóc dáng, giới, tuổi	Trẻ em, người rất cao/thấp, nam/nữ	Hồ sơ cá nhân (năm sinh, giới sinh học, chiều cao, cân nặng)	Chọn template theo nhóm (nam/nữ trưởng thành, 3 nhóm tuổi trẻ em); scale theo chiều cao/cân nặng (tham số hình thể kiểu SMPL cho bề mặt, cơ quan scale theo mốc)	Không cần cảnh báo
2	Cơ quan đã cắt bỏ / mất	Cắt thận, cắt túi mật, cắt cụt chi, nhổ răng	Hồ sơ ghi phẫu thuật/mất răng → `organStatus = removed/absent`	Ẩn mesh hoặc hiện "bóng mờ" kèm nhãn "đã cắt bỏ (theo hồ sơ, ngày…)"	Nét viền mờ + nhãn

#	Loại lệch	Ví dụ	Nhận biết từ đâu	Cách xử lý	Hiển thị
3	Dụng cụ cấy ghép	Máy tạo nhịp, stent, khớp nhân tạo, implant răng, đinh nẹp	Hồ sơ thủ thuật	Thư viện biểu tượng 3D cho dụng cụ, găn vào vùng tương ứng	Biểu tượng riêng, chú giải
4	Biến thể giải phẫu	Đảo ngược phủ tạng, thận hình móng ngựa, răng thừa	Hồ sơ ghi rõ	Nếu có mesh biến thể → thay; nếu không → giữ template + cảnh báo "giải phẫu của bạn khác hình mẫu" và ưu tiên sơ đồ 2D	Banner cảnh báo
5	Biến dạng do bệnh	Gan to, khối u lớn, tràn dịch	Kích thước trong hồ sơ (`size_mm`)	Không biến dạng mesh cơ quan; vẽ marker tổn thương theo tỉ lệ so với kích thước cơ quan chuẩn, có nhãn số đo	Marker có tỉ lệ + số đo
6	Độ chi tiết vị trí không khớp	Hồ sơ ghi "phổi phải" nhưng mesh chia thùy; hoặc ghi hạ phân thùy gan mà mesh chỉ có gan	Mapping trả `precision`	Cây vùng giải phẫu phân cấp: tô cả vùng cha với độ đậm thấp khi chỉ biết mức cha; vùng con khi biết chính xác	Nhãn "vị trí gần đúng"
7	Không rõ bên	"Thận" không ghi trái/phải	`laterality = unknown`	Tô nhạt cả hai bên, hỏi người dùng xác nhận trong màn review	Cảnh báo + câu hỏi
8	Lệch giữa CT của người dùng và template	Cơ quan ở vị trí/kích thước khác	Mesh từ CT	Căn chỉnh (27.3) hoặc hiển thị riêng chế độ "CT của bạn"	Lớp riêng, công tắc so sánh
9	Thay đổi theo thời gian	Trước/sau phẫu thuật	Timeline encounter	Trạng thái cơ quan theo từng mốc thời gian	Thanh trượt timeline

27.2 Cây vùng giải phẫu và độ chính xác vị trí

- Mỗi `region_code` có cha: `body → thorax → lung_r → lung_r_upper → lung_r_upper_apical`; mesh chỉ cần có ở một số mức, phần còn lại suy từ cây.
- Mapping trả về `precision ∈ {exact, segment, organ, system, body_part}` và `mappingConfidence`.
- Quy tắc hiển thị: `exact/segment` → tô vùng con; `organ` → tô cả cơ quan; `system/body_part` → tô nhạt vùng lớn và ghi "vị trí gần đúng"; confidence < 0,6 → `unmapped` (BR-015).
- Mỗi node trong cây có mã chuẩn tham chiếu (FMA hoặc SNOMED CT body structure khi có license) để Clinical Informaticist kiểm soát.

27.3 Căn chỉnh khi có CT (v2)

1. Segmentation cho ra mask các cơ quan và xương của người dùng.
2. Tính **mốc giải phẫu** (landmark): tâm đốt sống, xương ức, mào chậu, tâm các cơ quan.
3. Căn **rigid + affine** từ mốc của người dùng sang mốc của template (giải bài toán bình phương tối thiểu) để đưa về cùng hệ tọa độ, cùng hướng.
4. Tùy chọn **non-rigid** (thin-plate spline trên các mốc) để template "ôm" gần cơ thể người dùng khi cần so sánh.
5. **Ưu tiên hiển thị mesh cơ quan của chính người dùng** sau khi căn; template chỉ làm nền mờ. Như vậy vị trí tổn thương theo báo cáo đọc phim năm đúng trên cơ quan thật.
6. Kiểm tra chất lượng: khoảng cách trung bình giữa các mốc sau căn (ví dụ < 15 mm); vượt ngưỡng → chỉ hiển thị chế độ "CT của bạn", không trộn với template.

27.4 Trường dữ liệu bổ sung

Trường	Bảng	Ý nghĩa
`organ_status`	body_findings / organ_states	present, removed, absent_congenital, transplanted, implant_present
`variant_code`	organ_states	Mã biến thể giải phẫu (nếu hồ sơ ghi)
`device_type`	organ_states	Loại dụng cụ cấy ghép
`precision`	body_findings	Mức độ chi tiết vị trí

Trường	Bảng	Ý nghĩa
`template_id`	patient_profiles	Template đã chọn (giới, nhóm tuổi) + tham số scale
`registration_error_mm`	ct_studies	Sai số căn chỉnh CT

27.5 Phương án theo giai đoạn

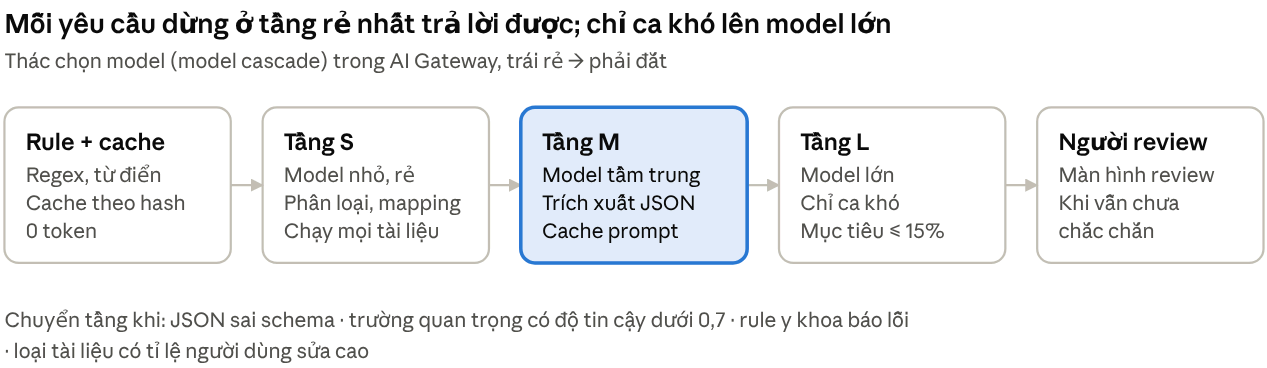
Phương án	Nội dung	Khi nào
A — Template cố định + cảnh báo	1 template người lớn + 2D; các loại lệch chỉ hiển thị băng nhãn	MVP
B — Thư viện template + trạng thái cơ quan	Template theo giới/nhóm tuổi, scale theo chiều cao/cân nặng, ẩn cơ quan đã cắt, biểu tượng dụng cụ, cây vùng phân cấp	v1.5
C — Giải phẫu cá nhân từ CT	Mesh từ CT của người dùng, căn chỉnh landmark, chế độ so sánh với template	v2

27.6 Kiểm thử

- Bộ test "giải phẫu đặc biệt": ≥ 30 hồ sơ synthetic có cắt bỏ cơ quan, implant, biến thể, không rõ bên, chỉ ghi mức cơ quan.
- Ảnh chụp viewer (visual regression) cho từng loại lệch.
- Clinical Safety Officer duyệt cách hiển thị từng loại (hazard: người dùng hiểu sai vị trí).

28. Chọn model và tối ưu token / chi phí

Chiến lược: **rule trước, model nhỏ sau, model lớn cuối cùng**. OCR và segmentation chạy bằng model mở tự host (0 token). LLM chỉ làm việc cần hiểu ngôn ngữ, và luôn qua AI Gateway để được cache, định tuyến, giới hạn và đo chi phí. Với giả định ở 28.4, chi phí AI ước khoảng **0,01 USD/tài liệu**, thấp hơn mục tiêu 0,10 USD khoảng 10 lần.



thác chọn model · 5 tầng từ rẻ đến đắt

Tỉ lệ chuyển lên Tầng L là chỉ số chi phí quan trọng nhất cần theo dõi; nếu vượt 15% thì cải thiện prompt/schema của Tầng M thay vì chấp nhận chi phí.

28.1 Gán model cho từng việc

Việc	Cách làm mặc định	Tầng	Ghi chú tiết kiệm
Kiểm tra chất lượng ảnh	OpenCV	Rule	0 token
OCR chữ in	PaddleOCR/VietOCR trên CPU (GPU khi tải cao)	Tự host	0 token
OCR chữ tay	LLM vision chỉ cho vùng cắt có độ tin cậy OCR thấp	M	Gửi vùng cắt, không gửi cả trang
Phân loại trang	Từ khóa + model nhỏ; sau này classifier tự train	S	Chỉ gửi 600 token đầu trang
Trích xuất trường	LLM structured output theo schema Unit	M → L khi cần	Cache system prompt + schema; chỉ gửi trang liên quan; khóa JSON ngắn; giới hạn output
Chuẩn hóa ICD-10/LOINC	Từ điển → embedding kNN → model nhỏ chọn trong top-5	Rule → S	Embedding tự host (bge-m3)
Mapping vùng	Rule → model nhỏ chọn trong danh sách region của Unit	Rule → S	Danh sách đóng, output rất ngắn
NER mô tả text	Model nhỏ	S	Input ngắn

Việc	Cách làm mặc định	Tầng	Ghi chú tiết kiệm
Giải thích RAG	Model tầm trung, câu trả lời ⩽ 250 từ	M	Cache phần hướng dẫn; cache câu hỏi phổ biến theo bài viết
Guardrail ý định	Rule + model nhỏ	Rule → S	Chạy trước khi gọi model lớn
Đánh giá offline (judge), sinh dữ liệu synthetic	Model lớn	L	Chạy batch ban đêm
Segmentation CT	TotalSegmentator	Tự host GPU theo yêu cầu	Scale về 0

28.2 Ứng viên model theo tầng (kiểm tra lại danh mục và region trước khi chốt)

Tầng	Ứng viên ví dụ	Tiêu chí chọn
S	Model mở cỡ nhỏ trên Bedrock (ví dụ họ Gemma, Ministral, Qwen cỡ nhỏ) hoặc model tự host qua vLLM/Ollama	Tiếng Việt đủ tốt cho phân loại/mapping trên dev set; giá thấp nhất
M	Model tầm trung có structured output và vision (ví dụ dòng Claude Haiku, Amazon Nova tầm trung)	F1 trích xuất trên golden set, hỗ trợ prompt caching, có ở region đã chọn
L	Model lớn (ví dụ dòng Claude Sonnet)	Chất lượng trên ca khó; chỉ dùng khi tầng M thất bại
Embedding	bge-m3 / multilingual-e5 tự host, hoặc embedding đa ngôn ngữ trên Bedrock	Recall trên bộ câu hỏi tiếng Việt

Chọn băng **bake-off**: chạy cùng golden set trên 2–3 ứng viên mỗi tầng, so F1, độ trễ, chi phí/tài liệu; ghi ADR. Lặp lại mỗi quý hoặc khi có model mới.

28.3 Đòn bẩy giảm chi phí

Đòn bẩy	Mức tiết kiệm tham khảo	Áp dụng ở MediLens
Batch inference	Khoảng 50% so với on-demand cho một số model (Bedrock pricing)	Eval ban đêm, xử lý lại khi đổi schema, sinh synthetic
Prompt caching	Cache read rẻ hơn input thường khoảng 90% ở ví dụ trên trang giá; cache write đắt hơn một chút	System prompt + JSON Schema + ví dụ cố định đặt đầu prompt
Flex tier	Giảm 50% so với Standard cho một số nhà cung cấp	Việc không gấp
Cascade + escalation	Tỷ lệ lên tầng L ⩽ 15%	AI Gateway
Cache kết quả	100% cho tài liệu trùng	Key = sha256(tài liệu) + prompt_version + model
Giảm token đầu vào	30–60% tùy tài liệu (ước tính)	Bỏ header/footer lặp, chỉ gửi trang có nội dung lâm sàng, OCR đã làm sạch
Giới hạn output	—	`max_tokens` theo schema; câu trả lời giải thích ⩽ 250 từ
Quota & ngân sách	Chặn chi phí bất thường	Quota/người/ngày, ngân sách/ngày, circuit breaker
Distillation	Chuyển việc từ tầng M xuống S	Fine-tune model nhỏ trên output đã được người xác nhận + synthetic (khi đủ dữ liệu, qua cổng G1-D)

28.4 Công thức và ví dụ chi phí

```
C_{doc} = \sum_{s} r_s \left( T^{new}_{in,s} P_{in,s} + T^{cache}_{in,s} P_{cache,s} + T_{out,s} P_{out,s} \right) + G_{sec} \cdot P_{gpu}
```

Trong đó `r_s` là tỉ lệ tài liệu đi qua bước s, `T` là số token, `P` là giá mỗi token, `G_sec` là số giây GPU.

Ví dụ cho tài liệu 3 trang (~2.500 token OCR). **Giá dưới đây là giả định để minh họa**: tầng S 0,15/0,15 USD mỗi triệu token (băng giá Ministral 8B tại region Mỹ trên trang giá Bedrock), tầng M 1/5 USD, tầng L 3/15 USD, cache read = 10% giá input. Hãy thay băng giá thật của region đã chọn.

Bước	Tầng	Tỉ lệ qua	Token (in mới / in cache / out)	Chi phí (USD)
Phân loại trang	S	100%	600 / 0 / 20	0,00009
Trích xuất	M	100%	2.500 / 1.500 / 800	0,00665
Mapping 5 finding	S	100%	1.000 / 0 / 100	0,00017
Chuyển lên tầng L	L	12%	4.000 / 0 / 800	0,00288
Tổng mỗi tài liệu				**≈ 0,0098**
Một câu hỏi giải thích	M	—	1.000 / 2.000 / 300	0,0027

Với 100 người dùng/tháng, mỗi người 5 tài liệu và 20 câu hỏi: khoảng 4,9 + 5,4 ≈ **10 USD/tháng** cho token.

Tự host có đáng không? Một máy GPU giả định 1 USD/giờ chạy liên tục tốn khoảng 720 USD/tháng. Chỉ hòa vốn khi xử lý khoảng 720 / 0,0098 ≈ **73.000 tài liệu/tháng** (chưa tính công vận hành). Với quy mô cá nhân, dùng API theo token rẻ hơn nhiều. Tự host chỉ nên làm để học, hoặc chạy GPU theo lô và scale về 0.

28.5 Ba phương án vận hành model

Phương án	Nội dung	Ưu	Nhược	Khi nào
A — API một model	Một model tầm trung cho mọi việc	Đơn giản	Đắt hơn 2–3 lần so với B, phụ thuộc một nhà cung cấp	Foundation, prototype
B — Cascade qua AI Gateway (khuyến nghị)	Rule → S → M → L, cache, batch, quota	Chi phí thấp, đổi model dễ	Cần eval tốt để đặt ngưỡng	Từ Build MVP

Phương án	Nội dung	Ưu	Nhược	Khi nào
C — Distill + tự host	Fine-tune model nhỏ cho trích xuất, phục vụ bằng vLLM/SageMaker hoặc Bedrock Custom Model Import	Không phụ thuộc giá token, dữ liệu không rời VPC	Chi phí GPU cố định, cần MLOps, cần dữ liệu đủ license	Quy mô lớn hoặc yêu cầu dữ liệu không rời hệ thống

28.6 Duy trì model

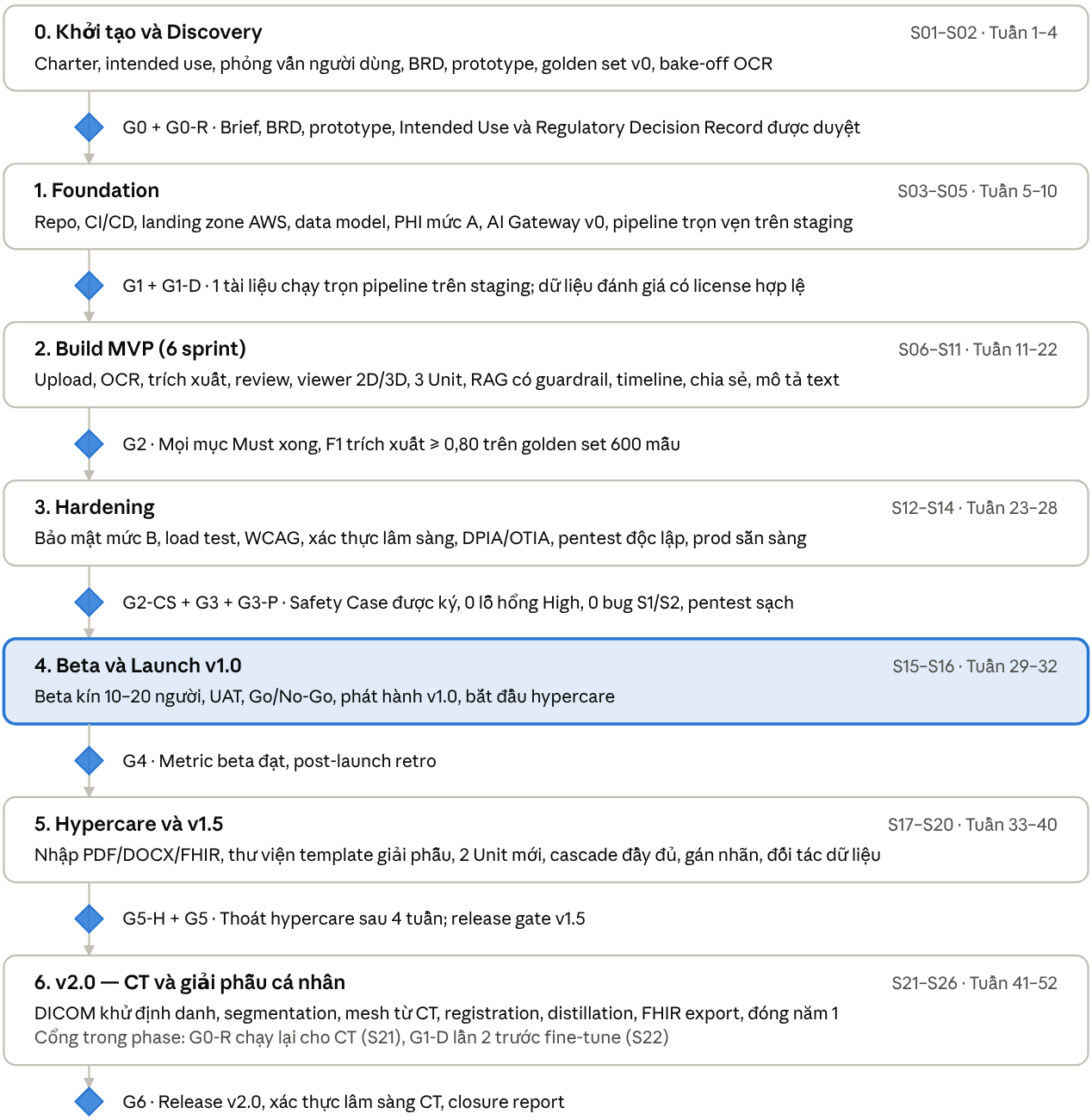
- **Model registry:** mỗi cấu hình (provider, model ID ghim phiên bản, prompt version, ngưỡng chuyển tầng) có ID và Model Card.
- **Bake-off hằng quý** và khi nhà cung cấp ra model mới hoặc báo ngừng model cũ.
- **Fallback provider** cho từng tầng; đổi qua AppConfig trong < 5 phút.
- **Dashboard chi phí:** USD/tài liệu, tỉ lệ chuyển tầng, cache hit rate, token trung bình mỗi bước; cảnh báo khi vượt ngân sách ngày.
- **Ngưỡng số liệu:** cache hit ≥ 60% cho phần prompt cố định; chuyển tầng L ≤ 15%; chi phí ≤ 0,03 USD/tài liệu (mục tiêu dài hạn ở mục 10).

29. Kế hoạch sprint dài hạn: 52 tuần, 26 sprint

Lộ trình này thay cho lộ trình 32 tuần ở mục 5. Năm phase đầu giữ nguyên thời lượng nên **v1.0 vẫn ra mắt ở tuần 32**; sau đó thêm **Hypercare và v1.5** (tuần 33–40) và **v2.0 với ảnh CT** (tuần 41–52). Mỗi sprint gồm 10 ngày làm việc × 4 giờ (20 giờ/tuần), tổng 260 ngày và 1.040 giờ. Việc của từng ngày (role, skill cần gọi, đầu ra, tiêu chí xong) nằm trong file **MediLens_Sprint_Plan_52w.xlsx** gửi kèm trong cuộc trò chuyện.

v1.0 vẫn ra mắt ở tuần 32; v2.0 với CT hoàn tất ở tuần 52

26 sprint × 10 ngày làm việc, 20 giờ/tuần; hình thoi = cổng phải đạt trước khi sang phase tiếp



lộ trình 52 tuần · 7 phase, 14 cổng

Năm cổng gốc G0–G4 giữ nguyên. Năm cổng bổ sung ở mục 22.4 được đặt vào đúng sprint, thêm G5 (phát hành v1.5) và G6 (phát hành v2.0). G0-R chạy lại ở S21 trước khi làm CT; G1-D chạy lần hai ở S22 trước khi fine-tune model.

29.1 Mục tiêu từng sprint

Sprint	Tuần	Mục tiêu	Cổng
S01	1–2	Khởi tạo: charter, intended use, nghiên cứu người dùng	
S02	3–4	Khóa phạm vi MVP, BRD, prototype, golden set v0, chọn OCR	G0, G0-R
S03	5–6	Repo, CI, landing zone AWS, VPC Terraform, khung auth	
S04	7–8	Data model, ranh giới PHI mức A, upload an toàn, design system	
S05	9–10	Pipeline AI end-to-end trên staging, AI Gateway v0	G1, G1-D
S06	11–12	Upload, state machine, OCR với trạng thái realtime	
S07	13–14	Trích xuất LLM, màn Review, cascade model v1	
S08	15–16	Viewer 2D toàn thân + Unit Răng hàm mặt	
S09	17–18	Viewer 3D + Unit Tim mạch	
S10	19–20	Unit Ung bướu + giải thích RAG có guardrail	
S11	21–22	Timeline pre/post, mô tả text, chia sẻ, admin, quyền dữ liệu	G2
S12	23–24	Bảo mật mức B, hiệu năng, WCAG 2.2 AA	
S13	25–26	An toàn lâm sàng, pháp lý, usability tổng kết	G2-CS
S14	27–28	Pentest độc lập, UAT, prod sẵn sàng	G3, G3-P
S15	29–30	Beta kín 10–20 người	
S16	31–32	Phát hành v1.0	G4
S17	33–34	Hypercare + nhập bệnh án số (PDF, DOCX, FHIR)	
S18	35–36	Thư viện template giải phẫu + đóng góp dữ liệu opt-in	G5-H
S19	37–38	Unit Hô hấp, Thận–Tiết niệu + cascade model đầy đủ	

Sprint	Tuần	Mục tiêu	Cổng
S20	39–40	Gán nhãn, đối tác dữ liệu, phát hành v1.5	G5
S21	41–42	Tái đánh giá pháp lý cho CT + tiếp nhận DICOM an toàn	G0-R (CT)
S22	43–44	Viewer lát cắt, segmentation, dựng mesh từ CT	G1-D (lần 2)
S23	45–46	Căn chỉnh với template (registration) + liên kết báo cáo CT	
S24	47–48	Distillation + tối ưu chi phí model	
S25	49–50	FHIR export, hardening v2, xác thực lâm sàng CT	
S26	51–52	Phát hành v2.0 + đóng năm 1	G6

29.2 Nhịp làm việc trong một sprint

- **Ngày 1:** Sprint Planning 1 giờ (chọn story, viết Sprint Goal), thời gian còn lại làm việc chính của ngày.
- **Ngày 2–9:** mỗi ngày một việc chính, đội một mũ role. Cột Skill cho biết skill agent cần gọi, ví dụ `medilens-backend-engineer`; việc nhiều role thì gọi `medilens-orchestrator`. Mỗi sáng viết daily note 5 phút.
- **Ngày 5:** thêm 1 giờ refinement cho sprint sau (mũ BA).
- **Ngày 10:** Review (video demo ⩽ 5 phút), Retro, cập nhật risk register, chấm cổng nếu sprint có cổng; thời gian còn lại là buffer cho việc trễ.
- **Việc định kỳ** (chi phí hằng tuần, báo cáo steering hằng tháng, rà soát license và bake-off model hằng quý, DR drill 6 tháng một lần) nằm ở sheet Recurring và làm kèm việc chính, không chiếm dòng riêng.

29.3 File Excel gồm những gì

Sheet	Dùng để
Dashboard	Sprint hiện tại, việc hôm nay, cổng kế tiếp, % hoàn thành so với tiến độ kỳ vọng, số việc quá hạn
Settings	Ngày bắt đầu và số giờ mỗi ngày (ô vàng); mọi ngày khác tự tính lại

Sheet	Dùng để
Roadmap, Gantt	7 phase trên 52 tuần, màu theo phase, ◆ là tuần có cổng
Sprints	26 sprint: mục tiêu VI/EN, demo, cổng, role, rủi ro trọng tâm, giờ và % xong
Daily Plan	260 ngày: ngày, role, skill, việc VI/EN, đầu ra, tiêu chí xong; bạn cập nhật Trạng thái, Giờ thực tế, Ghi chú
Gates	14 cổng: tiêu chí VI/EN, băng chứng, người duyệt, trạng thái
Roles	22 role, skill tương ứng, số ngày và số giờ theo kế hoạch
Recurring, Holidays, Change Log	Việc định kỳ; lịch nghỉ lễ 2026–2027; nhật ký thay đổi baseline

Ngày trong file được tính bằng hàm WORKDAY, bỏ qua cuối tuần và ngày nghỉ lễ. Lịch nghỉ đã nạp gồm 24/11/2026 (Ngày Văn hóa Việt Nam theo Nghị quyết 28/2026/QH16), Tết Dương lịch, Tết Nguyên đán 04–10/02/2027 (lịch của cán bộ, công chức theo thông báo của Bộ Nội vụ), Giỗ Tổ 16/04/2027, 30/4, 1/5 và 02–03/09/2027. Với ngày bắt đầu mặc định 19/10/2026, kế hoạch kết thúc ngày 01/11/2027. Nếu nơi bạn làm việc có lịch nghỉ khác, sửa sheet Holidays.

29.4 Phân bổ thời gian theo role

Theo kế hoạch gốc, AI/ML chiếm nhiều giờ nhất (108 giờ, khoảng 10%), tiếp theo là PM và Backend (100 giờ mỗi role), Frontend (80 giờ) và QA (76 giờ). Chín role mới chiếm khoảng 27% thời gian: Clinical Safety 48 giờ, Regulatory & Privacy 44, MLOps 40, Medical Imaging 32, Technical Writer 32, Data Curator 28, Support 24, Clinical Informaticist 20, 3D Medical Artist 16. Sheet Roles tự cập nhật khi bạn đổi role của một ngày.

29.5 Khi bị trễ

1. Dùng buffer của ngày 10 trước.
2. Trễ quá 2 ngày: cắt mục Should trong sprint (ví dụ bớt một biến thể template); không cắt kiểm thử, bảo mật hay cổng.
3. Trễ cả sprint: ghi Change Request vào sheet Change Log rồi mới dời các sprint sau; không gộp hai cổng thành một.

4. Hai sprint liên tiếp trễ: steering xem lại phạm vi (rủi ro R03 ở mục 11). Phương án dự phòng là giữ v1.5 và dời v2.0 sang năm 2.